

PBI zaliczenie

1. Proces realizowany przez podsystem kontroli dostępu logicznego systemu komputerowego, gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do pliku, nazywa się
2. Stosowana w określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków, nazywa się

Proces realizowany przez podsystem kontroli dostępu logicznego systemu komputerowego, gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do pliku, nazywa się:

Wybierz jedną odpowiedź:

- ☐ a. weryfikację uwierzytelnienia
- ☒ b. weryfikację autoryzacji
- ☐ c. weryfikację poziomu ochrony
- ☐ d. weryfikację tożsamości

[Odznacz mój wybór](#)

Stosowana w określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków, nazywa się:

Wybierz jedną odpowiedź:

- ☐ a. zasadą dwóch osób
- ☐ b. zasadą rotacji obowiązków
- ☐ c. zasadą minimalnego środowiska pracy
- ☒ d. zasadą wiedzy koniecznej

[Odznacz mój wybór](#)

1. Podstawowe atrybuty informacji związane z jej bezpieczeństwem to
2. Dokument Polityka bezpieczeństwa informacyjnego powinien być dokumentem zawierającym

Podstawowe atrybuty informacji związane z jej bezpieczeństwem to:

Wybierz jedną odpowiedź:

- ☒ a. tajność, integralność, dostępność
- ☐ b. integralność, metoda szyfrowania, dostępność
- ☐ c. tajność, integralność, długość (w bajtach)
- ☐ d. tajność, integralność, długość (w znakach)

[Odznacz mój wybór](#)

Dokument Polityka bezpieczeństwa informacyjnego powinien być dokumentem zawierającym:

Wybierz jedną odpowiedź:

- ☐ a. szczegółowe plany obiegu informacji i schematy sieci teleinformatycznych
- ☒ b. zapis najważniejszych, ogólnych zamiarów działań kierownictwa organizacji w zakresie bezpieczeństwa własnych i powierzonych informacji i jego deklaracje co do zapewniania odpowiedniego poziomu tego bezpieczeństwa
- ☐ c. instrukcje i procedury dla osób korzystających z systemów teleinformatycznych organizacji
- ☐ d. wykaz stosowanych w organizacji podstawowych zabezpieczeń informacji

[Odznacz mój wybór](#)

1. Norma PN-ISO/IEC-15408 dotyczy
2. Podpis cyfrowy ma za zadanie zapewnić

Norma PN-ISO/IEC-15408 dotyczy:

Wybierz jedną odpowiedź:

- ☐ a. sposobów archiwizowania informacji
- ☐ b. klas metod kryptograficznych
- ☒ c. konstrukcji i oceny „bezpiecznych” produktów informatycznych
- ☐ d. systemu zarządzania bezpieczeństwem informacji

[Odznacz mój wybór](#)

Podpis cyfrowy ma za zadanie zapewnić:

Wybierz jedną odpowiedź:

- ☐ a. tylko integralność informacji
- ☐ b. tylko poufność i autentyczność informacji
- ☐ c. dostępność informacji
- ☒ d. niezaprzeczalność, autentyczność, integralność informacji

[Odznacz mój wybór](#)

1. Zgodnie z ustawą z dn. 05.08.2010 „O ochronie informacji niejawnych” informację niejawną oznacza się klauzulą:
2. Incydent z zakresu bezpieczeństwa informacyjnego to

Zgodnie ustawą z dn. 05.08.2010 „O ochronie informacji niejawnych” informację niejawną oznacza się klauzulą:

Wybierz jedną odpowiedź:

- ☐ a. „tajne” lub „poufne” lub „zastrzeżone”
- ☐ b. „ściśle tajne” lub „tajne” lub „poufne” lub „do użytku wewnętrznego”
- ☒ c. „ściśle tajne” lub „tajne” lub „poufne” lub „zastrzeżone”
- ☐ d. „ściśle tajne” lub „tajne” lub „poufne”

[Odznacz mój wybór](#)

Incydent z zakresu bezpieczeństwa informacyjnego to:

Wybierz jedną odpowiedź:

- ☐ a. stan systemu informacyjnego, który powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- ☒ b. zdarzenie lub ciąg zdarzeń (składających się na realizację zagrożenia) które powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- ☐ c. zawsze i tylko rezultat działania cyberprzestępcy
- ☐ d. proces ujawniania podatności w systemie informacyjnym

[Odznacz mój wybór](#)

1. Minimalny zbiór cech skutecznego systemu ochrony informacji przetwarzanej w systemach informacyjnych obejmuje
2. Test penetracyjny to

Minimalny zbiór cech skutecznego systemu ochrony informacji przetwarzanej w systemach informacyjnych obejmuje:

Wybierz jedną odpowiedź:

- ☐ a. dywersyfikację i spójność zastosowanych zabezpieczeń
- ☐ b. dywersyfikację i niesprzeczność zastosowanych zabezpieczeń
- ☒ c. dywersyfikację, spójność, niesprzeczność zastosowanych zabezpieczeń i organizację ochrony „w głąb”
- ☐ d. dywersyfikację oraz spójność zastosowanych zabezpieczeń i organizację ochrony w „w głąb”

[Odznacz mój wybór](#)

Test penetracyjny to:

Wybierz jedną odpowiedź:

- ☐ a. metoda oddziaływania socjotechnicznego
- ☒ b. metoda zbierania informacji o badanym systemie
- ☐ c. to samo, co audyt bezpieczeństwa informacyjnego
- ☐ d. metoda włamywania się do systemu informatycznego

[Odznacz mój wybór](#)

1. Promieniowanie ujawniające
2. Incydent z zakresu bezpieczeństwa informacyjnego to

zawie 1
w udzielono
spowiedzi
punkty: 100
Odpowiedz
złote

Promieniowanie ujawniające:

Wybierz jedną odpowiedź:

- ☐ a. jest promieniowaniem elektromagnetycznym stanowiącym zagrożenie dla tajności informacji przetwarzanej w systemie komputerowym
- ☐ b. nie stanowi żadnego zagrożenia
- ☐ c. jest promieniowaniem akustycznym i/lub elektromagnetycznym stanowiącym zagrożenie dla tajności informacji przetwarzanej w systemie komputerowym
- ☒ d. jest promieniowaniem akustycznym i/lub elektromagnetycznym stanowiącym zagrożenie dla tajności i integralności informacji przetwarzanej w systemie komputerowym

[Odznacz mój wybór](#)

zawie 2
w udzielono
spowiedzi
punkty: 100
Odpowiedz
złote

incydent z zakresu bezpieczeństwa informacyjnego to:

Wybierz jedną odpowiedź:

- ☐ a. zawsze i tylko rezultat działania cyberprzestępcy
- ☐ b. stan systemu informacyjnego, który powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- ☐ c. proces ujawniania podatności w systemie informacyjnym
- ☒ d. zdarzenie lub ciąg zdarzeń (składających się na realizację zagrożenia) które powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji

[Odznacz mój wybór](#)

Następna strona

Nawigacja

1

2

Zakończ po

Pozostały

1. Parametr Recovery Time Actual (RTA) określa

2. Poprawna treść Zasady Kerckhoffs'a to

Pytanie 3

Odpowiedź zapisano

Punkty: 100

0% Oflaga pytań

Parametr Recovery Time Actual (RTA) określa:

Wybierz jedną odpowiedź:

☒

 a. maksymalny, możliwy do zaakceptowania przez kierownictwo organizacji, ze względu na ponoszone straty, czas pracy bez możliwości korzystania z usług całości lub części systemu informatycznego

☐

 b. ustalany drogą eksperymentów czas przywrócenia działania systemu informatycznego i odtworzenia zbiorów danych

☐

 c. „akceptowalne straty w danych” (aktualność danych odtworzonych po katastrofie) mierzone czasem od ostatniej kopii zapasowej do chwili katastrofy

☐

 d. wymaganą długość przerwy w przetwarzaniu danych, niezbędnej do wykonania kopii zapasowej[Odrzuć mój wybór](#)

Pytanie 4

Odpowiedź zapisano

Punkty: 100

0% Oflaga pytań

Poprawna treść Zasady Kerckhoffs'a to:

Wybierz jedną odpowiedź:

☒

 a. Odporność kryptosystemu powinna zależeć od utrzymania tajemnicy przekształceń używanych w tym kryptosystemie, a nie od tajemnicy klucza wybierającego konkretne przekształcenie

☐

 b. Odporność kryptosystemu powinna zależeć od utrzymania tajemnicy klucza wybierającego konkretne przekształcenie, a nie od tajemnicy przekształceń używanych w tym kryptosystemie

[Odrzuć mój wybór](#)

Poprzednia strona

Następna strona

PREVIOUS ACTIVITY

◀ Ogłoszenia

Przejdź do...

2

1. Kopiowanie (w celu wytwarzania kopii bezpieczeństwa), w którym w wybranym dniu...

2. Terminem „hoax” określa się

Pytanie 5

Nie udzielono odpowiedzi

Punkty: 100

0% Oflaga pytań

Kopiowanie (w celu wytwarzania kopii bezpieczeństwa), w którym w wybranym dniu tygodnia zapisujemy komplet danych, natomiast w pozostałe dni robocze zapisujemy jedynie dane zmienne od ostatniego kopiowania nazywamy:

Wybierz jedną odpowiedź:

☐

 a. pełnym

☐

 b. lustrzanym

☒

 c. przyrostowym

☐

 d. różnicowym[Odrzuć mój wybór](#)

Pytanie 6

Nie udzielono odpowiedzi

Punkty: 100

0% Oflaga pytań

Terminem „hoax” określa się:

Wybierz jedną odpowiedź:

☐

 a. programowy obiekt złośliwy przeprowadzający działania destrukcyjne w systemie

☐

 b. sprzętowy obiekt złośliwy posiadający zdolność powielania się

☒

 c. rodzaj ataku socjotechnicznego – żart rozsyłany pocztą elektroniczną☐[Odrzuć mój wybór](#)

Poprzednia strona

Następna strona

PREVIOUS ACTIVITY

◀ Ogłoszenia

Przejdź do...

2

1. Czy podatność jest warunkiem koniecznym realizacji zagrożenia
2. Sandbox to

7
Wskazanie odpowiedzi
Punkty: 100
Pytanie

Czy podatność jest warunkiem koniecznym realizacji zagrożenia:

Wybierz jedną odpowiedź:

☒ a. TAK

☐ b. NIE

[Odnacz mój wybór](#)

8
Wskazanie odpowiedzi
Punkty: 100
Pytanie

Sandbox to:

Wybierz jedną odpowiedź:

☐ a. rodzaj testu penetracyjnego wykonywany z zewnątrz, bez znajomości struktury oraz konfiguracji testowanego środowiska

☐ b. metoda porównania analizowanego obiektu z bazą sygnatur wirusów

☒ c. mechanizm służący do separacji programów oraz wykonywania niezaufanego kodu w odizolowanym środowisku

☐ d. skaner portów

[Odnacz mój wybór](#)

[Poprzednia strona](#) [Następna strona](#)

1. Inspektora bezpieczeństwa teleinformatycznego wyznacza się, zgodnie z odpowiednią ...
2. Informacja, której zmanipulowanie, uniedostępnienie lub ujawnienie może wyrządzić ...

Pytanie 9
Nie udzielano odpowiedzi
Punkty: 100
Pytanie

Inspektora bezpieczeństwa teleinformatycznego wyznacza się, zgodnie z odpowiednią ustawą, w przypadku przetwarzania w systemach teleinformatycznych:

Wybierz jedną odpowiedź:

☐ a. danych bankowych

☐ b. informacji wrażliwych

☒ c. danych osobowych

☐ d. informacji niejawnych

[Odnacz mój wybór](#)

Pytanie 10
Odpowiedź zapisana
Punkty: 100
Pytanie

Informacja, której zmanipulowanie, uniedostępnienie lub ujawnienie może wyrządzić szkody firmie lub osobie prywatnej to informacja:

Wybierz jedną odpowiedź:

☒ a. wrażliwa

☐ b. publiczna

☐ c. niejawną

☐ d. podatna

[Odnacz mój wybór](#)

[Poprzednia strona](#) [Zapisz podejście ...](#)

PREVIOUS ACTIVITY
◀ Ogłoszenia

Przejdź do...

Pomoc techniczna:

1. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

2. czego dotyczy norma ISO27001

Jest specyfikacją systemów zarządzania bezpieczeństwem informacji na zgodność z którą mogą być prowadzone audyty, na podstawie których są wydawane certyfikaty.

W normie ISO/IEC 27001 wyróżniono jedenaście obszarów, mających wpływ na bezpieczeństwo informacji w organizacji:

1. Polityka bezpieczeństwa;
2. Organizacja bezpieczeństwa informacji;
3. Zarządzanie aktywami;
4. Bezpieczeństwo zasobów ludzkich;
5. Bezpieczeństwo fizyczne i środowiskowe;
6. Zarządzanie systemami i sieciami;
7. Kontrola dostępu;
8. Zarządzanie ciągłością działania;
9. Pozyskiwanie, rozwój i utrzymanie systemów informatycznych;
10. Zarządzanie incydentami związanymi z bezpieczeństwem informacji;
11. Zgodność z wymaganiami prawnymi i własnymi standardami.

3. Czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

4. Jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa niejawny, dokument do użytku wewnętrznego

„Instrukcja bezpieczeństwa teleinformatycznego ... zawiera zasady postępowania w zakresie bezpieczeństwa teleinformatycznego dla osób korzystających z systemów teleinformatycznych; dokument do użytku wewnętrznego.”

5. Jaki poziom ochrony powinien mieć dokument polityka bezpieczeństwa jawny

„Zawiera najważniejsze ogólne ustalenia dotyczące działania firmy/instytucji w zakresie ochrony informacji”

6. jakie klauzule odpowiadają tajemnicy państwowej.

Informacje niejawne zaklasyfikowane jako stanowiące tajemnicę państwową oznaczają się klauzulą:

ściśle tajne - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować istotne zagrożenie dla niepodległości, nienaruszalności terytorium albo polityki zagranicznej lub stosunków międzynarodowych Rzeczypospolitej Polskiej albo zagrażać nieodwracalnymi lub wielkimi stratami dla interesów obronności, bezpieczeństwa państwa i obywateli lub innych istotnych interesów państwa, albo narazić je na szkodę w wielkich rozmiarach,

tajne - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować zagrożenie dla międzynarodowej pozycji państwa, interesów obronności, bezpieczeństwa państwa i obywateli, innych istotnych interesów państwa albo narazić je na znaczną szkodę.

7. jakie klauzule odpowiadają tajemnicy służbowej

Informacje niejawne zaklasyfikowane jako stanowiące tajemnicę służbową oznaczają się klauzulą:

poufne - w przypadku gdy ich nieuprawnione ujawnienie powodowałoby szkodę dla interesów państwa, interesu publicznego lub prawnie chronionego interesu obywateli,

zastrzeżone - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować szkodę dla prawnie chronionych interesów obywateli albo jednostki organizacyjnej.

8. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje

zasada wiedzy koniecznej (Skrypt 113)???

9. hoax - co to jest

Z ang: głupi żart; głupi kawał; głupi dowcip

Fałszywka (hoax) to wykorzystanie ludzkiej niewiedzy do rozprzestrzenienia podanej informacji. Polega to na tym, że użytkownik otrzymuje wiadomość (poprzez sieć, telefonicznie czy podczas rozmowy) o pewnym zdarzeniu powodującą podjęcie przez niego określonego działania. Może to być np. otrzymanie maila z wiadomością, że plik o podanej nazwie jest wirusem i można się go pozbyć jedynie poprzez usunięcie tego pliku. W rzeczywistości plik nie jest wirusem i może być nawet częścią systemu operacyjnego, a jego usunięcie może spowodować nieprzewidziane skutki. Użytkownik najczęściej zastosuje się do wskazówek zawartych w otrzymanej wiadomości i w dobrej wierze rozpowszechni ją dalej (w przypadku maili spowoduje to niepotrzebny wzrost generowanego w sieci ruchu). Oprócz wywołania zamieszania fałszywki mogą również przyczynić się do poniesienia szkód (np. otrzymanie wiadomości o awarii serwera i prośbie o wysłanie hasła do konta na podany adres). Walczyć z takimi fałszywymi alarmami jest szczególnie trudno gdyż nigdy nie ma 100% pewności czy są one prawdziwe czy nie. Najlepiej jest mieć ograniczone zaufanie do podejrzanych i pochodzących z niepewnych źródeł wiadomości i sprawdzać ich wiarygodność w serwisach antywirusowych.

10. Miara bezpieczeństwa w common criteria.

Common Criteria (norma ISO 15408) - norma pozwalająca w sposób formalny weryfikować bezpieczeństwo systemów teleinformatycznych.

CC udostępnia procedury pozwalające na zdefiniowanie zagrożeń oraz zabezpieczeń, które na te zagrożenia odpowiadają, a następnie przeprowadzenie formalnej weryfikacji ich faktycznego działania w produkcji. Certyfikacją według normy CC zajmują się niezależne, akredytowane laboratoria badawcze na całym świecie.

Wynikiem procesu certyfikacji jest tzw. "profil ochrony" (PP - *protection profile*), który definiuje zabezpieczenia stosowane przez produkt oraz certyfikat, potwierdzający ich faktyczną skuteczność. Proces certyfikacji może być prowadzony według różnych poziomów szczegółowości i weryfikacji formalnej (EAL - *Evaluation Assurance Level*), począwszy od EAL1 (tylko testy funkcjonalne) aż do EAL7 (formalna weryfikacja projektu oraz testy).

Posiadanie certyfikatu CC *nie gwarantuje* że produkt jest bezpieczny pod każdym względem - zapewnia jedynie o działaniu wszystkich *zadeklarowanych* przez producenta zabezpieczeń. Sam certyfikat niewiele więc mówi bez profilu ochrony opisującego zastosowane zabezpieczenia. Dla popularnych produktów (np. bezpieczne urządzenie do składania podpisu elektronicznego) istnieją ustandaryzowane profile ochrony.

Starszą, ale nadal stosowaną w certyfikacji normą tego typu jest ITSEC.

10b. Co zapewnia Common Criteria i standard ISO/IEC 15408 ?

Odpowiedni poziom zaufania.

11. Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność (Skrypt 124)

W szerszym rozumieniu podpis elektroniczny posiada cztery główne cechy:

autentykacja – uniemożliwienie podszywania się pod daną osobę i wystania w jej imieniu przesyłki, np. zlecenia dokonania przez bank operacji;

integralność – zapewnienie wykrywalności wszelkiej zmiany w danych przesyłki, zlecenia na drodze od nadawcy do odbiorcy i podczas przechowywania jej u odbiorcy;

autoryzacja – zapewnienie niemożliwości wyparcia się podpisu i treści przesyłki (zlecenia) przez autora;

umożliwienie weryfikacji podpisu przez osobę niezależną.

12. Czy w prawie karnym jest paragraf za włamania komputerowe

Tak (Skrypt 96 – 99)

12. Jaka norma jest od Systemu zarządzania bezpieczeństwem

Pytanie 2 - norma ISO27001

13. Różnica pomiędzy pełnym audytem informatycznym , a audytem bezpieczeństwa teleinformatycznego

Audyt – [ocena](#) danej [osoby](#), [organizacji](#), [systemu](#), [procesu](#), [projektu](#) lub [produktu](#). Audyt jest przeprowadzany w celu upewnienia się co do prawdziwości i rzetelności [informacji](#), a także oceny systemu [kontroli wewnętrznej](#).

Standard COBIT (Control Objectives for Information and Related Technology) opracowany i rozwijany w ramach ISACA (Information Systems Audit and Control Association). Standard ten zawiera "Control Objectives", czyli tak zwane Punkty Kontrolne, gdzie określone są 302 szczegółowe wymagania przypisane do 34 procesów przebiegających w systemie informatycznym. Jeżeli audyt będzie dotyczył wszystkich procesów, ocenionych zarówno przez pryzmat pierwszo jak i drugorzędnych kryteriów, będzie to pełny audyt informatyczny. Jeżeli procesy będą oceniane tylko wg wybranych kryteriów, np. poufności, integralności i dostępności to możemy mówić o audycie bezpieczeństwa informatycznego. Audyt bezpieczeństwa inf. jest tylko częścią audytu informatycznego

Pełny audyt informatyczny jest nadzbioorem audytu bezpieczeństwa teleinformatycznego

14. Na czym bazuje autoryzacja dostępu

- na przedmiocie posiadanym przez osobę autoryzowaną (przepustka)
- cechach fizycznych (odcisk palca, skan siatkówki oka)
- jego wiedzy (PIN, hasło)

15. Do czego wykorzystywany jest outsourcing?

Transfer ryzyka

Outsourcing – wykorzystywanie zasobów zewnętrznych, zlecanie wyspecjalizowanym podmiotom zewnętrznym procesów niezbędnych dla funkcjonowania własnego przedsiębiorstwa, które zostaną tam zrealizowane efektywniej niż byłoby to możliwe we własnym zakresie. Outsourcing jest częścią szerszego zagadnienia - strategii przedsiębiorstwa w obszarze [sourcingu](#).

Zwykle dotyczy to zadań pomocniczych, nie związanych bezpośrednio z uzyskiwaniem [dochodu](#). Współcześnie bardzo często outsource'owane są [usługi ochroniarskie](#), [prawnicze](#), [informatyczne](#), księgowe, rekrutacyjne, wynajem pracowników (outsourcing personalny), utrzymywanie czystości itd. Niektóre firmy idą znacznie dalej, outsource'ując np. support lub część [produkcji](#). Wśród dużych zachodnich [koncernów](#) rozpowszechniła się praktyka outsource'owania znacznej części produkcji do krajów o tańszej sile roboczej, zwłaszcza do krajów [azjatyckich](#) – szczególną popularnością cieszą się usługi firm [hinduskich](#).

Najczęstszą przyczyną wprowadzania praktyk outsourcingowych jest chęć obniżenia kosztów i uniknięcia sytuacji [korupcyjnych](#).

16. Metody uwierzytelniania pracowników

Weryfikacja z elem. z pytania 14

17. Co nie jest plikiem systemowym NTFS

\$Sector.

1. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

2. czego dotyczy norma ISO27001

>3. czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

4. jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa jawny

5. jakie klauzule odpowiadają tajemnicy państwowej

tajność , ścisła tajność

6. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje

zasada wiedzy koniecznej ((??) Skrypt 113)

7. hoax - co to jest

(tu nie wiem jakie były możliwości, wg wikipedii hoax to mistyfikacja ☺)

1. Miara bezpieczeństwa w common criteria (norma iso 15194 czy jakoś tak) - jest to poziom uzasadnionego zaufania.

2. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

3. Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność (Skrypt 124)

4. Zasada dostępu tylko do takich informacji przez pracownika , które mu są w tej chwili potrzebne to:

zasada wiedzy koniecznej (Skrypt 113)

5. Czy w prawie karnym jest paragraf za włamania komputerowe

Tak (Skrypt 96 – 99)

6. Jaka norma jest od Systemu zarządzania bezpieczeństwem

norma ISO27001

7. Różnica pomiędzy pełnym audytem informatycznym , a audytem bezpieczeństwa teleinformatycznego

różnica jest taka że pełny audyt jest nadzbiorem audytu bezpieczeństwa.

8. Jakie etykiety ma wiadomość sklasyfikowana jako tajemnica państwowa

tajność , ścisła tajność

9. Jaki powinien być dokument "Planowania bezpieczeństwa dla ..."

powinien być jawny.

10. Na czym bazuje autoryzacja dostępu

na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

Dla testu B

1. atrybuty informacji: **(tajność, integralność, dostępność)**

2. czy w polskim prawie karnym jest paragraf na włamania **(tak)** (chyba par. 255k.k. <- poza konkursem)

3. jaki poziom ochrony powinien mieć dokument polityka bezpieczeństwa **(jawny)**

4. w teście B zad 1 coś z normą PN/ISO xxxx45 odpowiedź **a)** (najmniej pasująca)

5. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje **(zasada wiedzy koniecznej)**

6. weryfikacja tożsamości użytkownika na podstawie **rzeczy** (np klucz), **cech fizycznych** (np odcisk palca, zdjęcie), **wiedzy** (np hasło)

7. było coś z normą PN/ISO 27001 ale nie pamiętam już co.

8. Nie pamiętam pytania, to jest konkluzja -> **Pełny audyt informatyczny jest nadzbiorem audytu bezpieczeństwa teleinformatycznego**

norma 15408 - norma pozwalająca w sposób formalny weryfikować bezpieczeństwo systemów teleinformatycznych

wymagania bezpieczeństwa, jakościowe- to są oceny opisowe, art. 267,

outsourcing - powierzenie przez organizację realizacji określonego procesu (własności procesu – process ownership) usługodawcy określając szczegółowo efekty, jakie zlecający zamierza uzyskać, ale bez instrukcji dotyczących sposobu wykonywania poszczególnych zadań, pozostawiając inicjatywę w tym zakresie zlecającemu

retencja – zbieranie i przechowywanie informacji np. nr IP, itp.

Audyt informatyczny - jest to proces zbierania i oceniania dowodów w celu określenia czy system informatyczny i związane z nim zasoby właściwie chronią majątek, utrzymują integralność danych i dostarczają odpowiednich i rzetelnych informacji, osiągają efektywnie cele organizacji, oszczędnie wykorzystują zasoby i stosują mechanizmy kontroli wewnętrznej, tak aby dostarczyć rozsądnego zapewnienia, że osiągnięte są cele operacyjne i kontrolne, oraz że chroni się przed niepożądanymi zdarzeniami lub są one na czas wykrywane a ich skutki na czas korygowane

Poufność –zapewnieniu, że informacja nie jest udostępniana lub ujawniana nieautoryzowanym osobom, podmiotom lub procesom,

Integralność –zapewnieniu, że dane nie zostały zmienione lub zniszczone w sposób nieautoryzowany,

Dostępność –zapewnieniu bycia osiągalnym i możliwym do wykorzystania na żądanie, w założonym czasie, przez autoryzowany podmiot,

Rozliczalność –zapewnieniu, że działania podmiotu mogą być przy pisane w sposób jednoznaczny tylko temu podmiotowi,

Autentyczność –zapewnieniu, że tożsamość podmiotu lub zasobu jest taka, jak deklarowana (autentyczność dotyczy użytkowników, procesów, systemów i informacji),

Niezaprzeczalność – braku możliwości wyparcia się swego uczestnictwa w całości lub w części wymiany danych przez jeden z podmiotów uczestniczących w tej wymianie,

Niezawodność –zapewnieniu spójności oraz zamierzonych zachowań i skutków

ISO/IEC 27001:2007 jest specyfikacją systemów zarządzania bezpieczeństwem [informacji](#) na zgodność z którą mogą być prowadzone [audyty](#), na podstawie których są wydawane [certyfikaty](#)^[1].

W normie ISO/IEC 27001 wyróżniono jedenaście obszarów, mających wpływ na bezpieczeństwo informacji w organizacji:

1. Polityka bezpieczeństwa;
2. Organizacja bezpieczeństwa informacji;
3. Zarządzanie aktywami;
4. Bezpieczeństwo zasobów ludzkich;
5. Bezpieczeństwo fizyczne i środowiskowe;
6. Zarządzanie systemami i sieciami;
7. Kontrola dostępu;
8. Zarządzanie ciągłością działania;
9. Pozyskiwanie, rozwój i utrzymanie systemów informatycznych;

10. Zarządzanie incydentami związanymi z bezpieczeństwem informacji;
11. Zgodność z wymaganiami prawnymi i własnymi standardami.

- 1) ubezpieczenie czegoś to -> transfer ryzyka
- 2) aplikacja sandbox zapewnia -> integralność
- 3) informacja zawarte są w normie -> iso 27001
- 4) Podpis cyfrowy - odpowiedź A
- 5) Pracownik ma przydzielone prawa -> zasada minimalnego środowiska
- 6) Dokument plan bezpieczeństwa jest -> tajny
- 7) Przez opracowanie planu -> minimalizujemy straty
- 8) cechy -> integralność, tajność, dostępność
- 9) audyt teleinformatyczny -> testy penetracyjne
- 10) najdłuższa odpowiedź z dywersyfikacją

1. Ubezpieczenie jest -> transferem ryzyka.
2. Polityka bezpieczeństwa -> dokument jawny.
3. Atrybuty informacji.
4. Cechy podpisu elektronicznego.
5. Pracownicy powinni mieć dostęp do sprzętu, oprogramowania, itp. zgodnie z... zasadą minimalnego środowiska pracy
6. Czy pliki są usuwane całkowicie z dysku...? -> odpowiedź z flagami
7. Audyt informatyczny vs. audyt teleinformatyczny
8. Pytanie o normę PN-ISO/IEC 27001
9. Cechy systemu informatycznego (czy jakoś tak)
10. Ogólnie chodziło o to, że poprzez plan awaryjny minimalizujemy skutki powstałe na wskutek kryzysu.

Zestaw C:

1. Ubezpieczenie zalicza się do....

kontroli ryzyka

retencji ryzyka

transferu ryzyka

2. Co się dzieje z plikiem po usunięciu z dysku:

wpis w \$MFT jest usuwany, dane zostają

wpis w \$MFT zostaje, dane zostają i zmieniają się dwie flagi

wpis w \$MFT jest usuwany, dane są usuwane

wpis w \$MFT zostaje, dane zostają

3. W którym dokumencie opisano System zarządzania bezpieczeństwem informacji:

ISO 27001

ISO 15408

4. Podpis cyfrowy zapewnia:

niezaprzeczalność, autentyczność i integralność

5. Minimalny zestaw wymagań na system zabezpieczeń:

dywersyfikacja i spójność

dywersyfikacja, niezaprzeczalność i organizacja wg zasady ochrony "w głąb"

dywersyfikacja, niezaprzeczalność, spójność i organizacja wg zasady ochrony "w głąb"

dywersyfikacja i organizacja wg zasady ochrony "w głąb" (chyba)

6. Zasada, żeby pracownik do wykonywania pracy miał tylko dostęp do tych programów i usług, których potrzebuje, to:

zasada minimalnego środowiska pracy

zasada wiedzy koniecznej

zasada dwóch ludzi

7. Atrybuty informacji w kontekście bezpieczeństwa:

poufność, integralność, dostępność

8. Coś o audycie bezpieczeństwa teleinformatycznego:

zawiera się w audycie informatycznym (jest podzbiorem audytu informatycznego coś takiego)

9. Poprzez sporządzenie i w razie potrzeby wdrożenie planu odzyskiwania:

minimalizujemy ryzyko

minimalizujemy zagrożenia

minimalizujemy podatności

minimalizujemy straty wynikłe z wykorzystania podatności przez zagrożenia

10. Dokument "Polityka bezpieczeństwa dla ..." powinien być:

jawny

Akty prawne dotyczące bezpieczeństwa systemów teleinformatycznych w Polsce

Polityka bezpieczeństwa to zbiór ogólnych zasad i podstawowych wymagań określających w jaki sposób powinny być zarządzane udostępnianie i chronione przed nieupoważnionym wykorzystaniem, zniszczeniem lub nieautoryzowanymi zmianami materialne i informacyjne aktywa organizacji

***Rozp. Prezesa Rady Ministrów z dnia 25 sierpnia 2005 r. w sprawie podstawowych wymagań bezpieczeństwa teleinformatycznego**

„Bezpieczeństwo teleinformatyczne zapewnia się, chroniąc informacje przetwarzane w systemach i sieciach teleinformatycznych przed utratą właściwości gwarantujących to bezpieczeństwo, w szczególności przed utratą poufności, dostępności i integralności.”

***Obszary bezpieczeństwa:** organizacja;;; systemy informacyjne;;; systemy teleinformatyczne

***Podstawowe założenia bezpieczeństwa teleinformatycznego:** podstawowymi założeniami bezpieczeństwa teleinformatycznego jest zapewnienie poniższych właściwości:

- poufności, czyli zapobieganiu nieupoważnionego udostępnienia lub wyjawienia informacji,
- dostępności, zdefiniowanej jako właściwość bycia dostępnym i użytecznym na żądanie upoważnionego podmiotu,
- integralności danych, polegającej na zapobieganiu celowej lub przypadkowej modyfikacji informacji przez nieupoważnionego użytkownika oraz zachowaniu spójności zewnętrznej i wewnętrznej,
- autentyczności, polegającej na sprawdzeniu i potwierdzeniu tożsamości podmiotu lub zasobu i jego upoważnienia do informacji,
- niezawodności, czyli zdolności systemu do spełnienia wymagań,
- rozliczalności, zapewniającej iż działania podmiotu mogą być przypisane w sposób jednoznaczny tylko temu podmiotowi.

***Przepisy obowiązujące prawa dotyczące bezpieczeństwa informatycznego.**

1. Konstytucja RP;
2. Ustawa z dnia 22.01.1999 r. „o ochronie informacji niejawnej”.
3. Rozporządzenie Prezesa Rady Ministrów z dn. 25.02.1999 „w sprawie podstawowych wymagań bezpieczeństwa systemów i sieci teleinformatycznych
6. Ustawa z dn. 29.08.97 „o ochronie danych osobowych
9. Ustawa z dn. 18.09.2001 „o podpisie elektronicznym
13. Ustawa z dn. 10.01.2003 „o zmianie ustawy – Kodeks postępowania karnego, ustawy – Przepisy zmieniające Kodeks postępowania karnego, ustawy o świadczeniu usług drogą elektroniczną oraz ustawy o ochronie informacji niejawnych
14. Ustawa z dn. 27.07.2001 „o ochronie baz danych
16. Ustawa z dn.18.07.2002 „o świadczeniu usług drogą elektroniczną”.

Poza tym, w prawie polskim wyróżnia się:

Tajemnice postępowania administracyjnego i karnego, tajemnicę lekarską, tajemnicę skarbową, tajemnicę handlową, tajemnicę bankową, tajemnicę ubezpieczeń społecznych, tajemnicę publicznego obrotu papierami wartościowymi, tajemnicę dziennikarską, tajemnicę pomocy społecznej itd.

*** Zakres ochrony informacji Ustawa z dnia 22 stycznia 1999r. o ochronie informacji niejawnych:**

- organizowanie ochrony informacji niejawnych,
- klasyfikowanie informacji niejawnych,
- udostępnianie informacji niejawnych,
- postępowanie sprawdzające, w celu ustalenia, czy osoba nim objęta daje rękojmię zachowania tajemnicy, zwanego dalej "postępowaniem sprawdzającym",
- szkolenie w zakresie ochrony informacji niejawnych,
- ewidencjonowanie, przechowywanie, przetwarzanie i udostępnianie danych uzyskiwanych w związku z prowadzonymi postępowaniami o ustalenie rękojmi zachowania tajemnicy, w zakresie określonym w ankiecie bezpieczeństwa osobowego oraz w kwestionariuszu bezpieczeństwa przemysłowego,
- organizacja kontroli przestrzegania zasad ochrony informacji niejawnych,
- ochrona informacji niejawnych w systemach i sieciach teleinformatycznych,
- stosowanie środków fizycznej ochrony informacji niejawnych.

***obszar zastosowania ustawy o ochronie informacji niejawnych**

- 1) Organy władzy publicznej, w szczególności: Sejm i Senat Rzeczypospolitej Polskiej;;; Prezydenta Rzeczypospolitej Polskiej;;; organów administracji rządowej;;; organów jednostek samorządu terytorialnego;;; sądów i trybunałów;;; organów kontroli państwowej i ochrony prawa.
- 2) Siły Zbrojne Rzeczypospolitej Polskiej i ich jednostki organizacyjne, a także inne jednostki organizacyjne podległe Ministrowi Obrony Narodowej lub przez niego nadzorowane.
- 3) Narodowy Bank Polski i banki państwowe.
- 4) Państwowe osoby prawne i inne niż wymienione w pkt. 1-3 państwowe jednostki organizacyjne.
- 5) Przedsiębiorcy, jednostek naukowych lub badawczo-rozwojowych, zamierzających ubiegać się, ubiegających się o zawarcie lub wykonujących umowy związane z dostępem do informacji niejawnych albo wykonujących na podstawie przepisów prawa zadania związane z dostępem do informacji niejawnych.

***tajemnica państwowa** - informacja określona w wykazie rodzajów informacji, stanowiącym załącznik nr 1, której nieuprawnione ujawnienie może spowodować istotne zagrożenie dla podstawowych interesów Rzeczypospolitej Polskiej, dotyczących porządku publicznego, obronności, bezpieczeństwa, stosunków międzynarodowych lub gospodarczych państwa,

***tajemnica służbowa** - informacja niejawna nie będąca tajemnicą państwową, uzyskana w związku z czynnościami służbowymi albo wykonywaniem prac zleconych, której nieuprawnione ujawnienie mogłoby narazić na szkodę interes państwa, interes publiczny lub prawnie chroniony interes obywateli albo jednostki organizacyjnej,

*** dokument** - każda utrwalona informacja niejawna, w szczególności na piśmie, mikrofilmach, negatywach i fotografiach, nośnikach do zapisów informacji w postaci cyfrowej i na taśmach elektromagnetycznych, także w formie mapy, wykresu, rysunku, obrazu, grafiki, fotografii, broszury, książki, kopii, odpisu, wypisu, wyciągu i tłumaczenia dokumentu, zbiegłego lub wadliwego wydruku, odbitki, kliszy, matrycy i dysku optycznego, kalki, taśmy atramentowej, jak również informacja niejawna utrwalona na elektronicznych nośnikach danych,

***materiał** - dokument, jak też chroniony jako informacja niejawna przedmiot lub dowolna jego część, a zwłaszcza urządzenie, wyposażenie lub broń wyprodukowana albo będąca w trakcie produkcji, a także składnik użyty do ich wytworzenia,

***system teleinformatyczny** - system, który tworzą urządzenia, narzędzia, metody postępowania i procedury stosowane przez wyspecjalizowanych pracowników, w sposób zapewniający wytwarzanie, przechowywanie, przetwarzanie lub przekazywanie informacji,

***sieć teleinformatyczna** - organizacyjne i techniczne połączenie systemów teleinformatycznych,

***akredytacja bezpieczeństwa teleinformatycznego** - dopuszczenie systemu lub sieci teleinformatycznej do wytwarzania, przetwarzania, przechowywania lub przekazywania informacji niejawnych, na zasadach określonych w ustawie,

***dokumentacja bezpieczeństwa systemu lub sieci informatycznej** - Szczególne Wymagania Bezpieczeństwa oraz Procedury Bezpiecznej Eksploatacji danego systemu lub sieci teleinformatycznej, sporządzone zgodnie z zasadami określonymi w ustawie,

***Klasyfikowanie informacji niejawnych. Klauzule tajności na podstawie ustawy o ochronie informacji niejawnych**

1. Klasyfikowanie informacji niejawnej oznacza przyznanie tej informacji, w sposób wyraźny, przewidzianej w ustawie jednej z klauzul tajności.
2. Klasyfikowanie informacji niejawnej zawartej w materiale, a zwłaszcza utrwalonej w dokumencie, polega na oznaczeniu tego materiału odpowiednią klauzulą tajności.
3. Informacjom niejawnym, materiałom, a zwłaszcza dokumentom lub ich zbiorom, przyznaje się klauzulę tajności co najmniej równą najwyższej zaklasyfikowanej informacji lub najwyższej klauzuli w zbiorze.
4. Dopuszczalne jest przyznawanie różnych klauzul tajności częściom dokumentu (rozdziałom, załącznikom, aneksom) lub poszczególnym dokumentom w zbiorze dokumentów, pod warunkiem wyraźnego ich oznaczenia i wskazania klauzuli tajności po odłączeniu dokumentu bądź jego części.

*** Informacje, które mogą być oznaczane klauzulą "ściśle tajne,, na podstawie ustawy o ochronie informacji niejawnych**

- Informacje dotyczące zagrożeń zewnętrznych bezpieczeństwa państwa o charakterze militarnym, plany i prognozowanie obronne oraz wynikające z nich decyzje i zadania.
- Szczegółowa struktura, organizacja i funkcjonowanie systemu kierowania państwem oraz dowodzenia Siłami Zbrojnymi w czasie zagrożenia państwa lub wojny.
- Lokalizacja, wyposażenie, właściwości ochronne i organizacja obrony stanowisk kierowania państwem i stanowiska dowodzenia Siłami Zbrojnymi w czasie zagrożenia państwa lub wojny.
- Szczegółowa organizacja, funkcjonowanie systemów łączności kierowania państwem i dowodzenia Siłami Zbrojnymi w czasie wyższych stanów gotowości bojowej lub wojny.
- Informacje dotyczące planowania, organizacji i funkcjonowania mobilizacyjnego rozwinięcia Sił Zbrojnych.
- Planowanie i realizacja przedsięwzięć w zakresie operacyjnego maskowania wojsk.
- Planowanie, realizacja, wyniki badań naukowych i prac badawczo-rozwojowych o szczególnie ważnym znaczeniu dla obronności i bezpieczeństwa państwa.
- Hasła i kody dostępu do urządzeń przechowujących, przetwarzających i przesyłających informacje oznaczone klauzulą "ściśle tajne".
- Szczególne wymagania bezpieczeństwa i procedury bezpiecznej eksploatacji systemów i sieci teleinformatycznych służących do wytwarzania, przetwarzania, przekazywania lub przechowywania informacji oznaczonych klauzulą "ściśle tajne".
- Organizacja, funkcjonowanie i środki techniczne radiokontrywiewadowczej ochrony państwa.

*** Informacje, które mogą być oznaczane klauzulą "tajne,, – wybór na podstawie ustawy o ochronie informacji niejawnych**

- Planowanie, rozmieszczenie i stan rezerw państwowych.
- Resortowe i wojewódzkie programy mobilizacji gospodarki.
- Plany obrony cywilnej państwa oraz plany obrony cywilnej województw.
- Organizacja kompleksowego przygotowania jednolitej sieci telekomunikacyjnej państwa dla potrzeb obronnych.
- Wojskowe mapy specjalne i fotodokumenty przedstawiające uczyelnione obiekty inżynierijnej rozbudowy prognozowanych rejonów i kierunków działań wojennych.
- Organizacja i funkcjonowanie systemu alarmowania wojsk oraz zadania jednostek wojskowych i garnizonów w procesie osiągania wyższych stanów gotowości bojowej.
- Szczegółowe informacje dotyczące organizacji, metod i środków służących do ochrony informacji stanowiących tajemnicę państwową, których ujawnienie może spowodować brak ich skuteczności, chyba że zawierają informacje oznaczone wyższą klauzulą tajności.
- Szczególne wymagania bezpieczeństwa i procedury bezpiecznej eksploatacji systemów i sieci teleinformatycznych służących do wytwarzania, przetwarzania, przekazywania lub przechowywania informacji oznaczonych klauzulą "tajne".
- Szczegółowe informacje dotyczące systemu i sposobu ochrony granicy państwowej w tym działań antyterrorystycznych i antysabotażowych.
- Szczegółowe informacje dotyczące ochrony i zabezpieczenia obiektów szczególnie ważnych dla gospodarki narodowej albo ze względu na obronność lub bezpieczeństwo państwa.
- Instrukcje do negocjacji w sprawie zawierania umów finansowych o znaczeniu ogólnopaństwowym, których ujawnienie mogłoby mieć wpływ na dalszy tok negocjacji.
- Decyzje o skokowych zmianach kursu złotego w stosunku do walut obcych (dewaluacja, rewaluacja) dokonywane przez Narodowy Bank Polski do czasu podania ich do publicznej wiadomości.
- Prace badawczo-rozwojowe o szczególnie istotnym znaczeniu dla interesu gospodarczego państwa, zlecone przez ministrów i inne centralne organy państwowe.
- Informacje niejawnie wymieniane przez RP z NATO, UE oraz z innymi organizacjami międzynarodowymi i państwami, oznaczone klauzulą "SECRET" lub równorzędną, jeżeli wymagają tego umowy międzynarodowe, na zasadzie wzajemności.

***Informacje niejawnie - zasady postępowania na podstawie ustawy o ochronie informacji niejawnych**

1. Mogą być udostępnione wyłącznie osobie uprawnionej do dostępu do informacji niejawnych o określonej klauzuli tajności,
 2. Muszą być wytwarzane, przetwarzane, przekazywane lub przechowywane w warunkach uniemożliwiających ich nieuprawnione ujawnienie, zgodnie z przepisami określającymi wymagania dotyczące kancelarii tajnych, obiegu i środków fizycznej ochrony informacji niejawnych, odpowiednich dla przynajmniej jednej z klauzul tajności
 3. Muszą być chronione, odpowiednio do przynajmniej jednej z klauzul tajności, przy zastosowaniu środków określonych w rozdziałach 9 i 10 ustawy.
- *strefa bezpieczeństwa** - obszar, obiekt, fragment budynku, jedno lub kilka pomieszczeń, w których przechowywane, przetwarzane lub wytwarzane są informacje niejawnie o klauzuli co najmniej "POUFNE", posiadający ściśle określone i strzeżone granice oraz system kontroli wejść i wyjść:
- "I strefa bezpieczeństwa** - obszar chroniony w taki sposób, że wejście do niego oznacza bezpośredni dostęp do informacji niejawnej; osoby upoważnione do dostępu do informacji niejawnych, co najmniej o klauzuli informacji przechowywanych w strefie, nie będące żołnierzami albo pracownikami jednostki lub komórki organizacyjnej (interesanci) mogą w niej przebywać jedynie po uzyskaniu zgody kierownika tej jednostki organizacyjnej (komórki organizacyjnej MON) i pod nadzorem żołnierza lub pracownika pionu ochrony,
- "II strefa bezpieczeństwa** - obszar, obiekt, fragment budynku, jedno lub kilka pomieszczeń, chroniony w taki sposób, że wejście do tej strefy nie oznacza bezpośredniego dostępu do informacji niejawnej; osoby upoważnione do dostępu do informacji niejawnych, co najmniej o klauzuli informacji przechowywanych w strefie, nie będące żołnierzami albo pracownikami jednostki lub komórki organizacyjnej (interesanci) mogą w niej przebywać bez nadzoru, za zgodą kierownika komórki organizacyjnej objętej tą strefą,
- * strefa administracyjna** - obszar, obiekt, fragment budynku przylegający do I lub II strefy, w którym zapewniona jest kontrola ruchu osób i pojazdów;
- *baza danych** oznacza zbiór danych lub jakichkolwiek innych materiałów i elementów zgromadzonych według określonej systematyki lub metody, indywidualnie dostępnych w jakikolwiek sposób, w tym środkami elektronicznymi, wymagający istotnego, co do jakości lub ilości, nakładu inwestycyjnego w celu sporządzenia, weryfikacji lub prezentacji jego zawartości,
- *pobieranie danych** oznacza stałe lub czasowe przejście lub przeniesienie całości lub istotnej, co do jakości lub ilości, części zawartości bazy danych na inny nośnik, bez względu na sposób lub formę tego przejścia lub przeniesienia,
- *wstępne wykorzystanie** oznacza publiczne udostępnienie bazy danych w dowolnej formie, a w szczególności poprzez rozpowszechnianie, bezpośrednie przekazywanie lub najem, z zastrzeżeniem,
- *producentem bazy danych** jest osoba fizyczna, prawna lub jednostka organizacyjna nie posiadająca osobowości prawnej, która ponosi ryzyko nakładu inwestycyjnego przy tworzeniu bazy danych.

***Bezpieczeństwo teleinformatyczne** to wszelkie aspekty związane z definiowaniem, osiąganiem i utrzymywaniem poufności, integralności, dostępności, rozliczalności, autentyczności i niezawodności.

***Usługi ochrony informacji**

- **Poufność** - obrona przekazywanej informacji przed osobami nieuprawnionymi
- **Uwierzytelnianie** - zapewnienie autentyczności informacji
- **Podpis cyfrowy** - potrzebny, jeżeli nie ma pełnego zaufania między nadawcą a odbiorcą (bo uwierzytelnienie by wystarczyło)
- **Niezaprzeczalność** - pozbawienie możliwości nadawcy i odbiorcy zaprzeczenia, że informację posłano
- **Kontrola dostępu** - możliwość ograniczenia i kontrolowania dostępu do systemu i programów
- **Nienaruszalność (integralność)** - gwarancja, że informacja jest odebrana w takiej postaci, w jakiej ją nadano
- **Pliki rozliczalności i audyt**

***ZAGROŻENIA**

Ochrona informacji: **ze względu na zamiar działania** (wynikające z celowego działania, nie będące skutkiem celowego działania); **ze względu na cel ataku** (związane z dostępem do informacji, związane z dostępem do usług systemu)

Atak na bezpieczeństwo: ataki aktywne, ataki pasywne

***ATAKI AKTYWNE**

Maskarada – polega na podszywaniu się pod inną stację np. nadawcę danych lub użytkownika, udawaniu kogoś innego. Celem maskarady może być np. zdobycie chronionej informacji lub zdeorganizowanie pracy w sieci, zwiększenie uprawnień swoich lub innego użytkownika, tworzenie fałszywych źródeł lub uścis informacji, symulowanie pokwitowań wiadomości.

Modyfikacje – nie wykrywalna zmiana treści danych może dotyczyć zarówno przechowywanych danych jak i przesyłanych, jest to atak godzący w integralność danych. Ataki: zmiany; dodawanie; kasowanie.

Potrząsk – ma miejsce gdy stacja ma zainstalowany ukryty mechanizm umożliwiający wytworzenie nieuprawnionego efektu na rozkaz, określone zdarzenie lub sekwencje zdarzeń, np. uaktywnienie zainstalowanego wirusa komputerowego skasowanie danych itp.

Odmowa usług – ma miejsce w sytuacji gdy stacja nie spełnia swoich funkcji lub uniemożliwia właściwą pracę innych stacji, uprawnieni użytkownicy nie mogą korzystać z zasobów systemu zarówno z powodu zniszczenia systemu jak i z powodu jego chwilowej niedostępności.

Powtórzenia – polegają na ponownym nadaniu przesłanej już informacji w celu wytworzenia nieuprawnionego efektu np. komunikat zawierający informację uprawniającą, powtórzony przez inną stację, może spowodować zwiększenie jej uprawnień

Wjazd na barana - polega na wprowadzeniu do kanału transmisyjnego własnych danych w czasie trwania seansu łączności między uprawnionymi stacjami np. w czasie oczekiwania stacji na pokwitowanie lub podczas rozmowy telefonicznej.

***ATAKI PASYWNE**

Przechwytywanie – polega na odkryciu treści przesyłanego komunikatu. Jeżeli natomiast przechwytywanie powoduje przejście przez intruza całego ruchu, tak że nie dociera on do autoryzowanego adresata, wówczas taki typ ataku należy zaklasyfikować jako typ ataku aktywnego.

Analiza ruchu – wnioskowanie informacji na podstawie obserwacji ruchu w sieci np. o rozmieszczeniu użytkowników, tożsamości wymienianych informacji, badanie długości i budowy komunikatów i częstotliwości z jaką są wysyłane.

Emisja ujawniająca - elektromagnetyczne przenikanie sygnałów do otaczającej przestrzeni przewodów i konstrukcji metalowych umożliwiających detekcję informacji.

Socjotechnika – próba skutecznego oddziaływania na użytkowników sieci w celu wywołania pożądaných zachowań zgodnie z wolą atakującego.

***DO NAJPOWAŻNIEJSZYCH ZAGROŻEŃ NALEŻĄ:** Podszywanie, modyfikacja, odmowa usług, złośliwe oprogramowanie, luki w programie.

- **Podszywanie** - stacja nieautoryzowana udaje inną stację autoryzowaną, w celu zdobycia niejawnych informacji

- **Modyfikacja** - zmiana treści danych np. podczas transmisji

- **Odmowa usług** - stacja nie spełnia swoich funkcji z powodu zniszczenia systemu lub zajęcia całej dostępnej pamięci oraz gdy stacja uniemożliwia właściwą pracę innych stacji np. poprzez generowanie sztucznych ruchów; nowsza wersja ataku DoS jest to DDoS (ang. Distributed Denial of Service) – czyli rozproszona odmowa usługi, polegająca na tym, że atakujące pakiety pochodzą z dziesiątek czy nawet setek różnych źródeł jednocześnie;

***ZŁOŚLIWE OPROGRAMOWANIE** – robak, wirus trojan, dialer, exploit

- **EXPLOIT** wykorzystuje występujący w oprogramowaniu błąd programistyczny i przejmując kontrolę nad działaniem procesu

- **DIALER** wykorzystuje nieświadomość użytkownika i łączy się poprzez numer dostępowy o kosztach wielokrotnie przekraczających typowe koszty dostępu do Internetu.

- **ROBAK KOMPUTEROWY** to samoreplikujący się program komputerowy. Rozprzestrzenia się we wszystkich sieciach podłączonych do zarażonego komputera poprzez wykorzystanie luk w systemie operacyjnym oraz naiwności użytkownika

- **SQL/URL INJECTION** - forma ataku na bazę danych poprzez stronę WWW i komendy języka SQL. Służy wyciąganiu informacji z bazy danych niedostępnych dla zwykłego użytkownika. Atakujący może zmodyfikować zapytanie kierowane do bazy danych poprzez modyfikację adresu URL o nieautoryzowane polecenia języka SQL.

***WIRUS** - program lub fragment wrogłego wykonanego kodu, który dołącza się, nadpisuje lub zamienia inny program w celu reprodukcji samego siebie bez zgody użytkownika.

- kasowanie i niszczenie danych;

- rosyłanie spamu;

- dokonywanie ataków na serwery internetowe;

- kradzież danych (hasła, numery kart płatniczych, dane osobowe);

- wyłączenie komputera, wyświetlanie grafiki lub odgrywanie dźwięków;

- uniemożliwienie pracy na komputerze;

- umożliwienie przejścia kontroli nad komputerem osobie nieupoważnionej;

***TROJAN** to oprogramowanie, które podszywa się pod przydatne lub ciekawe dla użytkownika aplikacje dodatkowo implementują niepożądaną, ukrytą przed użytkownikiem funkcjonalność

***ROOTKIT** - narzędzie pomocne we włamaniach do systemów informatycznych. Ukrywa on niebezpieczne pliki i procesy, które umożliwiają utrzymanie kontroli nad systemem. Może np. ukryć siebie oraz trojana przed administratorem oraz oprogramowaniem antywirusowym.

***BACKDOOR** (ang. tyłne drzwi) - luka w zabezpieczeniach systemu utworzona umyślnie w celu późniejszego wykorzystania. Backdoor w systemie może być np. pozostawiony przez crackera, który włamał się przez inną lukę w oprogramowaniu

***WABBIT** - program rezydentny nie powielający się przez sieć. Wynikiem jego działania jest jedna określona operacja np. powielanie tego samego pliku, aż do wyczerpania zasobów pamięci komputera.

***Kryptografia** to nauka zajmująca się układaniem szyfrów. Nazwa pochodzi z greckiego słowa: kryptos - "ukryty", gráphein "pisać...". Wyróżniane są dwa główne nurty kryptografii:

Kryptografia symetryczna, Kryptografia asymetryczna

***Szyfry Podstawieniowe**

Prosty szyfr podstawieniowy, homomorficzny(jedna litera na kilka symboli), wieloalfabetowy (kombinacja prostych szyfrów), poligramowy (grupy znaków za szyfrowanie)

***Najważniejszymi elementami mechanizmów zabezpieczeń w sieciach komputerowych są:**

poufność, integralność, dostępność.

Poufność danych uzyskiwana jest poprzez zastosowanie kryptografii (szyfrowania). Szyfrowanie realizuje się przy użyciu klucza symetrycznego bądź asymetrycznego.

***SZYFROWANIE SYMETRYCZNE**

Szyfrowanie przy wykorzystaniu klucza symetrycznego nazywane jest szyfrowaniem kluczem tajnym i realizowane jest za pomocą wspólnego klucza. Zarówno w celu szyfrowania jak i deszyfracji wykorzystywany jest ten sam algorytm.

***Wyróżniamy następujące rodzaje szyfrów symetrycznych:**

Szyfr blokowy – pracuje na 64-bitowych porcjach wiadomości.

Szyfr strumieniowy – pracuje na strumieniach danych, co oznacza, że kolejne bity są indywidualnie szyfrowane.

***Szyfr symetryczny strumieniowy** – ciąg bitów utajnianych jest sumowany modulo 2 z bitami ciągu szyfrującego.

***Szyfr synchroniczny strumieniowy** – ciąg szyfrujący i deszyfrujący jest generowany niezależnie od ciągu szyfrowanej wiadomości oba generatory muszą być zsynchronizowane. Nie rozwiązuje błędów transmisji, nie chroni przed modyfikacją, zapewnia ochronę przed wstawkami

***Szyfr synchroniczny strumieniowy samo synchronizujący** – każdy bit ciągów (de-)szyfrującego jest funkcją pewnej stałej liczby n poprzednich bitów szyfrogramu. Zapewnia integralność danych, powoduje błędy transmisji polegające na przekłamaniu bitu i są rozśiewane dalej przez funkcję n.

***Szyfry symetryczne blokowe** - szyfry blokowe to procedury, które szyfrują niewielkie bloki danych (znacznie mniejsze od typowej wiadomości), współcześnie jest to najczęściej 128 bitów. Klucze mają zwykle od 128 do 256 bitów, przy czym wartości mniejsze do 80 są uważane za niewystarczające.

Typowy szyfr blokowy składa się z kilkunastu dość prostych rund przekształcających blok.

Operacje używane w tych szyfrach są zwykle proste, ale pochodzą z "różnych światów", np. używa się dodawania, XOR, przesunięć cyklicznych, różnego typu S-BOXów, mnożenia modulo liczb pierwszych itd. Kilka rund takich operacji zupełnie zaburza jakikolwiek porządek i jest bardzo trudne do analizowania.

***Algorytmy szyfrowania z wykorzystaniem klucza symetrycznego:**

DES (Data Encryption Standard)

3DES (Triple Data Encryption Standard)

IDEA (International Data Encryption Algorithm)

***Najważniejsze elementy bezpieczeństwa szyfrowania kluczem symetrycznym to:**

Częsta zmiana kluczy tajnych zapobiega ich złamaniu;

Bezpieczne generowanie kluczy tajnych;

Bezpieczna dystrybucja kluczy tajnych.

***DES**

- jako standard.

- DES jest oparty na kluczu prywatnym.

- DES jest blokowym algorytmem z 64 bitowym blokiem.

- DES używa kluczy 56 bitowych (podatny na złamanie)

- DES jest wystarczająco silny by zatrzymać większość przypadkowych hackerów i osób trzecich.

- Odmiana DESa – podrójny DES bazuje na używaniu DESa trzy razy (zazwyczaj z trzema różnymi niepowiązanymi ze sobą kluczami).

- korzysta z 56-bitowego klucza. Klucz korzysta z siedmiu bitów 8-bitowych bajtów (ósmi bit każdego bajtu użyty jest jako bit parzystości). DES jest szyfrem blokowym operującym na 64-bitowym bloku tekstu jawnego na raz przedstawiony jest diagram blokowy algorytmu). Istnieje 16 rund szyfrowania za każdym razem z użyciem innego podklucza. Klucz przechodzi przez odrębny algorytm aby wytworzyć 16 podkluczy

***3DES – Triple DES**

- Zwiokrotniony DES może posłużyć do celu stworzenia silniejszego systemu szyfrowania.

- TDES może być zastosowany z trzema lub dwoma kluczami.

- TDES jest względnie szybkim algorytmem i można nadal stosować go przy obecnym sprzęcie.

- Zajmuje 3 razy więcej czasu niż DES, jako że zachodzą trzy operacje.

- Dla większości aplikacji należy stosować TDES zamiast DES

***IDEA** używa 128 bitowego klucza i jest generalnie uważany za bardzo bezpieczny.

Jest obecnie jednym z najbardziej znanych publicznie algorytmów.

Jest stosunkowo nowym algorytmem.

Nie udało się dotychczas przeprowadzić na niego udanego ataku.

IDEA jest opatentowany w USA i w większości krajów europejskich.

Niekomercyjne użycie IDEA jest darmowe.

Poleca się używanie tego algorytmu.

Fazy działania algorytmu IDEA przedstawiają się następująco:

w każdym kroku cztery 16b podbloki danych poddawane są operacji dodawania modulo 2, dodawania modulo 216 i mnożenia modulo 216 z innymi blokami i z sześcioma 16b podkluczami;

po między każdym krokiem następuje zamiana drugiego i trzeciego podbloku.

Szyfrowanie asymetryczne

Szyfrowanie asymetryczne określane jest często jako szyfrowanie z wykorzystaniem klucza publicznego. Do szyfrowania oraz deszyfracji wykorzystywane mogą być identyczne, bądź też uzupełniające się algorytmy.

Wymagane też jest użycie dwóch powiązanych ze sobą kluczy: publicznego i prywatnego. Wiadomość zaszyfrowana za pomocą klucza publicznego może być rozszyfrowana tylko przy zastosowaniu klucza prywatnego i na odwrót.

Najczęstsze zastosowania szyfrowania asymetrycznego:

Integralność danych;

Poufność danych;

Autentyczność nadawcy;

Uwierzytelnianie nadawcy.

***SZYFROWANIE ASYMETRYCZNE**

Szyfrowanie asymetryczne określane jest często jako szyfrowanie z wykorzystaniem klucza publicznego. Do szyfrowania oraz deszyfracji wykorzystywane mogą być identyczne, bądź też uzupełniające się algorytmy.

Wymagane też jest użycie dwóch powiązanych ze sobą kluczy: publicznego i prywatnego. Wiadomość zaszyfrowana za pomocą klucza publicznego może być rozszyfrowana tylko przy zastosowaniu klucza prywatnego i na odwrót.

***Najczęstsze zastosowania szyfrowania asymetrycznego:** Integralność danych;;;; Poufność danych;;;; Autentyczność nadawcy;;;; Uwierzytelnianie nadawcy.

***najważniejsze algorytmy asymetryczne:** RSA;; ElGamal;; DSS

***RSA** - opiera się na trudności faktoryzacji dużych liczb;;; obecnie jedynym zagrożeniem dla RSA może być komputer kwantowy (algorytm Shora).

1. Szukanie dwóch dużych pierwszych liczb p i q oraz wyliczamy ich iloczyn n = pq.

2. Wybór klucza szyfrującego (publicznego) e aby liczby e i (p-1)(q-1) były względnie pierwsze.

3. Szukanie liczby d (klucz tajny) będącej odwrotnością modulo n liczby e: d = e⁻¹ mod (p-1)(q-1).

4. Publikacja e i n.

5. Utajnienie klucza prywatnego d.

6. Zniszczenie liczb p i q tak aby nikt nigdy ich nie poznał.

- Klucz publiczny KU = {e, n}

- Klucz prywatny (tajny) KR = {d, n}

- Algorytm szyfrowania C = M^e mod n

- Algorytm deszyfrowania M = C^d mod n

*atak na RSA - atak polega na rozłożeniu danego klucza na iloczyn dwóch liczb względnie pierwszych;;; Klucze RSA z reguły mają długość 1024–2048 bitów!;;; Dla pełnego bezpieczeństwa zaleca się klucze o długości 4096 bitów.

***ALGORYTM ELGAMALA**

- Algorytm w połowie lat 80. XX wieku powstał.

- System jest oparty na trudności problemu logarytmu dyskretnego w ciele liczb całkowitych modulo duża liczba pierwsza.

- Klucz publiczny może być obliczony na podstawie prywatnego!

- Na koncepcji algorytmu ElGamal jest też oparta kryptografia krzywych eliptycznych.

- Atak na ElGamal jest jeszcze trudniejszy niż na RSA

***Mechanizmy integralności danych:** sprawdzanie integralności danych, polega na zweryfikowaniu i wykrywaniu ewentualnych modyfikacji w zbiorach bajtów. Wykorzystywane do tego są mechanizmy używające funkcji mieszających oraz podpisów cyfrowe. Podpis cyfrowy jest tworzony przy użyciu funkcji mieszającej.

***Funkcje mieszające (skrót, hash)**

Funkcja mieszająca pobiera tekst wejściowy, po czym jest generowany kod o stałej długości, nazywany zbiorem bądź szumem. Jeśli algorytm ma być bezpieczny pod względem kryptograficznym dla funkcji mieszającej, musi się charakteryzować poniższymi właściwościami:

- **Zwartość** – te same dane wejściowe muszą mieć identyczną postać wyjściową;

- **Losowość** – działanie losowe ma uniemożliwić domyślenia się treści wiadomości;

- **Unikalność** – powinno być niemożliwe znalezienie dwóch takich samych wiadomości, które wygenerują taki sam zbiór;

- **Jednokierunkowość** – niemożliwym, bądź ewentualnie bardzo trudnym powinno być ustalenie treści oryginalnej wiadomości na podstawie kodu wyjściowego.

***PODPISY CYFROWE**

Podpis cyfrowy jest zaszyfrowaną wiadomością, która dołączana jest do oryginalnego dokumentu. Najczęściej jest on wykorzystywany do potwierdzenia tożsamości nadawcy i zapewnienia integralności.

***Tworzenie podpisu cyfrowego** ma następujący przebieg:

Krok 1: Nadawca generuje parę kluczy, publiczny i prywatny.

Krok 2: Nadawca przesyła swój publiczny klucz odbiorcy.

Krok 3: Nadawca redaguje wiadomość dla odbiorcy i wykorzystuje ją jako dane wejściowe dla jednokierunkowej funkcji skrótu.

Krok 4: Nadawca szyfruje wynik skrótu przy pomocy własnego klucza prywatnego, rezultatem czego jest podpis cyfrowy.

***weryfikacja podpisu cyfrowego**

Aby zweryfikować Użytkownika 2 jako prawdziwego nadawcę wiadomości, Użytkownik 1 musi wykonać następujące czynności:

Krok 1: Odbiorca rozdziela wiadomość od podpisu cyfrowego.

Krok 2: Korzystając z klucza publicznego nadawcy odbiorca deszyfruje podpis cyfrowy, w wyniku czego otrzyma skrót wiadomości oryginalnej.

Krok 3: Odbiorca używa oryginalnej wiadomości jako dane wejściowe dla tej samej funkcji mieszającej, której użył nadawca. Po wykonaniu tej operacji otrzymuje skrót wiadomości.

Krok 4: Odbiorca porównuje obydwa skróty

***PORÓWNIANIE SZYFRÓW SYMETRYCZNYCH I ASYMETRYCZNYCH**

SYMETRYCZNE

- poufność: duże szybkości szyfrowania i deszyfrowania

- integralność i uwierzytelnianie: duże szybkości generowania i weryfikowania znacznika uwierzytelnienia MAC

- niezaprzeczalność: trudność generowania podpisu cyfrowego

- wymiana kluczy: trudna w realizacji

ASYMETRYCZNE

- poufność: małe szybkości szyfrowania i deszyfrowania

- integralność i uwierzytelnianie: wolniejsze generowanie i weryfikowanie podpisu cyfrowego

- niezaprzeczalność: łatwość generowania podpisu cyfrowego

- wymiana kluczy: łatwa w realizacji

***FUNKCJE SKRÓTU – WYMAGANIA**

- może być zastosowana do bloku danych dowolnej wielkości;

- generuje skrót ustalonej wielkości;

- $H(M)$ jest stosunkowo łatwo obliczyć dla każdego M , dzięki temu implementacja sprzętowa i programowa jest realna;

- dla każdego skrótu h znalezienie takiego M , że $H(M) = h$ nie jest wykonalne na drodze obliczeń;

- dla każdego M znalezienie takiego, że $H(M')=H(M)$ jest trudne obliczeniowo;

- znalezienie funkcji skrótu dla pary $(M1, M2)$, że $H(M1) = H(M2)$ jest trudne obliczeniowo.

***PORÓWNIANIE PODPISÓW**

- cechy wspólne cyfrowego i ręcznego: przypisany jednej osobie, niemożliwy do podrobienia, uniemożliwiający wyparcie się go przez autora, łatwy do weryfikacji przez osobę niezależną, łatwy do wygenerowania

RÓŻNICE:

- ręczny związany nierozłącznie z dokumentem, a cyfrowy może być składowany i transmitowany niezależnie od dokumentu

- ręczny taki sam dla wszystkich dokumentów, cyfrowy jest funkcją dokumentu

- ręczny stawiany na ostatniej stronie dokumentu, cyfrowy obejmuje cały dokument

***PROTOKÓŁ DIFFIEGO-HELLMANA** - protokół uzgadniania kluczy Diffiego-Hellmana to protokół kryptograficzny, w wyniku wykonania którego, dwie strony otrzymują taką samą liczbę, przy czym otrzymanie tej liczby na podstawie treści wymienionych wiadomości między stronami jest praktycznie niemożliwe. Liczba ta może być potem używana jako klucz do szyfrowania komunikacji, klucz symetryczny. Protokół nie zabezpiecza przed ingerencjami w komunikację (atak "man in the middle"), jedynie przed pasywnym podsłuchem. Dlatego należy go uzupełnić o zabezpieczenia przed atakiem aktywnym. Jedna strona zna klucz publiczny drugiej lub potrafi go zweryfikować – np. jest on podpisany przez organizację certyfikującą (*certification authority*)

- Użytkownik A i Użytkownik B w dowolny sposób wybierają dwie liczby względnie pierwsze: dużą liczbę p oraz liczbę g , będącą generatorem grupy multiplikatywnej Z_p . Liczby te mogą być opublikowane wcześniej lub uzgodnione on-line. Ich tajność nie jest istotna dla bezpieczeństwa procedury.

- Użytkownik A losuje liczbę a ; Użytkownik B losuje liczbę b

- Użytkownik A wysyła Użytkownikowi B $g^a \text{ mod } p$; Użytkownik B wysyła Użytkownikowi A $g^b \text{ mod } p$

- Użytkownik A oblicza $k=(g^b)^a \text{ mod } p = g^{ab} \text{ mod } p$; Użytkownik B oblicza $k=(g^a)^b \text{ mod } p = g^{ab} \text{ mod } p$

- Podsłuchujący zna g , $g^a \text{ mod } p$, $g^b \text{ mod } p$, $g^{ab} \text{ mod } p$. Jeśli nie potrafi obliczać logarytmu dyskretnego (a dla odpowiedniego p nie jest znany żaden algorytm o wielomianowej złożoności, który by potrafił), nie potrafi obliczyć $g^{ab} \text{ mod } p$.

- Użytkownik A nie zna liczby wylosowanej przez Użytkownika B, a Użytkownik B liczby wylosowanej przez Użytkownika A

***DYSTRYBUCJA KLUCZY PUBLICZNYCH**

- **Cel PKI** (Public Key Infrastruktury - infrastruktura kluczy publicznych) - zapewnienie zaufanego i wydajnego zarządzania kluczami oraz certyfikatami niezbędnymi dla tych protokołów.

- PKI składa się z poniższych pięciu typów komponentów:

> **CA** (Certificat Authorities - wydawcy certyfikatów), przysługujących i odbierających certyfikaty

> **ORA**(Organizational Registration Authorities - autorytet organizacyjnej rejestracji), poręczających za powiązania pomiędzy kluczami publicznymi, tożsamością posiadaczy certyfikatów oraz innymi atrybutami .

> **Posiadaczy certyfikatów** którym wydawane są certyfikaty i którzy mogą podpisywać cyfrowe dokumenty

> **Klientów**, którzy posiadają cyfrowe podpisy oraz ich ścieżki certyfikowania prowadzące do znanych publicznych kluczy zaufanych CA

> **Magazynów**, które przechowują i udostępniają certyfikaty oraz **CRL(Certificate Revocation List - lista unieważnienia certyfikatu)**

- **funkcje PKI**: Rejestracja;; Inicjacja;; Certyfikowanie;; Odzyskiwanie par kluczy;; Generowanie kluczy;; Uaktualnienie kluczy;; Certyfikowanie przechodnie;; Unieważnienie

***CERTYFIKAT**

jest potwierdzeniem tożsamości użytkownika wystawionym przez wystawcę certyfikatów CA. Certyfikat może zawierać informacje służące do ochrony danych lub do ustanowienia bezpiecznych połączeń, jest strukturą danych łączących wartości kluczy publicznych z danymi jednostkami . Celem CA jest zatem powiązanie klucza publicznego z publiczną nazwą certyfikatu i tym samym zapewnienie strony trzeciej , że zostały podjęte odpowiednie środki ostrożności służące zapewnieniu poprawności powiązania.

*** Certyfikaty są używane w procesie poświadczania podpisanych danych.** Szczegóły zmieniają się w zależności od zastosowanego algorytmu, ale ogólny proces działa w następujący sposób :

1. Odbiorca podpisanych danych sprawdza, czy podana tożsamość użytkownika jest zgodna z tożsamością zawartą w certyfikacie.

2. Odbiorca sprawdza, czy żaden certyfikat na ścieżce nie został unieważniony na przykład poprzez uzyskanie wystarczająco aktualnej CRL listy unieważnienia certyfikatu albo włączonego w sieć sygnalizatora statusu certyfikatu

3. Odbiorca sprawdza, czy dane mają atrybuty, do których według certyfikatu podpisujący nie jest upoważniony .

4. Odbiorca za pomocą klucza publicznego z certyfikatu sprawdza , czy dane nie zostały zmienione od momentu ich podpisania.

*** Standard X.509** stanowi powszechną podstawę infrastruktury PKI , definiującą format danych oraz związane z dystrybucją za pomocą certyfikatów cyfrowo podpisanych przez CA.

***STRUKTURA CERTYFIKATU**

- subject – dane właściciela certyfikatu

- public key – klucz publiczny właściciela certyfikatu

- issuer – dane wystawcy certyfikatu

- signature – podpis elektroniczny certyfikatu wykonany przez wystawcę certyfikatu

- validity – termin ważności certyfikatu

- administrative information – dane administracyjne: wersja, nr seryjny, algorytmy użyte przy tworzeniu certyfikatu

- extender information – informacje dodatkowe

***NARZĘDZIA PODWYŻSZAJĄCE BEZPIECZEŃSTWO SYSTEMÓW: Firewall;;; protokół SSL;;; System Kerberos**

***FIREWALL** - Firewallie służą do odseparowania sieci lokalnej od sieci Internet lub sieci współpracujących firm. Rolą firewalla jest analiza ruchu sieciowego i blokowanie połączeń, które są niedozwolone wg reguł zapisanych w konfiguracji firewalla. Istnieją trzy podstawowe zasady funkcjonowania firewali: filtr pakietów, proxy aplikacyjne i technologia inspekcji stanu.

***Firewall filtr pakietów** - Zasada działania polega na filtrowaniu ruchu w oparciu o takie kryteria jak adres źródłowy i docelowy, typ protokołu, port źródłowy i docelowy. Technologia ta charakteryzuje się prostotą implementacji i względnie dużą wydajnością.

***zakres funkcji firewalli obejmuje:**

- filtrowanie pakietów (podobnie jak robią to routery), ale przy zastosowaniu wyrafinowanych sposobów analizy,

- możliwość translacji, ukrywania adresów (NAT – Network Address Translation, IP masquering),

- tworzenie sieci wirtualnych VPN wraz z metodami szyfrowania,

- *statefull inspection* - sprawdzanie pakietów m.in. w kontekście pakietów poprzednio badanych,

- *application-level gateway* – analiza pakietów w kontekście warstwy aplikacji,

- możliwość wyszukiwania wirusów np. opcja CVP (Central Virus Protection), czyli odwoływanie się do wyznaczonego systemu z bazą danych o wirusach,

- możliwość pracy jako serwer proxy z dużą liczbą (nawet do 30) obsługiwanych protokołów,

- możliwość uwierzytelnionego dostępu do korzystania z wybranych protokołów,

- tworzenie tzw. strefy zdemilitaryzowanej DMZ (Demilitarized Zone) wydzielonej sieci z serwerami o publicznym dostępie,

- możliwość budowy hybrydowych i rozproszonych komunikujących się ze sobą firewalli,

- alarmy o naruszeniu bezpieczeństwa i dokładne raporty.

*** Ze względu na warstwową architekturę stosu protokołów TCP/IP wyróżniamy trzy typy zapór ogniowych:**

- **aplikacyjne** - umożliwiają kontrolowany dostęp do określonych usług, takich jak FTP, TELNET, WWW, wewnątrz chronionej podsieci poprzez odpowiedni program pośredniczący; pozostały ruch jest całkowicie blokowany,

- **połączeniowe** – zestawiają w ściśle określony sposób połączenia TCP pomiędzy komputerami wewnątrz chronionej podsieci a resztą Internetu, nie kontrolując zawartości pakietów,

- **filtrujące** – segregują pakiety IP, TCP, ICMP, itp.), przechodzące przez interfejsy sieciowe według określonych reguł.

***ZASTOSOWANIE ZAPÓR OGNIOWYCH**

- Połączenie dwóch sieci chronionych szyfrowanym tunelem (np. VPN) poprzez sieć o niskim poziomie zaufania (Internet)

- Identyfikacja i uwierzytelnianie użytkownika mobilnego przy dostępie do sieci wewnętrznej

- Zabezpieczenie serwerów i udostępnienie jedynie wybranych usług

- Rozdzielenie sieci chronionych na strefy bezpieczeństwa o różnym poziomie zaufania

- Ochrona sieci prywatnej przed nieautoryzowanym dostępem z Internetu

*** Protokół SSL, (ang.) Secure Socket Layer**

- opracowany przez firmę Netscape Communications.

- Specyfikacja: 'The SSL Protocol Version 3.0'
- Protokół SSL został stworzony dla potrzeb bezpiecznej komunikacji w internecie.
- Służy do zabezpieczenia (szyfrowania) przesyłanych danych w protokołach HTTP, FTP, protokołach poczty elektronicznej.
- W warstwie transportowej wykorzystuje protokół TCP.
- Protokół SSL był podstawą opracowania protokołu TLS, Transport Security Layer.

*Funkcje protokołu SSL:

- autoryzacja stron biorących udział w transmisji
- zapewnienie poufności transmisji poprzez szyfrowanie przesyłanych danych
- zapewnienie integralności przesyłanych danych

*Protokół SSL zapewnia trzy podstawowe komponenty zabezpieczenia:

- **Uwierzytelnienie** - zdolność do weryfikowania serwera lub serwera i klienta na obu końcach połączenia.
- **Poufność** - zdolność do takiego szyfrowania przesyłanych informacji, aby tylko obie komunikujące się strony mogły uzyskać do niej dostęp i zrozumieć ją.
- **Integralność** - niedopuszczenie do zmiany zawartości komunikatu. Odbiorca może być pewny, że otrzymuje niezmienną informację.

*Subprotokół SSL uzgadniania pełni funkcję legalizacji dwóch jego uczestników.

Akcję wspiera ciąg komunikatów przesyłanych między serwerem i klientem:

- Autoryzacja serwera wobec klienta.
- Umożliwienie klientowi i serwerowi wybrania algorytmów szyfrowania i poziomu bezpieczeństwa.
- Opcjonalnie autoryzacja klienta wobec serwera. Użycie publicznych kluczy kryptograficznych do utworzenia współużytkowanych tajnych informacji (*shared secrets*), które później będą użyte do transmisji rzeczywiste poufnych danych.
- Ustalenie połączenia SSL.

*ETAPY BEZPIECZNEGO PRZESYŁANIA DANYCH

1. Klient nawiązuje połączenie z serwerem wysyłając parametry połączenia i wygenerowaną losowo liczbę.
2. Server potwierdza parametry połączenia i wysyła inną wygenerowaną losowo liczbę. Server potwierdza swoją tożsamość wysyłając swój certyfikat i klucz publiczny.
3. Klient generuje klucz algorytmu symetrycznego (np. 3DES) który później będzie wykorzystywany do przesyłania danych i wysyła go szyfrując dane kluczem publicznym serwera.
4. Server odczytuje klucz algorytmu symetrycznego korzystając ze swojego klucza prywatnego.
5. Strony dalej komunikują się korzystając z szyfrowania symetrycznego.

*SYSTEM KERBEROS

- Kerberos służy do identyfikacji klientów i serwerów usług w sieciach otwartych, tzn. sieciach niezabezpieczonych.
- Do identyfikacji klientów i serwerów służą serwery identyfikacyjne, serwery AS, authentication servers.
- Serwer AS przesyła na żądanie klienta uwierzytelnienie, (ang.) credentials.
- Uwierzytelnienie składa się z: - biletu na dany serwer;;; - klucza sesji

*schemat uwierzytelnienia klienta

1. Klient chcąc zbudować bezpieczne połączenie z serwerem usługi wysyła do **serwera AS** żądanie przesłania uwierzytelnienia (credentials)
2. Serwer AS odpowiada wysyłając uwierzytelnienie w kluczu klienta. **Uwierzytelnienie zawiera:** -bilet;; - klucz sesji. Bilet (zawierający kopię klucza sesji) szyfrowany jest kluczem serwera usługi, klucz sesji szyfrowany jest kluczem klienta.
3. Klient przesyła bilet na serwer usługi. Bilet zawiera dane identyfikujące klienta i kopię klucza sesji. Bilet zaszyfrowany jest przez serwer **AS kluczem serwera usługi**. Wymieniony klucz sesji służy do identyfikacji klienta i serwera. Klucz może również służyć do szyfrowania transmisji między klientem a serwerem.

***IDENFIKATOR** - W celu uwierzytelnienia się, klient wysyła na serwer bilet. Aby uniknąć przechwycenia i użycia biletu przez innego użytkownika sieci (tylko część biletu jest przesyłana w formie szyfrowanej) klient wysyła drugą wiadomość szyfrowaną kluczem sesji zawierającą znacznik czasu, timestamp. Wiadomość ze znacznikiem czasu nazywa się identyfikatorem. Identyfikator służy do potwierdzenia, że bilet został wysłany przez klienta dla którego został wydany.

*PODPROTOKOŁY SYSTEMU KERBEROS:

>Podprotokół AS, Authentication Service Exchange. Służy do realizacji funkcji serwera identyfikacyjnego (serwer AS), tzn. wydawania biletów do przydzielania biletów, (ticket-granting server) i kluczy sesji TGT.

>Podprotokół TGS, Ticket-Granting Server Exchange. Służy do realizacji funkcji serwera TGS, (ticket-grantig server), tzn. wydawania biletów i kluczy sesji na żądanie klienta.

>Podprotokół CS, Client/Server Authentication Exchange. Służy do komunikacji między klientem a serwerem usługi w celu identyfikacji stron.

*WADY KERBEROSA

- Kerberos nie zapewnia w jakikolwiek sposób bezpieczeństwa hosta, a więc z zaufanymi hostami komunikuje się w sposób nie wymagający uwierzytelnień. Jeśli więc bezpieczeństwo hosta zostanie skompromitowane, również Kerberos jest skompromitowany. Zależy to oczywiście jeszcze od tego, do jakiego hosta nastąpi włamanie. Jeśli włamywacz ukradnie jedynie bilety, może on podszywać się pod osoby tylko do pewnego czasu, aż ważność biletów wygaśnie.
- W Kerberosie 4, identyfikatory są ważne przez 5 minut. Jeśli więc ktoś przeszukuje sieć w poszukiwaniu identyfikatorów, ma okno 5 minutowe, w którym może powtórnie użyć go i dostać dostęp do tej samej usługi. Kerberos 5 został pod tym względem poprawiony. Została zaimplementowana 'replay cache', która zapobiega użyciu po raz kolejny tego samego identyfikatora.
- Każdy może także wysłać prośbę o bilet podszywając się pod inną osobę. Otrzymuje zakodowany bilet hasłem danej osoby i może próbować w ten sposób otrzymać hasło rozkodowując bilet. Kerberos 5 rozwiązał jednak i ten problem stosując preweryfikację.
- Hosty także mogą używać protokołów do synchronizacji czasu, które nie wymagają uwierzytelnienia. Takie protokoły nie są odporne na ataki. Haker bardzo prosto może zmienić czas hostu, przez co może użyć stare identyfikatory.
- Ponadto w stacjach roboczych, intruz łatwo może podmienić program login, na własną wersję, która przed użyciem w Kerberosie będzie zapisywała gdzieś dane hasło. Łamie więc to zasadę, że hasła nie są nigdzie zapisane jako czysty tekst. Rozwiązaniem tego problemu mogłoby być używanie jednorazowych haseł, jednakże Kerberos nie wspiera takiego postępowania.

PBI – TEST

uznaniowe sterowanie dostępem DAC wykorzystuje

Uznaniowe sterowanie dostępem (ang. *Discretionary Access Control*, DAC) wykorzystuje:

Wybierz jedną odpowiedź:

- ☒ a. atrybut własności obiektu
- ☐ b. nadane obiektom i podmiotom etykiety
- ☐ c. przypisane podmiotom role
- ☐ d. przypisane do podmiotów i obiektów: atrybuty, warunki opisujące środowisko i zbiory zasad

[Odnznacz mój wybór](#)

Odp. A

DAC MAC RBAC ABAC

1. Uznaniowe sterowanie dostępem (ang. *Discretionary Access Control*, DAC).

Środki ochronne ograniczające dostęp do obiektów wykorzystują atrybut własności obiektu, umożliwiający podmiotowi-właścicielowi nadanie lub odebranie innemu podmiotowi (lub grupie podmiotów) prawa dostępu do obiektu, którego jest właścicielem.

2. Obowiązkowe sterowanie dostępem (ang. *Mandatory Access Control*, MAC).

Środki ochronne ograniczające dostęp do obiektów wykorzystują przypisane do obiektów etykiety określające wymagany poziom siły ochrony obiektu oraz formalnie nadane podmiotom poziomy uprawnienie (ang. *clearance level*).

3. Sterowanie dostępem wykorzystujące role (ang. *Role Based Access Control*, RBAC).

Uprawnienia dostępu do obiektów zamiast podmiotowi przypisane są rolom, które taki podmiot może pełnić.

4. Sterowanie dostępem wykorzystujące atrybuty (ang. *Attribute Based Access Control*, ABAC)

Środki ochronne ograniczające dostęp do obiektów wykorzystują przypisane do podmiotów i obiektów atrybuty, warunki opisujące środowisko i zbiory zasad wyspecyfikowane w terminach opisujących ww. atrybuty i warunki.

podstawowe atrybuty informacji związane z jej bezpieczeństwem

Podstawowe atrybuty informacji związane z jej bezpieczeństwem to:

Wybierz jedną odpowiedź:

- ☐ a. tajność, integralność, długość (w bajtach)
- ☐ b. tajność, integralność, długość (w znakach)
- ☒ c. tajność, integralność, dostępność
- ☐ d. integralność, metoda szyfrowania, dostępność

[Odznacz mój wybór](#)

Odp. C

„Odpowiedniość” jest wyznaczana wymaganymi wartościami kryteriów elementarnych, takich jak *tajność*, *integralność*, *dostępność*, np.

sandbox

Sandbox to:

Wybierz jedną odpowiedź:

- ☐ a. rodzaj testu penetracyjnego wykonywany z zewnątrz, bez znajomości struktury oraz konfiguracji testowanego środowiska
- ☐ b. metoda porównania analizowanego obiektu z bazą sygnatur wirusów
- ☒ c. mechanizm służący do separacji programów oraz wykonywania niezaufałego kodu w odizolowanym środowisku
- ☐ d. skaner portów

[Odznacz mój wybór](#)

Odp. C

czy podatność jest warunkiem koniecznym realizacji zagrożenia

Czy podatność jest warunkiem koniecznym realizacji zagrożenia:

Wybierz jedną odpowiedź:

- ☐ a. NIE
- ☒ b. TAK

[Odznacz mój wybór](#)

Odp. B

Podatności to wady lub luki:

W zasobach

- w strukturze fizycznej organizacji,
- sprzęcie i oprogramowaniu,
- personelu,
- procedurach.

W procesach

- zarządzania i administrowania,
- organizacji pracy,
- obsady stanowisk pracy personelem.

które mogą być wykorzystane przez zagrożenia do spowodowania szkód w systemie informacyjnym organizacji lub w jej działalności (np. usługach).

podmiot świadczący usługi kolokacji

Podmiot świadczący usługi kolokacji:

Wybierz jedną odpowiedź:

- ☐ a. szkoli pracowników klienta z ochrony zasobów informacyjnych
- ☐ b. serwisuje sprzęt komputerowy w siedzibie klienta
- ☒ c. udostępnia swoje centrum danych (infrastrukturę), a klient wstawia tam swój sprzęt komputerowy
- ☐ d. udostępnia klientowi swoje centrum danych (infrastrukturę) i swój sprzęt komputerowy

[Odznacz mój wybór](#)

Odp. C

hosting kolokacja

Hosting – realizacja usługi (np. składowania danych) przez jej dostawcę na jego zasobach sprzętowych i programowych, w jego centrum danych.

Kolokacja – usługa polegająca na wynajęciu miejsca w centrum danych dostawcy usługi i umieszczeniu w nim własnego sprzętu komputerowego.

utm oznacza

UTM (Unified Threat Management) oznacza:

Wybierz jedną odpowiedź:

- ☐ a. metodę szyfrowania danych uwierzytniających
- ☐ b. metodykę analizy ryzyka na potrzeby bezpieczeństwa informacyjnego
- ☐ c. zespół zarządzający w firmie bezpieczeństwem teleinformatycznym
- ☒ d. integrację oprogramowania zabezpieczającego w jeden kompleksowy system ochrony, osadzany na specjalizowanej platformie sprzętowej

[Odznacz mój wybór](#)

Odp. D

Aktualny kierunek rozwojowy oprogramowania do przeciwdziałania nieuprawnionym działaniom w sieciach i systemach komputerowych to **integracja** w jeden kompleksowy system ochrony, osadzany na specjalizowanej platformie sprzętowej (**UTM – Unified Threat Management**).

inspektora bezpieczeństwa teleinformatycznego

Inspektora bezpieczeństwa teleinformatycznego **wyznacza się, zgodnie z odpowiednią ustawą, w przypadku przetwarzania w systemach teleinformatycznych:**

Wybierz jedną odpowiedź:

- ☐ a. informacji wrażliwych
- ☒ b. danych osobowych
- ☐ c. informacji niejawnych
- ☐ d. danych bankowych

[Odznacz mój wybór](#)

Odp. C

W celu przetwarzania informacji niejawnych w systemie teleinformatycznym należy powierzyć dwie funkcje pracownikom jednostki organizacyjnej lub zatrudnić nowe osoby do pełnienia tych funkcji. Pierwsza to “administrator systemu”, druga to “inspektor bezpieczeństwa teleinformatycznego”.

dokument Polityka bezpieczeństwa informacyjnego powinien być

Dokument *Polityka bezpieczeństwa informacyjnego* powinien być dokumentem zawierającym:

Wybierz jedną odpowiedź:

- ☐ a. szczegółowe plany obiegu informacji i schematy sieci teleinformatycznych
- ☒ b. zapis najważniejszych, ogólnych zamiarów działań kierownictwa organizacji w zakresie bezpieczeństwa własnych i powierzonych informacji i jego deklaracje co do zapewniania odpowiedniego poziomu tego bezpieczeństwa
- ☐ c. instrukcje i procedury dla osób korzystających z systemów teleinformatycznych organizacji
- ☐ d. wykaz stosowanych w organizacji podstawowych zabezpieczeń informacji

[Odznacz mój wybór](#)

„Politykę bezpieczeństwa informacyjnego ...”; zawiera ogólne, najważniejsze ustalenia dotyczące działania organizacji w zakresie ochrony informacji; dokument jawny.

Dokument ten zawiera zapis najważniejszych, ogólnych zamiarów działań najwyższego kierownictwa organizacji w zakresie ochrony zasobów informacji i jego deklaracje w zakresie zapewniania odpowiedniej jakości tej ochrony.

Odp. B

kopiowanie bez pełnego

Kopiowanie (w celu wytworzenia kopii bezpieczeństwa), w którym w wybranym dniu tygodnia zapisujemy komplet danych, natomiast w pozostałe dni robocze zapisujemy jedynie dane zmienione od ostatniego kopiowania nazywamy:

Wybierz jedną odpowiedź:

- ☐ a. lustrzanym
- ☐ b. pełnym
- ☐ c. przyrostowym
- ☐ d. różnicowym

Odp. C

1. Kopia **pełna**

W ustalonych czasie (np. codziennie o godz. 17.00) kopiuje się na nośniki zapisowe zasoby informacyjne zgodnie ze specyfikacją z „Planu odtwarzania”, bez względu na to, czy zostały one zmodyfikowane czy też nie. Podstawową wadą tego rodzaju kopiowania jest wysokie zapotrzebowanie na nośniki danych.

2. Kopia **różnicowa** (tygodniowa)

W wybranym dniu (np. w piątek) zapisuje się komplet danych, natomiast w pozostałe dni robocze zapisuje jedynie dane zmienione od ostatniego kopiowania pełnego. Przechowywane są jedynie kopie pełne, nośniki z kopiami różnicowymi są kasowane po wykonaniu kolejnej kopii pełnej i używane ponownie, o ile takie działanie dopuszcza wdrożona polityka bezpieczeństwa.

3. Kopia **przyrostowa** (tygodniowa)

W wybranym dniu (np. w piątek) zapisuje się komplet danych, natomiast w pozostałe dni robocze zapisuje jedynie dane zmienione od ostatniego kopiowania. Przechowywane są jedynie kopie pełne, nośniki z kopiami przyrostowymi są kasowane po wykonaniu kolejnej kopii pełnej i używane ponownie, o ile takie działanie dopuszcza wdrożona polityka bezpieczeństwa.

zasady Kerckhoffs

Poprawna treść Zasady Kerckhoffs to:

Wybierz jedną odpowiedź:

- ☐ a. Odporność kryptosystemu powinna zależeć od utrzymania tajemnicy klucza wybierającego konkretne przekształcenie, a nie od tajemnicy przekształceń używanych w tym kryptosystemie
- ☐ b. Odporność kryptosystemu powinna zależeć od utrzymania tajemnicy przekształceń używanych w tym kryptosystemie, a nie od tajemnicy klucza wybierającego konkretne przekształcenie

Odp. B

proces realizowany przez podsystem

Proces realizowany przez podsystem kontroli dostępu logicznego systemu komputerowego, gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do pliku, nazywa się:

Wybierz jedną odpowiedź:

- ☐ a. weryfikacją uwierzytelnienia
- ☒ b. weryfikacją autoryzacji
- ☐ c. weryfikacją poziomu ochrony
- ☐ d. weryfikacją tożsamości

[Odznacz mój wybór](#)

Odp. B

stosowana w określaniu praw

Stosowana w określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków, nazywa się:

Wybierz jedną odpowiedź:

- ☐ a. zasadą dwóch osób
- ☐ b. zasadą rotacji obowiązków
- ☐ c. zasadą minimalnego środowiska pracy
- ☒ d. zasadą wiedzy koniecznej

[Odznacz mój wybór](#)

Odp. D

norma PN-ISO/IEC-15408

Norma PN-ISO/IEC-15408 dotyczy:

Wybierz jedną odpowiedź:

- ☐ a. sposobów archiwizowania informacji
- ☐ b. klas metod kryptograficznych
- ☒ c. konstrukcji i oceny „bezpiecznych” produktów informatycznych
- ☐ d. systemu zarządzania bezpieczeństwem informacji

[Odznacz mój wybór](#)

Odp. C
podpis cyfrowy ma

Podpis cyfrowy ma za zadanie zapewnić:

Wybierz jedną odpowiedź:

- ☐ a. tylko integralność informacji
- ☐ b. tylko poufność i autentyczność informacji
- ☐ c. dostępność informacji
- ☒ d. niezaprzeczalność, autentyczność, integralność informacji

[Odznacz mój wybór](#)

Odp. D
zgodnie ustawą z dn. 05.08.2010

Zgodnie ustawą z dn. 05.08.2010 „O ochronie informacji niejawnych” informację niejawną oznacza się klauzulą:

Wybierz jedną odpowiedź:

- ☐ a. „tajne” lub „poufne” lub „zastrzeżone”
- ☐ b. „ściśle tajne” lub „tajne” lub „poufne” lub „do użytku wewnętrznego”
- ☒ c. „ściśle tajne” lub „tajne” lub „poufne” lub „zastrzeżone”
- ☐ d. „ściśle tajne” lub „tajne” lub „poufne”

[Odznacz mój wybór](#)

Odp. C
incydent z zakresu bezpieczeństwa

Incydent z zakresu bezpieczeństwa informacyjnego to:

Wybierz jedną odpowiedź:

- ☐ a. stan systemu informacyjnego, który powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- ☒ b. zdarzenie lub ciąg zdarzeń (składających się na realizację zagrożenia) które powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- ☐ c. zawsze i tylko rezultat działania cyberprzestępcy
- ☐ d. proces ujawniania podatności w systemie informacyjnym

[Odznacz mój wybór](#)

Odp. B

Incydentem z zakresu bezpieczeństwa informacyjnego nazywa się zdarzenie lub ciąg zdarzeń (składających się na realizację zagrożenia) które powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji.

minimalny zbiór cech skutecznego

Minimalny zbiór cech skutecznego systemu ochrony informacji przetwarzanej w systemach informacyjnych obejmuje:

Wybierz jedną odpowiedź:

- ☐ a. dywersyfikację i spójność zastosowanych zabezpieczeń
- ☐ b. dywersyfikację i niesprzeczność zastosowanych zabezpieczeń
- ☒ c. dywersyfikację, spójność, niesprzeczność zastosowanych zabezpieczeń i organizację ochrony „w głąb”
- ☐ d. dywersyfikację oraz spójność zastosowanych zabezpieczeń i organizację ochrony w „w głąb”

[Odznacz mój wybór](#)

Odp. C

test penetracyjny

Test penetracyjny to:

Wybierz jedną odpowiedź:

- ☐ a. metoda oddziaływania socjotechnicznego
- ☒ b. metoda zbierania informacji o badanym systemie
- ☐ c. to samo, co audyt bezpieczeństwa informacyjnego
- ☐ d. metoda włamywania się do systemu informatycznego

[Odznacz mój wybór](#)

Odp. B

Czym jest test penetracyjny?

- Jedną z metod identyfikowania podatności.
- Kontrolowaną próbą przełamania zabezpieczeń.
- Badaniem bezpieczeństwa obiektu z punktu widzenia potencjalnego intruza.

Czym nie jest test penetracyjny?

- Test penetracyjny nie jest audytem bezpieczeństwa IT!!
- Test penetracyjny nie jest badaniem zabezpieczeń teleinformatycznych wyłącznie za pomocą automatycznego skanera.
- Test penetracyjny nie jest działaniem według wcześniej ustalonej listy kontrolnej (tzw. „checklisty”).

promieniowanie ujawniające

Promieniowanie ujawniające:

Wybierz jedną odpowiedź:

- ☐ a. jest promieniowaniem elektromagnetycznym stanowiącym zagrożenie dla tajności informacji przetwarzanej w systemie komputerowym.
- ☐ b. nie stanowi żadnego zagrożenia.
- ☐ c. jest promieniowaniem akustycznym i/lub elektromagnetycznym stanowiącym zagrożenie dla tajności informacji przetwarzanej w systemie komputerowym.
- ☒ d. jest promieniowaniem akustycznym i/lub elektromagnetycznym stanowiącym zagrożenie dla tajności i integralności informacji przetwarzanej w systemie komputerowym.

[Odznacz mój wybór](#)

Odp. C

Promieniowanie ujawniające (nazywane też emisją ujawniającą) to niepożądana emisja **elektromagnetyczna** lub **akustyczna** urządzeń przetwarzających lub transmitujących informację, której sygnał jest skorelowany z informacją użyteczną i może być wykorzystany do jej odtworzenia.

parametr RTA

Parametr Recovery Time Actual (RTA) określa:

Wybierz jedną odpowiedź:

- ☒ a. maksymalny, możliwy do zaakceptowania przez kierownictwo organizacji, ze względu na ponoszone straty, czas pracy bez możliwości korzystania z usług całego lub części systemu informatycznego
- ☐ b. ustalony drogą eksperymentów czas przywrócenia działania systemu informatycznego i odtworzenia zbiorów danych
- ☐ c. „akceptowalne straty w danych” (aktualność danych odtworzonych po katastrofie) mierzone czasem od ostatniej kopii zapasowej do chwili katastrofy
- ☐ d. wymaganą długość przerwy w przetwarzaniu danych, niezbędnej do wykonania kopii zapasowej

[Odznacz mój wybór](#)

Odp. B

Recovery Time Actual (RTA) – parametr ten określa, ustalany eksperymentalnie, czas odtworzenia systemu (RTO był szacowany podczas analizy ryzyka). Powinna być spełniona zależność $RTA \leq RTO$.

termin hoax

Terminem „hoax” określa się:

Wybierz jedną odpowiedź:

- ☐ a. programowy obiekt złośliwy przeprowadzający działania destrukcyjne w systemie
- ☐ b. sprzętowy obiekt złośliwy posiadający zdolność powielania się
- ☒ c. rodzaj ataku socjotechnicznego – żart rozsyłany pocztą elektroniczną
- ☐ d. programowy obiekt złośliwy posiadający zdolność powielania się

[Odznacz mój wybór](#)

Odp. C

Atak socjotechniczny (ang. *social engineering*) polega na **obserwacji i oddziaływaniu** (głównie psychologicznym) na użytkownika(-ów) systemu teleinformatycznego oraz **przeszukiwanie** środowiska pracy atakowanego użytkownika w celu uzyskaniu nieuprawnionego dostępu do informacji.

Przykładem ataku socjotechnicznego „informatycznego” jest tzw. hoax (żart – klasyfikowany przez producentów AV jako kod złośliwy) oraz phishing i listy łańcuszkowe.

informacja, której zmanipulowanie

Informacja, której zmanipulowanie, uniedostępnienie lub ujawnienie może wyrządzić szkody firmie lub osobie prywatnej **to informacja:**

Wybierz jedną odpowiedź:

- ☐ a. niejawna
- ☐ b. podatna
- ☐ c. wrażliwa
- ☐ d. publiczna

Odp. C

Szczególnej uwagi wymagają **informacje wrażliwe**, tj. takie, które mogą zostać wykorzystane przeciwko określonemu podmiotowi poprzez **ujawnienie, uniedostępnienie oraz zmanipulowanie** jawne lub skryte.

ustalany eksperymentalnie

Ustalany eksperymentalnie czas przywrócenia działania systemu informatycznego i odtworzenia zbiorów danych określa parametr:

Wybierz jedną odpowiedź:

- ☐ a. RTO
- ☐ b. BWO
- ☐ c. RPO
- ☐ d. RTA

Odp. D

Recovery Time Objective (RTO) – parametr ten określa maksymalny, możliwy do zaakceptowania przez kierownictwo organizacji, ze względu na ponoszone straty, czas pracy organizacji bez możliwości korzystania z określonych usług (w tym całości lub części systemu informatycznego).

Jest to jednocześnie maksymalny, szacowany czas odtworzenia systemu. RTO jest ustalany podczas analizy ryzyka, podlega zatwierdzeniu przez naczelne kierownictwo organizacji.

Recovery Time Actual (RTA) – parametr ten określa, ustalany eksperymentalnie, czas odtworzenia systemu (RTO był szacowany podczas analizy ryzyka). Powinna być spełniona zależność $RTA \leq RTO$.

Recovery Point Objective (RPO) – parametr ten określa „akceptowalne straty w danych” mierzone utraconym wolumenem zmian danych w czasie od ostatniej kopii zapasowej do chwili „katastrofy” (tj. wyznacza ostatni przed „katastrofą”, możliwy do odtworzenia, stan systemu).

Backup Window Objective (BWO) – parametr ten określa wymaganą długość przerwy w przetwarzaniu danych, niezbędną do wykonania kopii zapasowej.

Maximum Data Loss (MDL) – parametr ten określa maksymalną wielkość utraconych danych z uwzględnieniem dodatkowych możliwości odtwarzania (logi transakcji, dokumenty papierowe itp.).

zapora osobista

Zapora osobista (ang. *personal firewall*) ma za podstawowe zadanie

Wybierz jedną odpowiedź:

- ☐ a. szyfrować transmitowane lokalnie pakiety
- ☐ b. wymuszać logowanie użytkownika stacji roboczej
- ☐ c. filtrować pakiety wchodzące/wychodzące do/z stacji roboczej
- ☐ d. chronić centralny serwer sieci LAN przed nieuprawnionymi działaniami

Odp. C

AF WAF

AF (zapora aplikacyjna) to rozwinięcie tradycyjnych zapór sieciowych o mechanizmy rozpoznawania aplikacji (poprzez dekodowanie pakietów w warstwie 7) i kontroli dostępu użytkowników do konkretnych aplikacji.

WAF (ang. *Web Application Firewall*) to w zasadzie specjalizowany do analizy aplikacji webowych IPS. Wymagania, które powinna spełniać zapora sieciowa typu WAF, są sformułowane w:

Payment Card Industry Data Security Standard – PCI DSS – (sekcje 6.5 i 6.6).

stosowana w określaniu praw dostępu

Stosowana w określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków, nazywa się:

Wybierz jedną odpowiedź:

- ☐ a. zasadę wiedzy koniecznej
- ☐ b. zasadę dwóch osób
- ☐ c. zasadę rotacji obowiązków
- ☐ d. zasadę minimalnego środowiska pracy

Odp. A

2. Zasada wiedzy niezbędnej („wiedza konieczna”):

pracownik powinien wiedzieć tylko tyle, ile jest mu niezbędne do rzetelnego wykonywania jego obowiązków służbowych.

urządzenia forward proxy

Urządzenia *forward proxy*:

Wybierz jedną odpowiedź:

- ☐ a. kontrolują dostęp procesów do konkretnych aplikacji
- ☐ b. ukrywają tożsamość klienta przed serwerem usługi
- ☐ c. kontrolują dostęp użytkowników do konkretnych aplikacji
- ☐ d. ukrywają tożsamość serwera usługi przed klientem

Odp. B



kopiowanie z pełnym

Kopiowanie (w celu wytworzenia kopii bezpieczeństwa), w którym w wybranym dniu tygodnia zapisujemy komplet danych, natomiast w pozostałe dni robocze zapisujemy jedynie dane zmienione od ostatniego kopiowania pełnego nazywamy:

Wybierz jedną odpowiedź:

- ☐ a. lustrzanym
- ☒ b. różnicowym
- ☐ c. przyrostowym
- ☐ d. pełnym

[Odznacz mój wybór](#)

Odp. B

1. Kopia **pełna**

W ustalonych czasie (np. codziennie o godz. 17.00) kopiuje się na nośniki zapasowe zasoby informacyjne zgodnie ze specyfikacją z „Planu odtwarzania”, bez względu na to, czy zostały one zmodyfikowane czy też nie. Podstawową wadą tego rodzaju kopiowania jest wysokie zapotrzebowanie na nośniki danych.

2. Kopia **różnicowa** (tygodniowa)

W wybranym dniu (np. w piątek) zapisuje się komplet danych, natomiast w pozostałe dni robocze zapisuje jedynie dane zmienione od ostatniego kopiowania **pełnego**. Przechowywane są jedynie kopie pełne, nośniki z kopiami różnicowymi są kasowane po wykonaniu kolejnej kopii pełnej i używane ponownie, o ile takie działanie dopuszcza wdrożona polityka bezpieczeństwa.

3. Kopia **przyrostowa** (tygodniowa)

W wybranym dniu (np. w piątek) zapisuje się komplet danych, natomiast w pozostałe dni robocze zapisuje jedynie dane zmienione od ostatniego kopiowania. Przechowywane są jedynie kopie pełne, nośniki z kopiami przyrostowymi są kasowane po wykonaniu kolejnej kopii pełnej i używane ponownie, o ile takie działanie dopuszcza wdrożona polityka bezpieczeństwa.

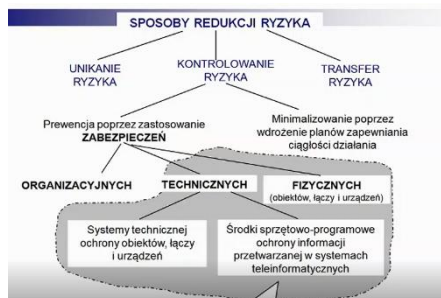
korzystanie z systemu ochrony fizycznej

Korzystanie z systemu ochrony fizycznej i technicznej obiektów, w ramach metod postępowania z ryzykiem, należy do:

Wybierz jedną odpowiedź:

- ☐ a. kontrolowania ryzyka
- ☐ b. transferu ryzyka
- ☐ c. unikania ryzyka
- ☐ d. retencji ryzyka

Odp. A



produkt klasy SIEM

Produkty klasy SIEM służą do:

Wybierz jedną odpowiedź:

- ☐ a. nadzorowania obiegu informacji w systemie informatycznym i wspomagania przeciwdziałania jej wyciekowi
- ☐ b. kontroli tożsamości użytkowników systemu informatycznego
- ☐ c. korelowania wyników działania różnych narzędzi z zakresu bezpieczeństwa (IPS, WAF, itd.) oraz automatyzacji prezentacji wybranych zdarzeń i reakcji na te zdarzenia
- ☐ d. analizy i korelacji informacji wieloźródłowej o zdarzeniach zachodzących w systemie informatycznym i przedstawiania w czasie zbliżonym do rzeczywistego spójnego, kompleksowego obrazu stanu tego systemu

Odp. D

SIEM DLP SOAR

DLP (ang. *Data Leak Protection*) – oprogramowanie do nadzorowania obiegu informacji w systemie informatycznym i wspomagające przeciwdziałanie jej wyciekowi.

SIEM (ang. *Security Information and Event Management*) – oprogramowanie do analizy i korelacji informacji wieloźródłowej o zdarzeniach zachodzących w systemie informatycznym (pozyskiwanej z własnych agentów i z dzienników zdarzeń różnych urządzeń i programów zainstalowanych w systemie nadzorowanym) i na tej podstawie przedstawiający w czasie zbliżonym do rzeczywistego (ang. *near real-time*) spójny, kompleksowy obraz stanu systemu informatycznego przydatny do zarządzania ryzykiem operacyjnym IT.

SOAR (ang. *Security Orchestration, Automation and Response*) – narzędzie do zgrywania (tak jak „zgrywa się” działania jednostek wojskowych) wyników działania różnych narzędzi z zakresu „bezpieczeństwa” (IPS, WAF, itd.), automatyzacji prezentacji wybranych zdarzeń oraz reakcji na nie. SOAR zwykle współpracują z SIEM.

założenia: kopia pełna jest wykonywana

Założenia: kopia pełna jest wykonywana w każdy piątek o godz. 18:00; w dni robocze wykonywane są kopie różnicowe o godz. 18:00; każda kopia (także pełna) zajmuje jeden nośnik. **Pytanie:** nośniki z kopiami różnicowymi z jakich dni są niezbędne do odtworzenia zbiorów informacyjnych, jeżeli oryginalne zbiory zostały zniszczone w czwartek o 17:50:

Wybierz jedną odpowiedź:

- ☐ a. piątek, środa
- ☒ b. poniedziałek, wtorek, środa
- ☐ c. czwartek
- ☐ d. środa

[Odznacz mój wybór](#)

Odp. B? D?

do uwierzytelniania danych

Do uwierzytelniania danych stosuje się:

Wybierz jedną odpowiedź:

- ☐ a. tokeny
- ☒ b. sumy kontrolne i podpisy cyfrowe
- ☐ c. hasła
- ☐ d. metody biometryczne

[Odznacz mój wybór](#)

Odp. B lub C ...raczej B

Suma kontrolna (ang. *checksum*) – liczba uzyskana według specjalnego algorytmu służąca do zapewnienia **integralności danych**.

Podpis cyfrowy – matematyczny sposób sprawdzenia autentyczności **dokumentów i wiadomości elektronicznych**. Poprawny podpis oznacza, że wiadomość pochodzi od właściwego nadawcy, który nie może zaprzeczyć faktowi jej nadania, oraz że wiadomość nie została zmieniona podczas transmisji.

metody biometryczne

Weryfikacja cech fizycznych

Wykorzystywane są tzw. metody biometryczne, polegające na identyfikacji podmiotu (przez element systemu ochrony) poprzez porównanie z wzorcem wybranych cech biometrycznych (linii papilarnych, tęczy oka, głosu, itd.).

token

Token (w języku polskim także **żeton**)

– generator kodów jednorazowych – urządzenie elektroniczne służące do uwierzytelniania transakcji internetowych, najczęściej bankowych.

hasła

Metoda ta polega na sprawdzaniu przez element systemu ochrony informacji znanej wyłącznie użytkownikowi.

Najprostszą i najczęściej stosowaną formą realizacji tej metody jest sprawdzanie hasła.

Hasła nie powinny być przechowywane w postaci jawnej (również tak drukowane czy wyświetlane),

czy dane w postaci elektronicznej opatrzone

Czy dane w postaci elektronicznej opatrzone podpisem potwierdzonym profilem zaufanym ePUAP są równoważne pod względem skutków prawnych dokumentowi opatrzonemu podpisem własnoręcznym:

Wybierz jedną odpowiedź:

☒ a. TAK, chyba że przepisy odrębne stanowią inaczej

☐ b. NIE

Odp. A

para (poziom atrybutu, kategoria informacji)

7. Para (poziom atrybutu, kategoria informacji) wyznacza klasę:

Wybierz jedną odpowiedź:

☐ a. bezpieczeństwa

☐ b. sterowania dostępem

☒ c. uwierzytelniania

☐ d. autoryzacji

[Odznacz mój wybór](#)

Odp. C

atak na system informacyjny

Atak na system informacyjny i informację w nim przetwarzaną jest:

Wybierz jedną odpowiedź:

☒ a. zagrożeniem

☐ b. sposobem realizacji zagrożenia

☐ c. elementem socjotechniki

☐ d. narzędziem intruza

[Odznacz mój wybór](#)

Odp. B

Atak na system informacyjny i informację w nim przetwarzaną **to sposób realizacji zagrożenia** poprzez **nieuprawnione, celowe działanie człowieka** powodujące **niepożądaną zmianę** wymaganych wartości istotnych kryteriów jakości informacji.

zagrożenie

Zagrożenie (dla bezpieczeństwa informacji) to materialny i/lub niematerialny czynnik mogący spowodować niepożądaną zmianę wymaganych wartości istotnych kryteriów jakości informacji.

zabezpieczenia

Zabezpieczenia to środki:

- fizyczne (np. sejf, płot, przegroda budowlana),
 - techniczne (np. system alarmowy, system p.poż.),
 - osobowe (np. strażnik),
 - programowe (np. oprogramowanie antywirusowe)
- oraz działania organizacyjne (np. szkolenia), stosowane w celu przeciwdziałania wykorzystaniu podatności przez zagrożenia.

Norma 27001 dotyczy

- klas metod kryptograficznych
- konstrukcji bezpiecznych produktów informatycznych
- sposobów archiwizowania informacji
- **systemów zarządzania bezpieczeństwem informacji**

bezpieczeństwo informacji

Bezpieczeństwo informacji oznacza **uzasadnione** (np. analizą ryzyka i przyjętymi metodami postępowania z ryzykiem) **zaufanie**, że nie zostaną poniesione straty wynikające z niepożądanego zmiany, na skutek realizacji zagrożenia, wymaganych wartości istotnych kryteriów jakości informacji.

Bezpieczeństwo informacyjne oznacza uzasadnione zaufanie podmiotu do jakości i dostępności pozyskiwanej oraz wykorzystywanej informacji i obejmuje wszystkie jej formy (werbalne, elektroniczne, „papierowe”).

Za pomocą VPN nie da się zabezpieczyć

- **dostępności**
- integralności
- czytelności

Czy zastosowanie profilu zaufanego ePUAP w kontaktach z administracją państwową jest równoważne, co do skutków prawnych, użyciu bezpiecznego podpisu elektronicznego weryfikowanego kwalifikowanym certyfikatem?

- **tak**
- nie

Postępowanie i wdrożenie planów zapewniania ciągłości działania w ramach metod postępowania z ryzykiem to

- retencji ryzyka
- transferu ryzyka
- unikania ryzyka
- **kontrolowania ryzyka**

Podstawowe metody realizacji operacji uwierzytelniania tożsamości użytkownika to:

- weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja wiedzy użytkownika, weryfikacja jego uprawnień systemowych
- weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja cech fizycznych użytkownika, weryfikacja komputera z którego loguje się użytkownika
- **weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja cech fizycznych użytkownika, weryfikacja wiedzy użytkownika**

Audyt w zakresie bezpieczeństwa informacyjnego

- wykonuje się przy okazji sporządzania spisu zasobów informacyjnych
- jest tym samym co test penetracyjny
- **wymaga tzw wzorca audytowego i niezależności podmiotu wykonującego audyt**
- polega na sprawdzeniu logów systemowych przez administratora systemu teleinformatycznego

Wymagania na system zarządzania bezpieczeństwem informacji (SZBI) są opisane w normie

- PN-ISO/1EC-9001
- PN-ISO/1EC-15408

- PN-ISO/1EC-27001

- nie są opisane w żadnej normie

Czy obowiązuje w Polsce Kodeks Karny przewiduje sankcje za nieuprawnione, szkodliwe działanie wobec systemu komputerowego i informacji w nich przetwarzanej?

- tak
- nie

Nie każdy incydent z zakresu bezpieczeństwa teleinformatycznego jest przestępstwem w rozumieniu polskiego prawa – przestępstwem jest tylko to, na co jest paragraf w Kodeksie Karnym.

spójny system ochrony dostępu do zasobów

Procesy wykrywania, autoryzacji, uwierzytelniania i weryfikacji autoryzacji wraz z zabezpieczeniami powinny tworzyć spójny system ochrony dostępu do zasobów

Klasyfikacja

Klasyfikacja – cd.

1. Klasyfikacja, w zastosowaniu do ochrony informacji, polega zatem na wyznaczeniu par:

(poziom atrybutu, kategoria informacji)

Na przykład, jeżeli chronionym atrybutem ma być „tajność”, to ww. formuła ma postać:

(poziom tajności, kategoria informacji)

W szczególnym przypadku może to być np.:

(tajne, dyslokacja specgrup)

SSO

SSO (ang. *Single Sign-On*) – mechanizm, z pomocą którego jedna akcja uwierzytelniania oraz autoryzacji umożliwia użytkownikowi uzyskanie dostępu do wszystkich komputerów oraz systemów, do których dany użytkownik ma uprawnienia dostępu, bez konieczności wielokrotnego wprowadzania haseł.

zarządzanie incydentami

Zarządzanie incydentami to systematyczne stosowanie polityki, procedur i praktyki zarządzania do zadań:

- wykrywania i rejestrowania incydentów,
- analizowania i klasyfikowania incydentów,
- minimalizowania negatywnych skutków incydentów,
- ustalania i wykonywania działań prewencyjnych.

istnienie ryzyka

Istnienie ryzyka oznacza występowanie zagrożenia dla chronionych atrybutów informacji. Wielkość ryzyka określa się łącząc możliwości wystąpienia zdarzeń powodowanych przez zagrożenie i wielkości szkód (skutków) powstałych w wyniku tych zdarzeń.

$RYZYKO = f(\text{MOŻLIWOŚĆ REALIZACJI ZAGROŻENIA, SZKODY})$

zarządzanie ryzykiem

Zarządzanie ryzykiem to systematyczne stosowanie polityki, procedur i praktyki zarządzania do zadań:

- ustalania kontekstu ryzyka,
- jego identyfikowania,
- analizowania,
- wyznaczania,
- postępowania z ryzykiem,
- oraz monitorowania i komunikowania ryzyka.

audyt

Audyt – w zakresie bezpieczeństwa informacyjnego nazywa się tak postępowanie sprawdzające sposób wykonania i stan zabezpieczeń systemu informacyjnego na zgodność z określonymi wymaganiami lub standardami (tzw. *wzorzec audytowy*, np. PN-ISO/IEC 27001, CoBIT), wykonywane przez stronę *niezależną*.

1 . Promieniowanie ujawniające: (Wybierz jedną odpowiedź:)

- a) jest promieniowaniem elektromagnetycznym stanowiącym zagrożenie dla tajności informacji przetwarzanej w systemie komputerowym
- b) nie stanowi żadnego zagrożenia

c) jest promieniowaniem akustycznym i/lub elektromagnetycznym stanowiącym zagrożenie dla tajności informacji przetwarzanej w systemie komputerowym
d) jest promieniowaniem akustycznym i/lub elektromagnetycznym stanowiącym zagrożenie dla tajności i integralności informacji przetwarzanej w systemie komputerowym.

2 . Incydent z zakresu bezpieczeństwa informacyjnego to:

Wybierz jedną odpowiedź:

- a) zawsze i tylko rezultat działania cyberprzestępcy
- b) stan systemu informacyjnego, który powoduje lub może powodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- c) proces ujawniania podatności w systemie informacyjnym
- d) zdarzenie lub ciąg zdarzeń (składających się na realizację zagrożenia) które powoduje lub może powodować niepożądaną zmianę istotnych kryteriów jakości informacji

3 . Uznaniowe sterowane dostępem (ang. Discretionary Access Control, DAC) wykorzystuje: wybierz jedną odpowiedź:

- a. przypisane do podmiotów i obiektów: atrybuty, warunki opisujące środowisko i zbiory zasad
- b. przypisane podmiotom role
- c. nadane obiektom i podmiotom etykiety
- d. atrybut własności obiektu

4. Atak na system informacyjny i informację w nim przetwarzaną jest : (wybierz jedną odpowiedź):

- a. zagrożeniem
- b. sposobem realizacji zagrożenia
- c. narzędziem intruza
- d. elementem socjotechniki

5 . Proces realizowany przez podsystem kontroli dostępu logicznego systemu komputerowego, gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do pliku, nazywa się(Wybierz jedną odpowiedź):

- a. weryfikacją uwierzytelnienia
- b. weryfikacją poziomu ochrony
- c. weryfikacją tożsamości
- d. weryfikacją autoryzacji

6 . Ustalany eksperymentalnie czas przywrócenia działania systemu informatycznego i odtworzenia zbiorów danych określa parametr(Wybierz jedną odpowiedź):

- a. RTO
- b. BWO
- c. RPO
- d. RTA

7 . Parametr Recovery Time Actual (RTA) określa (wybierz jedną odpowiedź):

- a. „akceptowalne straty w danych” (aktualność danych odtworzonych po katastrofie) mierzone czasem od ostatniej kopii zapasowej do chwili katastrofy
- b. wymaganą długość przerwy w przetwarzaniu danych, niezbędną do wykonania kopii zapasowej
- c. ustalany drogą eksperymentów czas przywrócenia działania systemu informatycznego i odtworzenia zbiorów danych
- d. maksymalny, możliwy do zaakceptowania przez kierownictwo organizacji, ze względu na ponoszone straty, czas pracy bez możliwości korzystania z usług całości lub części systemu informatycznego

8 . Podmiot świadczący usługi kolokacji (wybierz jedną odpowiedź):

- a. udostępnia swoje centrum danych (infrastrukturę), a klient wstawia tam swój sprzęt komputerowy
- b. udostępnia klientowi swoje centrum danych (infrastrukturę) i swój sprzęt komputerowy

- c. szkoli pracowników klienta z ochrony zasobów informacyjnych
- d. serwisuje sprzęt komputerowy w siedzibie klienta

9 . Założenia: kopia pełna jest wykonywana w każdy piątek o godz. 18:00; w dni robocze wykonywane są kopie różnicowe o godz 18:00; każda kopia (także pełna) zajmuje jeden nośnik. Pytanie: nośniki z kopiami różnicowym z jakich dni są niezbędne do odtworzenia zbiorów informacyjnych, jeżeli oryginalne zbiory zostały zniszczone w czwartek o 17:50 (Wybierz jedną odpowiedź):

- a. poniedziałek, wtorek, środa
- b. czwartek
- c. piątek, środa
- d. środa

10. Inspektora bezpieczeństwa teleinformatycznego wyznacza się, zgodnie z odpowiednią ustawą, w przypadku przetwarzania w systemach teleinformatycznych (Wybierz jedną odpowiedź):

- a. informacji wrażliwych
- b. danych osobowych
- c. informacji niejawnych
- d. danych bankowych

11 . Stosowana w określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków, nazywa się (Wybierz jedną odpowiedź):

- a. zasadą wiedzy koniecznej
- b. zasadą dwóch osób
- c. zasadą rotacji obowiązków
- d. zasadą minimalnego środowiska pracy

12 . Czy dane w postaci elektronicznej opatrzone podpisem potwierdzonym profilem zaufanym ePUAP są równoważne pod względem skutków prawnych dokumentowi opatrzonemu podpisem własnoręcznym (Wybierz jedną odpowiedź):

- a. TAK, chyba że przepisy odrębne stanowią inaczej
- b. NIE

13. Korzystanie z systemu ochrony fizycznej i technicznej obiektów, w ramach metod postępowania z ryzykiem, należy do (Wybierz jedną odpowiedź): (strona 115)

- a. transferu ryzyka
- b. kontrolowania ryzyka
- c. unikania ryzyka
- d. retencji ryzyka

14 . Czy podatność jest warunkiem koniecznym realizacji zagrożenia (Wybierz jedną odpowiedź): (strona 7)

- a. NIE
- b. TAK

15. Minimalny zbiór cech skutecznego systemu ochrony informacji przetwarzanej w systemach informacyjnych obejmuje (Wybierz jedną osobę):

- a. dywersyfikację i spójność zastosowanych zabezpieczeń
- b. dywersyfikację i niesprzeczność zastosowanych zabezpieczeń
- c. dywersyfikację, spójność, niesprzeczność zastosowanych zabezpieczeń i organizację ochrony "w głąb"
- d. dywersyfikację oraz spójność zastosowanych zabezpieczeń i organizację ochrony "w głąb"

16 . Zasada Defense-in-depth (obrona w głąb) oznacza, że (Wybierz jedną odpowiedź):

- a. zastosowano implementację zasad polityki bezpieczeństwa z uwzględnieniem ataków na warstwę aplikacyjną (zasada stosowana min. przez aplikacyjne zapory sieciowe)
- b. po przełamaniu jednej warstwy zabezpieczeń zagrożenie natrafia na kolejną, z innymi zabezpieczeniami
- c. następuje zmniejszenie prawdopodobieństwa ukrycia źródła ataku poprzez wdrożenie systemu zabezpieczeń wewnątrz sieci LAN

d. wykorzystano w obrębie jednego urządzenia sieciowego wiele funkcji zabezpieczeń dla różnych usług, np.: poczty elektronicznej, baz danych, serwerów FTP itp.

17 . Test penetracyjny to (Wybierz jedną odpowiedź):

- a. metoda oddziaływania socjotechnicznego
- b. metoda zbierania informacji o badanym systemie
- c. to samo, co audyt bezpieczeństwa informacyjnego
- d. metoda włamywania się do systemu informacyjnego

18. Zapora osobista (ang. personal firewall) ma za podstawowe zadanie (Wybierz jedną odpowiedź):

- a. wymuszać logowanie użytkownika stacji roboczej
- b. szyfrować transmitowane lokalnie pakiety
- c. chronić centralny serwer sieci LAN przed nieuprawnionymi działaniami
- d. filtrować pakiety wchodzące/wychodzące do/z stacji roboczej

19 . Para (poziom atrybutu, kategoria informacji) wyznacza klasę (Wybierz jedną odpowiedź):

- a. bezpieczeństwa
- b. sterowania dostępem
- c. uwierzytelniania
- d. autoryzacji

20 . Podstawowe atrybuty informacji związane z jej bezpieczeństwem, to (wybierz jedną odpowiedź):

- a. tajność, integralność, dostępność
- b. integralność, metoda szyfrowania, dostępność
- c. tajność, integralność, długość (w bajtach)
- d. tajność, integralność, długość (w znakach)

21 . Dokument Polityka bezpieczeństwa informacyjnego powinien być dokumentem zawierającym (Wybierz jedną odpowiedź):

- a. szczegółowe plany obiegu informacji i schematy sieci teleinformatycznych
- b. zapis najważniejszych ogólnym zamiarów działań kierownictwa organizacji w zakresie bezpieczeństwa własnych i powierzonych informacji i jego deklaracje co do zapewniania odpowiedniego poziomu tego bezpieczeństwa
- c. instrukcje i procedury dla osób korzystających z systemów teleinformatycznych organizacji
- d. wykaz stosowanych w organizacji podstawowych zabezpieczeń informacji

22 . Poprawna treść Zasady Kerckhoffs'a to (Wybierz jedną odpowiedź):

- a. Odporność kryptosystemu powinna zależeć od utrzymania tajności przekształceń używanych w tym krypto systemie, a nie od tajności klucza wybierającego konkretne przekształcenie.
- b. Odporność kryptosystemu powinna zależeć od utrzymania tajności klucza wybierającego konkretne przekształcenie, a nie od tajności przekształceń używanych w tym kryptosystemie.

23. Kopiowanie (w celu wytwarzania kopii bezpieczeństwa), w którym w wybranym dniu tygodnia zapisujemy komplet danych, natomiast w pozostałe dni robocze zapisujemy jedynie dane zmienione od ostatniego kopiowania nazywamy (Wybierz jedną odpowiedź):

- a. pełnym
- b. lustrzanym
- c. przyrostowym
- d. różnicowym

24. Terminem "hoax" określa się (Wybierz jedną odpowiedź):

- a. programowy obiekt złośliwy przeprowadzający działania destrukcyjne w systemie
- b. sprzętowy obiekt złośliwy posiadający zdolność powielania się
- c. rodzaj aktu socjotechnicznego - żart rozsyłany pocztą elektroniczną
- d. programowy obiekt złośliwy posiadający zdolność powielania się

25 . Zgodnie ustawą z dn. 05.08.2010 "O ochronie informacji niejawnych" informację

niejawną oznacza się klauzulą (Wybierz jedną odpowiedź):

- a. "tajne" lub "poufne" lub "zastrzeżone"
- b. "ściśle tajne" lub "tajne" lub "poufne" lub do "użytku wewnętrznego"
- c. "ściśle tajne" lub "tajne" lub "poufne" lub "zastrzeżone"
- d. "ściśle tajne" lub "tajne" lub "poufne"

26 . Sandbox to (Wybierz jedną odpowiedź):

- a. rodzaj testu penetracyjnego wykonywany z zewnątrz, bez znajomości struktury oraz konfiguracji testowanego środowiska
- b. metoda porównania analizowanego obiektu z bazą sygnatur wirusów
- c. mechanizm służący do separacji programów oraz wykonywania nie zaufanego kodu w odizolowanym środowisku
- d. skaner portów

27 . Norma PN-ISO/IEC-15408 dotyczy (Wybierz jedną odpowiedź):

- a. sposobów archiwizowania informacji
- b. klas metod kryptograficznych
- c. konstrukcji i oceny "bezpiecznych" produktów informatycznych
- d. systemu zarządzania bezpieczeństwem informacji

28 . Podpis cyfrowy ma za zadanie zapewnić (Wybierz jedną odpowiedź):

- a. tylko integralność informacji
- b. tylko poufność i autentyczność informacji
- c. dostępność informacji
- d. niezaprzeczalność, autentyczność, integralność informacji

29. Informacja, której manipulowanie, uniedostępnienie lub ujawnienie może wyrządzić szkody firmie lub osobie prywatnej to informacja (Wybierz jedną odpowiedź):

- a. wrażliwa
- b. publiczna
- c. niejawna
- d. podatna

30 . Produkt klasy **SIEM** służą do (Wybierz jedną odpowiedź):

- a. korelowania wyników działania różnych narzędzi z zakresu bezpieczeństwa (IPS, WAF, itd.) oraz automatyzacji prezentacji wybranych zdarzeń i reakcji na te zdarzenia
- b. nadzorowania obiegu informacji w systemie informatycznym i wspomagania przeciwdziałania jej wyciekowi
- c. analizy i korelacji informacji wieloźródłowej o zdarzeniach zachodzących w systemie informatycznym i przedstawiania w czasie zbliżonym do rzeczywistego spójnego, kompleksowego obrazu stanu tego systemu
- d. kontroli tożsamości użytkowników systemu informatycznego

31. Dokument "Plan bezpieczeństwa informacyjnego dla..." powinien być dokumentem (Wybierz jedną odpowiedź):

- a. jawnym
- b. dostępnym zgodnie z zasadą wiedzy koniecznej
- c. poufnym (w rozumieniu ustawy o ochronie informacji niejawnych)
- d. do użytku wewnętrznego

32 . Norma PN-ISO/IEC-15408 dotyczy (Wybierz jedną odpowiedź):

- a. sposobów archiwizowania informacji
- b. klas metod kryptograficznych
- c. konstrukcji i oceny "bezpiecznych" produktów informatycznych
- d. systemu zarządzania bezpieczeństwem informacji

33. Urządzenie forward proxy (Wybierz jedną odpowiedź):

- a. kontrolują dostęp procesów do konkretnych aplikacji
- b. kontrolują dostęp użytkowników do konkretnych aplikacji
- c. ukrywają tożsamość klienta przed serwerem usługi
- d. urywają tożsamość serwera usługi przed klientem

34. Do uwierzytelniania danych stosuje się (Wybierz jedną odpowiedź):

- a. tokeny
- b. sumy kontrolne i podpisy cyfrowe
- c. hasło
- d. metody biometryczne

35. Czy zastosowanie profilu zaufanego ePUAP w kontaktach z administracją państwową jest równoważne, co do skutków prawnych, użyciu bezpiecznego podpisu elektronicznego weryfikowanego kwalifikowanym certyfikatem?

- a. TAK
- b. NIE

36. Przygotowanie i wdrożenie planów zapewnienia ciągłości działania, w ramach postępowania z ryzykiem, należy do:

- a. retencji ryzyka
- b. transferu ryzyka
- c. unikania ryzyk
- d. kontrolowania ryzyka

37. Podstawowe metody realizacji operacji uwierzytelniania tożsamości użytkownika to:

- a. weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja wiedzy użytkownika, weryfikacja jego uprawnień systemowych
- b. weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja cech fizycznych użytkownika, weryfikacja komputera z którego loguje się użytkownik
- c. weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja wiedzy użytkownika, weryfikacja miejsca logowania użytkownika
- d. weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja cech fizycznych użytkownika, weryfikacja wiedzy użytkownika

38. Audyt w zakresie bezpieczeństwa informacyjnego:

- a. wykonuje się przy okazji sporządzania spisu zasobów informacyjnych
- b. jest tym samym co jest penetracyjny (obie nazwy oznaczają to samo)
- c. wymaga tzw. wzorca audytowego i niezależności podmiotu wykonującego audyt
- d. polega na sprawdzaniu logów systemowych przez administratora systemu teleinformatycznego

39. Wymagania na system zarządzania bezpieczeństwem informacji (SZBI) są opisane w normie:

- a. PN-ISO/IEC-9001
- b. PN-ISO/IEC-15408
- c. PN-ISO/IEC-27001
- d. e snią opisane w żadnej normie

40. Czy obowiązujący w Polsce Kodeks Karny przewiduje sankcje za nieuprawnione, szkodliwe działania wobec systemów komputerowych i informacji w nich przetwarzanej:

- a. NIE
- b. TAK

41. **Termin** "steganografia" **oznacza** (Wybierz jedną odpowiedź):

- a. rysunki stegozaurów wykonywane na ścianach jaskiń przez człowieka pierwotnego
- b. metodę zapewnienia integralności informacji
- c. metodę ukrywania informacji
- d. sposób weryfikacji tożsamości użytkownika systemu teleinformatycznego

42. **Podmiot świadczący usługi** hostingu (Wybierz jedną odpowiedź):

- a. serwisuje sprzęt komputerowy w siedzibie klienta
- b. administruje i przetwarza w swoim centrum komputerowym zasoby informacyjne powierzone przez klienta
- c. udostępnia klientowi swoje centrum danych i swój sprzęt komputerowy
- d. udostępnia swoje centrum danych, a klient wstawia tam swój sprzęt komputerowy

43. **UTM** (Unified Threat Management) **oznacza** (Wybierz jedną odpowiedź):

- a. zespół zarządzający w firmie bezpieczeństwem teleinformatycznym
- b. integrację oprogramowania zabezpieczającego w jeden kompleksowy system ochrony, osadzony na specjalizowanej platformie sprzętowej

- c. metodykę analizy ryzyka na potrzeby bezpieczeństwa informacyjnego
 - d. metodykę szyfrowania danych uwierzytelniających
44. Za pomocą VPN nie da się zabezpieczyć
- a. dostępności
 - b. integralności
 - c. czytelności
45. Postępowanie i wdrożenie planów zapewniania ciągłości działania w ramach metod postępowania z ryzykiem to
- a. retencji ryzyka
 - b. transferu ryzyka
 - c. unikania ryzyka
 - d. kontrolowania ryzyka
46. Ubezpieczenia zalicza się do....
- a. kontroli ryzyka
 - b. retencji ryzyka
 - c. transferu ryzyka
- 47 . Co się dzieje z plikiem po usunięciu z dysku:
- a. wpis w \$MFT jest usuwany, dane zostają
 - b. wpis w \$MFT zostaje, dane zostają i zmieniają się dwie flagi
 - c. wpis w \$MFT jest usuwany, dane są usuwane
 - d. wpis w \$MFT zostaje, dane zostają
- 48 . Stosowanie określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków nazywa się:
- a. zasada wiedzy koniecznej
 - b. zasada rotacji obowiązków
 - c. zasada minimalnego środowiska pracy
 - d. zasada dwóch osób
- 49 . Dokument „Polityka bezpieczeństwa teleinformatycznego dla...” powinien być dokumentem:
- a. do użytku wewnętrznego
 - b. jawnym
 - c. nie ma znaczenia
 - d. poufny
- 50 . Zgodnie z ustawą o ochronie informacji niejawnych informacje nie jawne oznacza się klauzulą
- a. ściśle tajne lub tajne lub poufne lub zastrzeżone
 - b. ściśle tajna lub tajne
 - c. poufne lub zastrzeżone
 - d. jawne
- 51 . Norma 27001 dotyczy:
- a. klas metod kryptograficznych
 - b. konstrukcji bezpiecznych produktów informatycznych
 - c. sposobów archiwizowania informacji
 - d. systemów zarządzania bezpieczeństwem informacji

Z TXT

17. Co nie jest plikiem systemowym NTFS \$Sector.

>3. czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

6. Jaka norma jest od Systemu zarządzania bezpieczeństwem norma ISO27001

10. Na czym bazuje autoryzacja dostępu na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

1. Ubezpieczenie zalicza się do - transferu ryzyka
2. Co to jest SNORT - IDS/IPS...
3. W którym dokumencie opisano System Zarządzania Bezpieczeństwem Informacji - ISO 27001
4. Zasada, żeby pracownik, do wykonywania pracy, miał tylko dostęp do tych programów i usług, których potrzebuje to - zasada minimalnego środowiska pracy
5. Pytanie z odpowiedzią - dane wrażliwe
6. Usługa kolokacji - udostępnienie miejsca, własny sprzęt
7. Co to jest Recovery Point Objective? ['A' było, jedyna odpowiedź w cudzysłowie.] akceptowalne straty w danych
8. zadanko ze od pon do cz o 18 jest backup niepełny a w piątek o 18 pełny i jak w czwartek o 17 50 sie zepsuje system to ile dyskow potrzeba z backupem żeby odnowic system - jeden backup = jeden dysk
9. ochrona danych osobowych - tylko dla żyjących
grupa F:
 - 2) outsourcing odp. transfer ryzyka
- grupa x:

Rta,

pytania z odp: renetcja ryzyka,

transfer ryzyka,

retencja aktywna,

audyt,
- grupa y:
 1. outsourcing

transfer ryzyka

utajnianie informacji

 4. rta time actual

chodzilo o eksperymenty do wyznaczania czasu jakiegos

 5. backup taki ze zapisuje raz pelny a potem tylko modyfikacje

roznicowy

wielofunkcyjne zapory sieciowe zintegrowane w postaci jednego urzadzenia

 8. ochrona danych osobowych

tylko dla

żyjącychjak przedostanie sie przez zapore to napotyka druga
- grupa z:
 2. Dokument polityka bezpieczeństwa powinien być dokumentem zawierającym - zapis najważniejszych ogólnych zamiarów działań kierownictwa organizacji w zakresie bezpieczeństwa własnym i powierzonych informacji i jego deklaracje w stosunku do zapewnienia bezpieczeństwa
- grupa m:
 2. Postępowanie i wdrożenie planów zapewniania ciągłości działania w ramach metod postępowania z ryzykiem to
 - kontrolowania ryzyka
10. Dokument „Polityka bezpieczeństwa teleinformatycznego dla...” powinien być dokumentem
- jawnym

PBI TEORIA JAKAŚ NIE WIEM CO TO

Przygotowanie i wdrożenie planów zapewnienia ciągłości działania:

Minimalizujemy straty wynikłe z wykorzystania podatności przez zagrożenia.

Dokument „Polityka bezpieczeństwa teleinformatycznego dla..” powinien być dokumentem: **Jawnym**.

Co to jest SNORT ? **IDS/IPS...** („prewencja przed intruzami”)

Co to jest RTA? **Czas przywrócenia danych (eksperymentalny)**.

Na czym polega hosting? **Udostępnione centrum danych i sprzętu**.

Outsourcing zaliczamy do: **Transferu ryzyka**.

Firewall co robi? **Kontrola ruchu pakietów w sieci**.

Zadanko ze od pon do cz o 18 jest backup niepełny a w piątek o 18 pełny i jak w czwartek o 17 50 się zepsuje system to ile dysków potrzeba z backupem żeby odnowić system - **jeden backup = jeden dysk**

Dokument polityka bezpieczeństwa powinien być dokumentem zawierającym:

Zapis najważniejszych ogólnych zamiarów działań kierownictwa organizacji w zakresie bezpieczeństwa własnym i powierzonych informacji i jego deklaracje w stosunku do zapewnienia bezpieczeństwa.

Coś tam o audycie bezpieczeństwa teleinformatycznego:

Zawiera się w audycie informatycznym (jest podzbiorem audytu informatycznego)

Jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa? **Niejawny – do użytku wewnętrznego.**

Kogo dotyczy Ustawa o ochronie danych osobowych? **Tylko żywych.**

Co to jest RPO ? **Był szacowany podczas analizy ryzyka – określa maksymalny, szacowany czas pracy możliwy do zaakceptowania przez kierownictwo organizacji**

Miara bezpieczeństwa w common criteria (norma iso 15194 czy jakoś tak) **Poziom uzasadnionego zaufania.**

Poprzez sporządzenie i w razie potrzeby wdrożenie planu odzyskiwania: **Minimalizujemy straty wynikłe z wykorzystania podatności przez zagrożenia.**

Jakie są klauzule tajemnicy państwowej? **Tajność, ścisła tajność.**

Management a kompleksowy system ochrony - **Difens po przełamaniu 1 warstwy**

Trochę info.

Informacja - Byt abstrakcyjny który zwiększa obszar wiedzy bądź zmniejsza obszar niewiedzy.

Przykład:

- dla piszącego kolokwium informacją nie jest – treść pytania, imię nazwisko osoby siedzącej obok, numer Sali w której piszemy kolokwium.
- dla ucznia szkoły pdst informacją jest – wzór na transmitancję Laplacea, przestrzeń Hilberta itp.

Bezpieczeństwo informacji - oznacza zachowanie poufności, integralności i dostępności informacji.

integralność - jest zdefiniowana jako zapewnienie dokładności i kompletności informacji oraz metod jej przetwarzania,

dostępność - jest zdefiniowana jako zapewnienie, że osoby upoważnione mają dostęp do informacji i związanych z nią aktywów wtedy, gdy jest to potrzebne.

Jakie są skutki zawyżania klauzul tajności:

Bezpieczeństwo przetwarzania danych (informacji) o zróżnicowanych klauzulach tajności - dane (informacje) o wyższej klauzuli tajności nie mogą „przepływać” do obiektów (aktywnych lub pasywnych) mających niższą klauzulę tajności. **Problem niedoceniany** - nadmierne koszty systemu bezpieczeństwa dla informacji o zawyżonych bez uzasadnienia klauzulach tajności barierą dla wzmacniania innych składników bezpieczeństwa informacyjnego (niegospodarne dysponowanie publicznymi środkami finansowymi)

Na czym polega problem bliskości:

Zarówno w świecie realnym, jak i cyberprzestrzeni występuje problem bliskości. Jeśli firma ma siedzibę w biurowcu wraz z innymi instytucjami, dla których ryzyko fizycznego ataku jest większe, firma ta przyjmuje w pewnej części to ryzyko. Takie fizyczne ataki mogą przybierać dowolną formę, od groźby podłożenia bomby do pikietowania, lub może być cokolwiek innego, co ma wpływ na działanie tego przedsiębiorstwa.

Co to są szkody uboczne:

Szkoda uboczna to taka, która jest spowodowana przez efekt uboczny towarzyszący danemu incydentowi. Nieraz jest to określane efektami kaskadowymi; zwykle ujawniają się one w systemach uzależnionych od systemów, w których wystąpiły incydenty. Szkoda uboczna jest relatywnie nowym problemem w dziedzinie bezpieczeństwa informacji

Co to jest polityka nakazowa, co to jest polityka uszczelniająca:

Polityka nakazowa obejmuje zbiór rozwiązań, które wprost wynikają z nakazów prawnych i które muszą być bezwzględnie stosowane.

Polityka uszczelniająca obejmuje zbiór rozwiązań, które decyzją kierownika jednostki organizacyjnej stanowią „wzmocnienie” rozwiązań nakazowych.

Na czym polega sterowanie dostępem:

- model Lampsona (macierzy dostępu) 1969
- najczęściej stosowany
- zbiór podmiotów, zbiór obiektów, zbiór reguł dostępu

Rozszerzenia:

- identyfikacja osoby tworzącej regułę dostępu
- wskaźnik prawa przekazania prawa dostępu
- reguły dodatkowych warunków dostępu

Reguła ochrony wykorzystująca ten mechanizm - upoważnienie dowolnego żądania dostępu polega na sprawdzeniu w macierzy dostępu czy istnieje reguła dostępu dopuszczająca jego realizację

Na czym polega sterowanie przepływem:

- korporacja MITRE, 1973
- zbiór obiektów pamięciowych
- zbiór procesów powodujących przepływ danych
- zbiór klas tajności
- relacja przepływu

Reguła ochrony wykorzystująca ten mechanizm - mechanizm sterowania przepływem powinien zabronić realizacji żądań powodujących przepływ danych niezgodnych z określoną relacją przepływu

Kto wchodzi w skład pionu ochrony danych niejawnych:

- **Pionem Ochrony Informacji Niejawnych** kieruje **Pełnomocnik do spraw Ochrony Informacji Niejawnych** zwany dalej „Pełnomocnikiem Ochrony”, który odpowiada za zapewnienie przestrzegania przepisów o ochronie informacji niejawnych.
- W skład **Pionu Ochrony Informacji Niejawnych** wchodzi **Kancelaria Tajna**, która stanowi wyodrębnioną komórkę organizacyjną podległą bezpośrednio Pełnomocnikowi Ochrony, odpowiedzialną za właściwe rejestrowanie, przechowywanie, obieg i wydawanie dokumentów zawierających informacje niejawne uprawnionym osobom.

Kto stoi na straży ochrony danych osobowych:

GIODO - Generalny Inspektor Ochrony Danych Osobowych

Kompetencje GIODO wyznaczają przepisy ustawy z dnia 29 sierpnia 1997 r.

o ochronie danych osobowych (t.j. Dz. U. z 2002 r. Nr 101, poz. 926, ze zm.). W ich świetle GIODO jest uprawniony do:

- kontroli zgodności przetwarzania danych z przepisami o ochronie danych osobowych,
- wydawania decyzji administracyjnych i rozpatrywanie skarg w sprawach wykonania przepisów o ochronie danych osobowych,
- prowadzenia rejestru zbioru danych oraz udzielanie informacji o zarejestrowanych zbiorach,
- opiniowania projektów ustaw i rozporządzeń dotyczących ochrony danych osobowych,
- inicjowania i podejmowania przedsięwzięć w zakresie doskonalenia ochrony danych osobowych,
- uczestniczenia w pracach międzynarodowych organizacji i instytucji zajmujących się problematyką ochrony danych osobowych.

W przypadku naruszenia przepisów o ochronie danych osobowych, Generalny Inspektor z urzędu lub na wniosek osoby zainteresowanej, w drodze decyzji administracyjnej, nakazuje przywrócenie stanu zgodnego z prawem, a w szczególności:

- usunięcie uchybień,
- uzupełnienie, uaktualnienie, sprostowanie, udostępnienie lub nieudostępnienie danych osobowych,
- zastosowanie dodatkowych środków zabezpieczających zgromadzone dane osobowe,
- wstrzymanie przekazywania danych osobowych do państwa trzeciego,
- zabezpieczenie danych lub przekazanie ich innym podmiotom,
- usunięcie danych osobowych.

W razie stwierdzenia, że działanie lub zaniechanie kierownika jednostki organizacyjnej, jej pracownika lub innej osoby fizycznej będącej administratorem danych wyczerpuje znamiona przestępstwa określonego w ustawie, Generalny Inspektor kieruje do organu powołanego do ścigania przestępstw zawiadomienie o popełnieniu przestępstwa, dołączając dowody dokumentujące podejrzenie.

Różnica pomiędzy administratorem danych osobowych a administratorem bezpieczeństwa danych osobowych:

Podstawowe obowiązki administratora danych osobowych

- obowiązek informacyjny wypełniany przy zbieraniu danych osobowych (art. 24 i 25 ustawy)
- szczególna staranność przy przetwarzaniu danych osobowych w celu ochrony interesów osób, których dane przetwarza (art. 26 ustawy)
- udzielanie informacji o zakresie przetwarzanych danych osobowych (art. 33 ustawy)
- obowiązek uzupełniania, uaktualnienia, sprostowania danych, czasowego lub stałego wstrzymania przetwarzania kwestionowanych danych lub ich usunięcia ze zbioru, gdy zażąda tego osoba, której dane są przetwarzane przez administratora (art. 35 ustawy)
- obowiązek stosowania środków technicznych i organizacyjnych zapewniających ochronę przetwarzanych danych osobowych odpowiednią do zagrożeń oraz kategorii danych objętych ochroną (art. 36 ustawy)

- kontroluje, jakie dane, kiedy i przez kogo zostały wprowadzone do zbioru i komu są przekazywane (art. 38 ustawy)
- prowadzi ewidencje osób upoważnionych do przetwarzania danych osobowych (art. 39 ustawy)
- zgłasza zbiór do rejestracji Generalnemu Inspektorowi Ochrony Danych Osobowych w przypadkach przewidzianych prawem (art. 40 ustawy)

Administrator bezpieczeństwa informacji ([skrót ABI](#)) – [termin prawniczy](#), który w [prawie polskim](#) został zdefiniowany w ustawie z dnia [29 sierpnia 1997](#) roku o [ochronie danych osobowych](#). Oznacza osobę nadzorującą z upoważnienia [administratora danych osobowych](#) przestrzeganie stosowania środków technicznych i organizacyjnych zapewniających ochronę [przetwarzanych danych osobowych](#) w sposób odpowiedni do zagrożeń oraz kategorii danych objętych ochroną.

Co to jest zagrożenie pasywne i aktywne:

- zagrożenia aktywne - wynikające z działań nieuprawnionego użytkownika np. wirusy, terroryzm, wandalizm, inżynieria społeczna
- zagrożenia pasywne - nie będące skutkiem celowego działania (np. powódź, trzęsienie ziemi, huragan, awaria zasilania, awaria sprzętu)

Co to jest polityka bezpieczeństwa:

Zestaw reguł określających wykorzystanie informacji, łącznie z jej przetwarzaniem, przechowywaniem, dystrybucją i prezentacją, niezależnie od wymagań dotyczących bezpieczeństwa i celów bezpieczeństwa

Zest. 4.

1. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

2. czego dotyczy norma ISO27001

3. czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

4. jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa

jawny

5. jakie klauzule odpowiadają tajemnicy państwowej

tajność , ścisła tajność

6. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje

zasada wiedzy koniecznej ((??) Skrypt 113)

7. hoax - co to jest

(tu nie wiem jakie były możliwości, wg wikipedii hoax to mistyfikacja ☺)

Zest. 5.

1. Miara bezpieczeństwa w common criteria (norma iso 15194 czy jakoś tak) - jest to poziom uzasadnionego zaufania.

2. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

3. Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność (Skrypt 124)

4. Zasada dostępu tylko do takich informacji przez pracownika , które mu są w tej chwili potrzebne to:

zasada wiedzy koniecznej (Skrypt 113)

5. Czy w prawie karnym jest paragraf za włamania komputerowe

Tak (Skrypt 96 – 99)

6. Jaka norma jest od Systemu zarządzania bezpieczeństwem

norma ISO27001

7. Różnica pomiędzy pełnym audytem informatycznym , a audytem bezpieczeństwa teleinformatycznego

różnica jest taka że pełny audyt jest nadzbiorem audytu bezpieczeństwa.

8. Jakie etykiety ma wiadomość sklasyfikowana jako tajemnica państwowa tajność , ścisła tajność

9. Jaki powinien być dokument "Planowania bezpieczeństwa dla ..."

powinien być jawny.

10. Na czym bazuje autoryzacja dostępu

na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

Zest. 5.

1. Co zapewnia Common Criteria i standard ISO/IEC 15408 ?

Odpowiedni poziom zaufania (odp. Ze słowem „zaufanie”)

2. Do czego wykorzystywany jest outsourcing?

Transfer ryzyka

3. Metody uwierzytelniania pracowników

weryfikacja przedmiotu posiadanego przez użytkownika (przepustka).

weryfikacja cech fizycznych użytkownika (odcisk palca, oko, długość palca)

weryfikacja wiedzy użytkownika (piny, hasła)

4. Co zapewnia podpis cyfrowy:

Jednoznaczność, autentyczność... (odpowiedź z największą liczbą wymienionych cech)

5. Czym różni się audyt informatyczny od audytu bezpieczeństwa

Audyt bezpieczeństwa zawiera się w audycie informatycznym.

6.) czy w polskim prawie jest paragraf dotyczący sankcji za włamania informatyczne?
tak

7. "polityka bezpieczeństwa" jaka powinna mieć klauzule tajności?

Jawna

8. w której normie jest mowa o wymaganiach dotyczących bezpieczeństwa teleinformatycznego

norma 27001

9. Pytanie dotyczące podawania pracownikom informacji

Odp. Zgodnie z zasadą wiedzy koniecznej

10. Atrybuty informacji związane z jej bezpieczeństwem

Tajność, integralność, dostępność

Troszke zebranych materiałów na ten temat:

1. Co to jest outsourcing?

Jest to wykorzystywanie zasobów zewnętrznych, zlecanie wyspecjalizowanym podmiotom zewnętrznym procesów niezbędnych do funkcjonowania dla funkcjonowania własnego przedsiębiorstwa, które zostaną zrealizowane efektywniej niż byłoby to możliwe we własnym zakresie. Zwykle dotyczy to zadań pomocniczych nie związanych bezpośrednio z uzyskiwaniem dochodu. Współcześnie bardzo często są to usługi ochroniarskie, prawnicze, informatyczne, księgowe, rekrutacyjne, wynajem pracowników, utrzymywanie czystości itp.

2. W której normie jest mowa o poziomie bezpieczeństwa teleinformatycznego?

Common Criteria. ISO/IEC 15408 (?)

3. Audyt bezpieczeństwa teleinformatycznego, a audyt informatyczny.

- Audyt informatyczny jest wykorzystywany w procesach biznesowych organizacji systemów informatycznych oraz projektów takich systemów. Jest to proces zbierania i oceniania dowodów w celu określenia czy system informatyczny i związane z nim zasoby właściwie chronią majątek, utrzymują integralność danych i dostarczają odpowiednich i rzetelnych informacji, osiągają efektywnie cele organizacji, oszczędnie wykorzystują zasoby i stosują mechanizmy kontroli wewnętrznej tak aby dostarczyć rozsądnego zapewnienia, że osiągnięte są cele operacyjne i kontrolne oraz,

że chroni się przed niepożądanymi zdarzeniami lub są one na czas wykrywane, a ich skutki na czas korygowane.

- Audyt bezpieczeństwa to coś mniejszego niż audyt informatyczny. Jest to proces testowania organizacji pod kątem jej zdolności do ochrony informacji

- Audyt informacyjny jako diagnoza stanu posiadania strategii biznesowej, ocena jej poprawności oraz ocena jej postrzegania istotnej akceptacji wśród pracowników firmy.

4. **Czy w polskim prawie jest paragraf na włamania**

Tak.

5. **Co zapewnia podpis cyfrowy?**

Podpis elektroniczny jest ekwiwalentem podpisu ręcznego. Technologia zapewnia niezaprzeczalność wystawienia takiego podpisu. Oznacza to jednoznaczność identyfikację transakcji i możliwość kontroli nienaruszalności danych podczas transmisji. Podpis cyfrowy polega na dodawaniu unikatowych danych do dokumentu w taki sposób, że generować je może jedynie właściciel klucza prywatnego, ale każdy kto posiada odpowiedni klucz publiczny może weryfikować autentyczność takiego podpisu.

6. **Dokument „polityka bezpieczeństwa” jaka powinien mieć klauzulę tajności?**

Jawny i ogólnodostępny.

7. **Metody uwierzytelnienia pracowników?**

1. weryfikacja przedmiotu posiadanego przez użytkownika (przepustka).
2. weryfikacja cech fizycznych użytkownika (odcisk palca, oko, długość fallusa)
3. weryfikacja wiedzy użytkownik (piny, hasła)

8. **Pytanie o zasadę wiedzy koniecznej?**

Każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji (danych), które wynikają z jego obowiązków, np. prezes firmy ma prawo dostępu do wszystkich danych i ich zestawień na odczyt, ale nie ma prawa żadnych danych modyfikować.

9. **Common criteria.**

Trzyczęściowa norma międzynarodowa ISO/IEC 15408.

1. Mają na celu ujednolicenie programu informatycznego pod względem bezpieczeństwa
2. Nie zalecają żadnej z metodyk projektowania i wytwarzania systemów informatycznych
3. Są katalogiem schematów konstrukcji wymagań związanych z ochroną wymiany informacji.
4. Mogą być stosowane zarówno do produktów programowych jak i sprzętowych w informatyce
5. Są przeznaczone dla użytkowników projektantów

10. **Czego dotyczy norma 27001**

Jest ona specyfikacją systemów zarządzania bezpieczeństwem informacji na zgodność, z którą będą wydawane certyfikaty. W normie ISO/IEC 27001 wyróżniono jedenaście obszarów mających wpływ na bezpieczeństwo informacji w organizacji:

1. Polityka bezpieczeństwa
2. Organizacja bezpieczeństwa informacji
3. Zarządzanie aktywami
4. Bezpieczeństwo zasobów ludzkich
5. Bezpieczeństwo fizyczne i środowiskowe
6. Zarządzanie systemami i sieciami
7. Kontrola dostępu
8. Zarządzanie ciągłością działania

9. Pozyskiwanie, rozwój i utrzymanie systemów teleinformatycznych
10. Zarządzanie incydentami związanymi z bezpieczeństwem informacji
11. Zgodność z wymaganiami prawnymi i własnymi standardami

11. Atrybuty informacji związane z jej bezpieczeństwem

1. tajność – termin ten oznacza, że dostęp do określonych danych i informacji posiadają wyłącznie uprawnione osoby
2. integralność – termin ten oznacza, że dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji
3. dostępność – termin ten charakteryzuje system informatyczny i oznacza dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika
4. inne atrybuty w literaturze - rozliczalność

Zest. 6.

1. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

2. czego dotyczy norma ISO27001

Jest specyfikacją systemów zarządzania bezpieczeństwem informacji na zgodność z którą mogą być prowadzone audyty, na podstawie których są wydawane certyfikaty.

W normie ISO/IEC 27001 wyróżniono jedenaście obszarów, mających wpływ na bezpieczeństwo informacji w organizacji:

12. Polityka bezpieczeństwa;
13. Organizacja bezpieczeństwa informacji;
14. Zarządzanie aktywami;
15. Bezpieczeństwo zasobów ludzkich;
16. Bezpieczeństwo fizyczne i środowiskowe;
17. Zarządzanie systemami i sieciami;
18. Kontrola dostępu;
19. Zarządzanie ciągłością działania;
20. Pozyskiwanie, rozwój i utrzymanie systemów informatycznych;
21. Zarządzanie incydentami związanymi z bezpieczeństwem informacji;
22. Zgodność z wymaganiami prawnymi i własnymi standardami.

3. Czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

4. Jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa

niejawny, dokument do użytku wewnętrznego

„Instrukcja bezpieczeństwa teleinformatycznego ... zawiera zasady postępowania w zakresie bezpieczeństwa teleinformatycznego dla osób korzystających z systemów teleinformatycznych; **dokument do użytku wewnętrznego.**”

5. Jaki poziom ochrony powinien mieć dokument polityka bezpieczeństwa

jawny

„Zawiera najważniejsze ogólne ustalenia dotyczące działania firmy/instytucji w zakresie ochrony informacji”

6. jakie klauzule odpowiadają tajemnicy państwowej.

Informacje niejawne zaklasyfikowane jako stanowiące tajemnicę państwową oznaczają się klauzulą:

ściśle tajne - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować istotne zagrożenie dla niepodległości, nienaruszalności terytorium albo polityki zagranicznej lub stosunków międzynarodowych Rzeczypospolitej Polskiej albo zagrażać nieodwracalnymi lub wielkimi stratami dla interesów obronności, bezpieczeństwa państwa i obywateli lub innych istotnych interesów państwa, albo narazić je na szkodę w wielkich rozmiarach,

tajne - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować zagrożenie dla międzynarodowej pozycji państwa, interesów obronności, bezpieczeństwa państwa i obywateli, innych istotnych interesów państwa albo narazić je na znaczną szkodę.

7. jakie klauzule odpowiadają tajemnicy służbowej

Informacje niejawne zaklasyfikowane jako stanowiące tajemnicę służbową oznacza się klauzulą:

poufne - w przypadku gdy ich nieuprawnione ujawnienie powodowałoby szkodę dla interesów państwa, interesu publicznego lub prawnie chronionego interesu obywateli,

zastrzeżone - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować szkodę dla prawnie chronionych interesów obywateli albo jednostki organizacyjnej.

8. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje

zasada wiedzy koniecznej (Skrypt 113)???

9. hoax - co to jest

Z ang: głupi żart; głupi kawał; głupi dowcip

Fałszywka (hoax) to wykorzystanie ludzkiej niewiedzy do rozprzestrzenienia podanej informacji. Polega to na tym, że użytkownik otrzymuje wiadomość (poprzez sieć, telefonicznie czy podczas rozmowy) o pewnym zdarzeniu powodującą podjęcie przez niego określonego działania. Może to być np. otrzymanie maila z wiadomością, że plik o podanej nazwie jest wirusem i można się go pozbyć jedynie poprzez usunięcie tego pliku. W rzeczywistości plik nie jest wirusem i może być nawet częścią systemu operacyjnego, a jego usunięcie może spowodować nieprzewidziane skutki. Użytkownik najczęściej zastosuje się do wskazówek zawartych w otrzymanej wiadomości i w dobrej wierze rozpowszechni ją dalej (w przypadku maili spowoduje to niepotrzebny wzrost generowanego w sieci ruchu). Oprócz wywołania zamieszania fałszywki mogą również przyczynić się do poniesienia szkód (np. otrzymanie wiadomości o awarii serwera i prośbie o wysłanie hasła do konta na podany adres). Walczyć z takimi fałszywymi alarmami jest szczególnie trudno gdyż nigdy nie ma 100% pewności czy są one prawdziwe czy nie. Najlepiej jest mieć ograniczone zaufanie do podejrzanych i pochodzących z niepewnych źródeł wiadomości i sprawdzać ich wiarygodność w serwisach antywirusowych.

10. Miara bezpieczeństwa w common criteria.

Common Criteria (norma ISO 15408) - norma pozwalająca w sposób formalny weryfikować bezpieczeństwo systemów teleinformatycznych.

CC udostępnia procedury pozwalające na zdefiniowanie zagrożeń oraz zabezpieczeń, które na te zagrożenia odpowiadają, a następnie przeprowadzenie formalnej weryfikacji ich faktycznego działania w produkcie. Certyfikacją według normy CC zajmują się niezależne, akredytowane laboratoria badawcze na całym świecie.

Wynikiem procesu certyfikacji jest tzw. "profil ochrony" (PP - *protection profile*), który definiuje zabezpieczenia stosowane przez produkt oraz certyfikat, potwierdzający ich faktyczną skuteczność. Proces certyfikacji może być prowadzony według różnych poziomów szczegółowości i weryfikacji formalnej (EAL - *Evaluation Assurance Level*), począwszy od EAL1 (tylko testy funkcjonalne) aż do EAL7 (formalna weryfikacja projektu oraz testy).

Posiadanie certyfikatu CC *nie gwarantuje* że produkt jest bezpieczny pod każdym względem - zapewnia jedynie o działaniu wszystkich *zadeklarowanych* przez producenta zabezpieczeń. Sam certyfikat niewiele więc mówi bez profilu ochrony opisującego zastosowane zabezpieczenia. Dla popularnych produktów (np. bezpieczne urządzenie do składania podpisu elektronicznego) istnieją ustandaryzowane profile ochrony.

Starszą, ale nadal stosowaną w certyfikacji normą tego typu jest ITSEC.

10b. Co zapewnia Common Criteria i standard ISO/IEC 15408 ?

Odpowiedni poziom zaufania.

11. Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność (Skrypt 124)

W szerszym rozumieniu podpis elektroniczny posiada cztery główne cechy:

autentykacja – uniemożliwienie podszywania się pod daną osobę i wysłania w jej imieniu przesyłki, np. zlecenia dokonania przez bank operacji;

integralność – zapewnienie wykrywalności wszelkiej zmiany w danych przesyłki, zlecenia na drodze od nadawcy do odbiorcy i podczas przechowywania jej u odbiorcy;

autoryzacja – zapewnienie niemożliwości wyparcia się podpisu i treści przesyłki (zlecenia) przez autora;

umożliwienie weryfikacji podpisu przez osobę niezależną.

12. Czy w prawie karnym jest paragraf za włamanie komputerowe

Tak (Skrypt 96 – 99)

12. Jaka norma jest od Systemu zarządzania bezpieczeństwem

Pytanie 2 - norma ISO27001

13. Różnica pomiędzy pełnym audytem informatycznym , a audytem bezpieczeństwa teleinformatycznego

Audyt – [ocena](#) danej [osoby](#), [organizacji](#), [systemu](#), [procesu](#), [projektu](#) lub [produktu](#). Audyt jest przeprowadzany w celu upewnienia się co do prawdziwości i rzetelności [informacji](#), a także oceny systemu [kontroli wewnętrznej](#).

Standard COBIT (Control Objectives for Information and Related Technology) opracowany i rozwijany w ramach ISACA (Information Systems Audit and Control Association). Standard ten zawiera "Control Objectives", czyli tak zwane Punkty Kontrolne, gdzie określone są 302 szczegółowe wymagania przypisane do 34 procesów przebiegających w systemie informatycznym. Jeżeli audyt będzie dotyczył wszystkich procesów, ocenionych zarówno przez pryzmat pierwszo jak i drugorzędnych kryteriów, będzie to pełny audyt informatyczny. Jeżeli procesy będą oceniane tylko wg wybranych kryteriów, np. poufności, integralności i dostępności to możemy mówić o audycie bezpieczeństwa informatycznego. Audyt bezpieczeństwa inf. jest tylko częścią audytu informatycznego

Pełny audyt informatyczny jest nadzbiorem audytu bezpieczeństwa teleinformatycznego

14. Na czym bazuje autoryzacja dostępu

- na przedmiocie posiadanym przez osobę autoryzowaną (przepustka)
- cechach fizycznych (odcisk palca, skan siatkówki oka)
- jego wiedzy (PIN, hasło)

15. Do czego wykorzystywany jest outsourcing?

Transfer ryzyka

Outsourcing – wykorzystywanie zasobów zewnętrznych, zlecanie wyspecjalizowanym podmiotom zewnętrznym procesów niezbędnych dla funkcjonowania własnego przedsiębiorstwa, które zostaną tam zrealizowane efektywniej niż byłoby to możliwe we własnym zakresie. Outsourcing jest częścią szerszego zagadnienia - strategii przedsiębiorstwa w obszarze [sourcingu](#).

Zwykle dotyczy to zadań pomocniczych, nie związanych bezpośrednio z uzyskiwaniem [dochodu](#). Współcześnie bardzo często outsource'owane są [usługi ochroniarskie](#), [prawnicze](#), [informatyczne](#), księgowe, rekrutacyjne, wynajem pracowników (outsourcing personalny), utrzymywanie czystości itd. Niektóre firmy idą znacznie dalej, outsource'ując np. support lub część [produkcji](#). Wśród dużych zachodnich [koncernów](#) rozpowszechniła się praktyka outsource'owania znacznej części produkcji do krajów o tańszej sile roboczej, zwłaszcza do krajów [azjatyckich](#) – szczególną popularnością cieszą się usługi firm [hinduskich](#).

Najczęstszą przyczyną wprowadzania praktyk outsourcingowych jest chęć obniżenia kosztów i uniknięcia sytuacji [korupcyjnych](#).

16. Metody uwierzytelniania pracowników

Weryfikacja z elem. z pytania 14

17. Co nie jest plikiem systemowym NTFS

\$Sector.

Zest. 7.

1. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

2. czego dotyczy norma ISO27001

Jest specyfikacją systemów zarządzania bezpieczeństwem informacji na zgodność z którą mogą być prowadzone audyty, na podstawie których są wydawane certyfikaty.

W normie ISO/IEC 27001 wyróżniono jedenaście obszarów, mających wpływ na bezpieczeństwo informacji w organizacji:

1. Polityka bezpieczeństwa;
2. Organizacja bezpieczeństwa informacji;
3. Zarządzanie aktywami;
4. Bezpieczeństwo zasobów ludzkich;
5. Bezpieczeństwo fizyczne i środowiskowe;
6. Zarządzanie systemami i sieciami;
7. Kontrola dostępu;
8. Zarządzanie ciągłością działania;
9. Pozyskiwanie, rozwój i utrzymanie systemów informatycznych;
10. Zarządzanie incydentami związanymi z bezpieczeństwem informacji;
11. Zgodność z wymaganiami prawnymi i własnymi standardami.

3. Czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

4. Jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa

niejawny, dokument do użytku wewnętrznego

„Instrukcja bezpieczeństwa teleinformatycznego ... zawiera zasady postępowania w zakresie bezpieczeństwa teleinformatycznego dla osób korzystających z systemów teleinformatycznych; **dokument do użytku wewnętrznego.**”

5. Jaki poziom ochrony powinien mieć dokument polityka bezpieczeństwa

jawny

„Zawiera najważniejsze ogólne ustalenia dotyczące działania firmy/instytucji w zakresie ochrony informacji”

6. jakie klauzule odpowiadają tajemnicy państwowej.

Informacje niejawne zaklasyfikowane jako stanowiące tajemnicę państwową oznacza się klauzulą:

ściśle tajne - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować istotne zagrożenie dla niepodległości, nienaruszalności terytorium albo polityki zagranicznej lub stosunków międzynarodowych Rzeczypospolitej Polskiej albo zagrażać nieodwracalnymi lub wielkimi stratami dla interesów obronności, bezpieczeństwa państwa i obywateli lub innych istotnych interesów państwa, albo narazić je na szkodę w wielkich rozmiarach,

tajne - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować zagrożenie dla międzynarodowej pozycji państwa, interesów obronności, bezpieczeństwa państwa i obywateli, innych istotnych interesów państwa albo narazić je na znaczną szkodę.

7. jakie klauzule odpowiadają tajemnicy służbowej

Informacje niejawne zaklasyfikowane jako stanowiące tajemnicę służbową oznacza się klauzulą:

poufne - w przypadku gdy ich nieuprawnione ujawnienie powodowałoby szkodę dla interesów państwa, interesu publicznego lub prawnie chronionego interesu obywateli,

zastrzeżone - w przypadku gdy ich nieuprawnione ujawnienie mogłoby spowodować szkodę dla prawnie chronionych interesów obywateli albo jednostki organizacyjnej.

8. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje

zasada wiedzy koniecznej (Skrypt 113)???

9. hoax - co to jest

Z ang: głupi żart; głupi kawał; głupi dowcip

Fałszywka (hoax) to wykorzystanie ludzkiej niewiedzy do rozprzestrzenienia podanej informacji. Polega to na tym, że użytkownik otrzymuje wiadomość (poprzez sieć, telefonicznie czy podczas rozmowy) o pewnym zdarzeniu powodującą podjęcie przez niego określonego działania. Może to być np. otrzymanie maila z wiadomością, że plik o podanej nazwie jest wirusem i można się go pozbyć jedynie poprzez usunięcie tego pliku. W rzeczywistości plik nie jest wirusem i może być nawet częścią systemu operacyjnego, a jego usunięcie może spowodować nieprzewidziane skutki. Użytkownik najczęściej zastosuje się do wskazówek zawartych w otrzymanej wiadomości i w dobrej wierze rozpowszechni ją dalej (w przypadku maili spowoduje to niepotrzebny wzrost generowanego w sieci ruchu). Oprócz wywołania zamieszania fałszywki mogą również przyczynić się do poniesienia szkód (np. otrzymanie wiadomości o awarii serwera i prośbie o wysłanie hasła do konta na podany adres). Walczyć z takimi fałszywymi alarmami jest szczególnie trudno gdyż nigdy nie ma 100% pewności czy są one prawdziwe czy nie. Najlepiej jest mieć ograniczone zaufanie do podejrzanych i pochodzących z niepewnych źródeł wiadomości i sprawdzać ich wiarygodność w serwisach antywirusowych.

10. Miara bezpieczeństwa w common criteria.

Common Criteria (norma ISO 15408) - norma pozwalająca w sposób formalny weryfikować bezpieczeństwo systemów teleinformatycznych.

CC udostępnia procedury pozwalające na zdefiniowanie zagrożeń oraz zabezpieczeń, które na te zagrożenia odpowiadają, a następnie przeprowadzenie formalnej weryfikacji ich faktycznego działania w produkcie. Certyfikacją według normy CC zajmują się niezależne, akredytowane laboratoria badawcze na całym świecie.

Wynikiem procesu certyfikacji jest tzw. "profil ochrony" (PP - *protection profile*), który definiuje zabezpieczenia stosowane przez produkt oraz certyfikat, potwierdzający ich faktyczną skuteczność. Proces certyfikacji może być prowadzony według różnych poziomów szczegółowości i weryfikacji formalnej (EAL - *Evaluation Assurance Level*), począwszy od EAL1 (tylko testy funkcjonalne) aż do EAL7 (formalna weryfikacja projektu oraz testy).

Posiadanie certyfikatu CC *nie gwarantuje* że produkt jest bezpieczny pod każdym względem - zapewnia jedynie o działaniu wszystkich *zadeklarowanych* przez producenta zabezpieczeń. Sam certyfikat niewiele więc mówi bez profilu ochrony opisującego zastosowane zabezpieczenia. Dla popularnych produktów (np. bezpieczne urządzenie do składania podpisu elektronicznego) istnieją ustandaryzowane profile ochrony.

Starszą, ale nadal stosowaną w certyfikacji normą tego typu jest ITSEC.

10b. Co zapewnia Common Criteria i standard ISO/IEC 15408 ?

Odpowiedni poziom zaufania.

11. Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność (Skrypt 124)

W szerszym rozumieniu podpis elektroniczny posiada cztery główne cechy:

autentykacja – uniemożliwienie podszywania się pod daną osobę i wysłania w jej imieniu przesyłki, np. zlecenia dokonania przez bank operacji;

integralność – zapewnienie wykrywalności wszelkiej zmiany w danych przesyłki, zlecenia na drodze od nadawcy do odbiorcy i podczas przechowywania jej u odbiorcy;

autoryzacja – zapewnienie niemożliwości wyparcia się podpisu i treści przesyłki (zlecenia) przez autora;

umożliwienie weryfikacji podpisu przez osobę niezależną.

12. Czy w prawie karnym jest paragraf za włamanie komputerowe

Tak (Skrypt 96 – 99)

12. Jaka norma jest od Systemu zarządzania bezpieczeństwem

Pytanie 2 - norma ISO27001

13. Różnica pomiędzy pełnym audytem informatycznym , a audytem bezpieczeństwa teleinformatycznego

Audyt – [ocena](#) danej [osoby](#), [organizacji](#), [systemu](#), [procesu](#), [projektu](#) lub [produktu](#). Audyt jest przeprowadzany w celu upewnienia się co do prawdziwości i rzetelności [informacji](#), a także oceny systemu [kontroli wewnętrznej](#).

Standard COBIT (Control Objectives for Information and Related Technology) opracowany i rozwijany w ramach ISACA (Information Systems Audit and Control Association). Standard ten zawiera "Control Objectives", czyli tak zwane Punkty Kontrolne, gdzie określone są 302 szczegółowe wymagania przypisane do 34 procesów przebiegających w systemie informatycznym. Jeżeli audyt będzie dotyczył wszystkich procesów, ocenionych zarówno przez pryzmat pierwszo jak i drugorzędnych kryteriów, będzie to pełny audyt informatyczny. Jeżeli procesy będą oceniane tylko wg wybranych kryteriów, np. poufności, integralności i dostępności to możemy mówić o audycie bezpieczeństwa informatycznego. Audyt bezpieczeństwa inf. jest tylko częścią audytu informatycznego

Pełny audyt informatyczny jest [nadzbiorem](#) audytu bezpieczeństwa teleinformatycznego

14. Na czym bazuje autoryzacja dostępu

- na przedmiocie posiadanym przez osobę autoryzowaną (przepustka)
- cechach fizycznych (odcisk palca, skan siatkówki oka)
- jego wiedzy (PIN, hasło)

15. Do czego wykorzystywany jest outsourcing?

Transfer ryzyka

Outsourcing – wykorzystywanie zasobów zewnętrznych, zlecanie wyspecjalizowanym podmiotom zewnętrznym procesów niezbędnych dla funkcjonowania własnego przedsiębiorstwa, które zostaną tam zrealizowane efektywniej niż byłoby to możliwe we własnym zakresie. Outsourcing jest częścią szerszego zagadnienia - strategii przedsiębiorstwa w obszarze [sourcingu](#).

Zwykle dotyczy to zadań pomocniczych, nie związanych bezpośrednio z uzyskiwaniem [dochodu](#). Współcześnie bardzo często outsource'owane są [usługi ochroniarskie](#), [prawnicze](#), [informatyczne](#), księgowe, rekrutacyjne, wynajem pracowników (outsourcing personalny), utrzymywanie czystości itd. Niektóre firmy idą znacznie dalej, outsource'ując np. support lub część [produkcji](#). Wśród dużych zachodnich [koncernów](#) rozpowszechniła się praktyka outsource'owania znacznej części produkcji do krajów o tańszej sile roboczej, zwłaszcza do krajów [azjatyckich](#) – szczególną popularnością cieszą się usługi firm [hinduskich](#).

Najczęstszą przyczyną wprowadzania praktyk outsourcingowych jest chęć obniżenia kosztów i uniknięcia sytuacji [korupcyjnych](#).

16. Metody uwierzytelniania pracowników

Weryfikacja z elem. z pytania 14

17. Co nie jest plikiem systemowym NTFS

\$Sector.

Zest. 8.

1. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

2. czego dotyczy norma ISO27001

>3. czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

4. jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa jawny

5. jakie klauzule odpowiadają tajemnicy państwowej

tajność , ścisła tajność

6. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje

zasada wiedzy koniecznej ((??) Skrypt 113)

7. hoax - co to jest

(tu nie wiem jakie były możliwości, wg wikipedii hoax to mistyfikacja 😊)

1. Miara bezpieczeństwa w common criteria (norma iso 15194 czy jakoś tak) - jest to poziom uzasadnionego zaufania.

2. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

3. Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność (Skrypt 124)

4. Zasada dostępu tylko do takich informacji przez pracownika , które mu są w tej chwili potrzebne to:

zasada wiedzy koniecznej (Skrypt 113)

5. Czy w prawie karnym jest paragraf za włamania komputerowe

Tak (Skrypt 96 – 99)

6. Jaka norma jest od Systemu zarządzania bezpieczeństwem

norma ISO27001

7. Różnica pomiędzy pełnym audytem informatycznym , a audytem bezpieczeństwa teleinformatycznego

różnica jest taka że pełny audyt jest nadzbiorem audytu bezpieczeństwa.

8. Jakie etykiety ma wiadomość sklasyfikowana jako tajemnica państwowa tajność , ścisła tajność

9. Jaki powinien być dokument "Planowania bezpieczeństwa dla ..."

powinien być jawny.

10. Na czym bazuje autoryzacja dostępu

na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

Dla testu B

1. atrybuty informacji: **(tajność, integralność, dostępność)**
2. czy w polskim prawie karnym jest paragraf na włamania **(tak)** (chyba par. 255k.k. <- poza konkursem)
3. jaki poziom ochrony powinien mieć dokument polityka bezpieczeństwa **(jawny)**
4. w teście B zad 1 coś z normą PN/ISO xxxx45 odpowiedź **a)** (najmniej pasująca)
5. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje **(zasada wiedzy koniecznej)**
6. weryfikacja tożsamości użytkownika na podstawie **rzeczy** (np klucz), **cech fizycznych** (np odcisk palca, zdjęcie), **wiedzy** (np hasło)
7. było coś z normą PN/ISO 27001 ale nie pamiętam już co.
8. Nie pamiętam pytania, to jest konkluzja -> **Pełny audyt informatyczny jest nadzbiorem audytu bezpieczeństwa teleinformatycznego**

Zest. 9.

1. Co to jest informacja

Informacja – obiekt abstrakcyjny, który może zwiększyć obszar wiedzy.

Z teorii informacji to miara niepewności zajścia pewnego zdarzenia ze zbioru skończonego zdarzeń prawdziwych.

2. Co to jest bezpieczeństwo informacji

slajd 94 +

W obecnych czasach, instytucje niezależnie od profilu działalności wytwarzają, przechowują, przetwarzają i przesyłają informacje wrażliwe, których nieuprawnione ujawnienie lub zniszczenie może spowodować poważne szkody dla osoby fizycznej lub instytucji.

Przykładem informacji wrażliwej mogą być informacje stanowiące tajemnicę państwową lub służbową, dane osobowe, hasła użytkowników systemów informatycznych oraz informacje dotyczące działań instytucji. W odniesieniu do bezpieczeństwa systemów teleinformatycznych informacja jest przedmiotem, którym należy właściwie zarządzać i chronić go.

Ochrona danych przed nieuprawnionym, przypadkowym, umyślnym ujawnieniem, modyfikacją lub zniszczeniem opiera się na spełnieniu aspektów bezpieczeństwa, jakimi są:

- poufność,
- integralność,
- dostępność,
- spójność danych.

Poufność oznacza stan w którym informacje wrażliwe mogą zostać odczytane tylko przez uprawnione osoby.

Integralność danych oznacza, że pochodzą one z wiarygodnego źródła, są kompletne i poprawne, ich modyfikacji dokonują osoby upoważnione.

Dostępność to zapewnienie, że uprawnieni użytkownicy mają dostęp do zasobów systemu informatycznego, kiedy zachodzi taka potrzeba.

Spójność danych dotyczy poprawności baz danych i wiąże się z właściwym ich zarządzaniem oraz odpornością na awarie środowiska sprzętowo-programowego oraz anomalie wynikające z rozproszenia baz danych.

Powszechnie bezpieczeństwo kojarzy się z niezakłóconą pracą systemów, jednak należy przy tym pamiętać, że zakłócić może ją wiele czynników. Źródłem zagrożenia może być niepowołany dostęp do zasobów nie tylko z zewnątrz, ale i od wewnątrz sieci korporacyjnej. Ze względu na rodzaj zagrożenia, wyróżniamy ataki aktywne i pasywne. Ataki aktywne dążą do modyfikacji strumienia informacji lub tworzenia fałszywych informacji, np. podszywanie się pod osobę uprawnioną i blokowanie działania. Ataki pasywne polegają na podsłuchiwanie i monitorowaniu przesyłanych informacji, np. dążenie do ujawnienia treści wiadomości.

Utrzymanie wysokiego poziomu bezpieczeństwa strategicznych zasobów systemu informatycznego wymaga między innymi:

- dokonania klasyfikacji zasobów poprzez określenie stopnia ich wrażliwości;
- stałego monitorowania i okresowego badania stanu zabezpieczenia wszystkich elementów systemu;

- doboru i wdrożenia odpowiednich sprzętowo-programowych rozwiązań, takich jak system zaporowy, systemy wykrywania włamań, system antywirusowy;
- zastosowania środków ochrony mających wpływ na zwiększenie niezawodności sprzętu oraz umożliwiających odtworzenie stanu systemu po awarii;
- przeszkolenia użytkowników sieci korporacyjnej w zakresie przeciwdziałania i wykrywania naruszeń bezpieczeństwa informatycznego;
- podnoszenia kwalifikacji administratorów systemów poprzez specjalistyczne szkolenia z zakresu bezpieczeństwa teleinformatycznego.

W celu zapewnienia niezawodności w działaniu wdrożonego systemu bezpieczeństwa i stworzenia możliwości spełnienia powierzonych roli, należy go systematycznie aktualizować. Wdrożone systemy zaporowy lub antywirusowy, które nie posiadają uaktualnień wersji i łatek, stają się podatne na wszelkiego rodzaju ataki ze strony hakerów. Sytuacja taka powoduje naruszenie aspektów bezpieczeństwa, jakimi są: poufność, integralność, dostępność i spójność danych znajdujących się w sieci.

Ventus Communications kładzie szczególny nacisk na bezpieczeństwo danych w projektowanych przez siebie sieciach. Opracowujemy kompleksową politykę bezpieczeństwa systemów teleinformatycznych przedsiębiorstwa obejmującą podstawowe założenia bezpieczeństwa oraz szczegółowe procedury dla każdego z użytkowników. W naszej ofercie posiadamy produkty pozwalające na stworzenie kompleksowego systemu zabezpieczeń każdego przedsiębiorstwa. Z dostępnych na rynku rozwiązań wybraliśmy te o najlepszych referencjach tak, aby realizowane przez nas systemy były niezawodne i funkcjonalne.

3. Jakie są skutki zawyżania klauzuli tajności

Nieuzasadnione podwyższanie klauzul tajności powoduje:

- utrudnienia w przetwarzaniu danych,
- zwiększone koszty budowy systemu bezpieczeństwa informacyjnego, znacznie zwiększone koszty eksploatacyjne, szkoleniowe, itd.,
- ograniczone możliwości współdziałania z innymi systemami informatycznymi,
- niemożliwość wykonania wielu uzasadnionych zadań przetwarzania bez naruszenia ustawy,
- narażenie pracowników na świadome lub nieświadome (przy braku odpowiednich mechanizmów) naruszenie ustawy,

4. Co to jest zagrożenie pasywne i zagrożenie aktywne

Zagrożenie aktywne - dowolne zagrożenie związane z zamierzoną, nieuprawnioną zmianą stanu systemu przetwarzania danych.

Zagrożenia zamierzone:

- a. nielegalne , świadome działania własnych pracowników
- b. działania użytkowników wykraczające poza ich obowiązki
- c. działania przestępców komputerowych
- d. szpiegostwo gospodarcze i wojskowe
- e. wandalizm , terroryzm , sabotaż

Zagrożenie pasywne - nie będące skutkiem celowego działania.

Zagrożenia niezamierzone:

- a. zagrożenia losowe
- b. zagrożenia związane z niedostatkami organizacyjnymi
- c. zagrożenia związane z błędem człowieka
- d. Zagrożenia techniczne (awarie)

Źródła zagrożeń

- użytkownicy:
 - wewnątrzni:
 - akty wewnętrznego sabotażu
 - kradzież informacji
 - kradzież usług
 - błędy użytkowników
 - niedbalstwo
 - nieprawidłowe stosowanie mechanizmów bezpieczeństwa
 - zewnątrzni
- ataki na systemy informatyczne
- wirusy komputerowe
- awarie sprzętu

Przyczyny występowania luk

- błędy na etapie projektowania systemu
 - asymetria polityki bezpieczeństwa i zabezpieczeń
- brak lub wady polityki bezpieczeństwa
 - asymetria polityki bezpieczeństwa i brak kontroli
- błędy w konfiguracji
 - prymat funkcjonalności systemu
- niewłaściwe stosowanie narzędzi
 - Nadmierne zaufanie do narzędzi (ulubionych)
- błędy w oprogramowaniu
 - nie ma oprogramowanie bez błędów
- zaufanie do „uznanych producentów”
 - producent implementuje technologie

5. Co to jest problem bliskości i szkody uboczne

Problem bliskości

Zarówno w świecie realnym, jak i cyberprzestrzeni występuje problem bliskości. Jeśli firma ma siedzibę w biurówcu wraz z innymi instytucjami, dla których ryzyko fizycznego ataku jest większe, firma ta przyjmuje w pewnej części to ryzyko. Takie fizyczne ataki mogą przybierać dowolną formę, od groźby podłożenia bomby do pikietowania, lub może być cokolwiek innego, co ma wpływ na działanie tego przedsiębiorstwa.

Szkody uboczne

Szkoda uboczna to taka, która jest spowodowana przez efekt uboczny towarzyszący danemu incydentowi. Nieraz jest to określane efektami kaskadowymi; zwykle ujawniają się one w systemach uzależnionych od systemów, w których wystąpiły incydenty. Szkoda uboczna jest relatywnie nowym problemem w dziedzinie bezpieczeństwa informacji.

6. Co to jest polityka nakazowa i polityka uszczelniająca

Polityka nakazowa obejmuje zbiór rozwiązań, które wprost wynikają z nakazów prawnych i które muszą być bezwzględnie stosowane.

Polityka uszczelniająca obejmuje zbiór rozwiązań, które decyzją kierownika jednostki organizacyjnej stanowią „wzmocnienie” rozwiązań nakazowych.

7. Na czym polega sterowanie dostępem i sterowanie przepływem, wraz z regułami ochrony

kontrola dostępu / sterowanie dostępem - jest ochroną zasobów przed nieupoważnionymi użytkownikami.

- model Lampsona (macierzy dostępu) 1969
- najczęściej stosowany
- zbiór podmiotów, zbiór obiektów, zbiór reguł dostępu

rozszerzenia:

- identyfikacja osoby tworzącej regułę dostępu
- wskaźnik prawa przekazania prawa dostępu
- reguły dodatkowych warunków dostępu

reguła ochrony - upoważnienie dowolnego żądania dostępu polega na sprawdzeniu w macierzy dostępu czy istnieje reguła dostępu dopuszczająca jego realizację.

- sterowanie przepływem
- korporacja MITRE, 1973
- zbiór obiektów pamięciowych
- zbiór procesów powodujących przepływ danych
- zbiór klas tajności
- relacja przepływu

reguła ochrony - mechanizm sterowania przepływem powinien zabronić realizacji żądań powodujących przepływ danych niezgodnych z określoną relacją przepływu

8. Co to jest polityka bezpieczeństwa

Polityka bezpieczeństwa (ang. *security policy*) jest zbiorem spójnych, precyzyjnych i zgodnych z obowiązującym prawem przepisów, reguł i procedur, według których dana organizacja buduje, zarządza oraz udostępnia zasoby i systemy informacyjne i informatyczne. Określa ona, które zasoby i w jaki sposób mają być chronione.

Polityka powinna obejmować wskazanie możliwych rodzajów naruszenia bezpieczeństwa (jak np. utrata danych, nieautoryzowany dostęp), scenariusze postępowania w takich sytuacjach i działania, które pozwolą uniknąć powtórzenia się danego incydentu. Polityka bezpieczeństwa definiuje ponadto poprawne i niepoprawne korzystanie z zasobów (np. kont użytkowników, danych, oprogramowania).

Istotne jest, aby polityka bezpieczeństwa była dokumentem spisany i znanym oraz zrozumianym przez pracowników organizacji korzystających z zasobów informatycznych. Dotyczy to także klientów organizacji (użytkowników jej zasobów).

Przy projektowaniu polityki należy rozważyć, czy organizacja będzie w stanie ponieść koszty wprowadzania tej polityki w życie. Podwyższanie poziomu bezpieczeństwa organizacji/systemu odbywa się najczęściej kosztem wygody i efektywności działania. Dlatego, opierając się na zalecanych modelach czy standardach w tej dziedzinie, należy pamiętać o dostosowaniu rozwiązania do specyfiki organizacji, tak aby nadać jej cechy ułatwiające zastosowanie w praktyce. Podstawowym zadaniem jest przeprowadzenie analizy ryzyka i ustalenie akceptowalnego poziomu ryzyka - bo tylko wtedy możemy zacząć myśleć o tworzeniu polityki bezpieczeństwa.

Polityka powinna adresować następujące zagadnienia:

- co podlega ochronie ?
 - informacja (dane)
 - systemy teleinformatyczne (sprzęt)
- jak chronimy krytyczne zasoby ?

Projektując mechanizmy ochrony informacji należy określić następujące elementy:

- model bezpieczeństwa
- mechanizmy kontroli dostępu
- poziomy uprawnień (jakie poziomy uprawnień istnieją i jakie są zasady ich przyznawania)
- mechanizmy identyfikacji i zapewnienie autentyczności (na poziomie fizycznym i

systemów)

- śledzenie zdarzeń w systemie (jakie mechanizmy/programy/procedury stosowane są do śledzenia zmian w systemach)

9. Kto wchodzi w skład pionu ochrony danych osobowych

W celu realizacji zadań związanych z ochroną informacji niejawnych kierownicy jednostek organizacyjnych tworzą stanowiska pełnomocników ochrony informacji niejawnych, którym podlegają pionowi ochrony lub wytypowani do tych zadań pracownicy.

Pion ochrony informacji niejawnych jest komórką organizacyjną właściwą do określania i zapewniania przestrzegania zasad ochrony informacji niejawnych, a także ich eksploatacji, jak również bezpieczeństwa systemów i sieci teleinformatycznych oraz ochrony fizycznej obiektów w danej jednostce organizacyjnej, które wymagają ochrony przed nieuprawnionym dostępem osób postronnych /nieupoważnionych/.

Tworzenia pionu ochrony informacji niejawnych w jednostce organizacyjnej:

– Kierownik jednostki organizacyjnej powołuje na pełnomocnika ochrony osobę, która spełnia następujące wymagania:

- posiada obywatelstwo polskie,
- posiada co najmniej średnie wykształcenie,

- posiada odpowiednie poświadczenie bezpieczeństwa wydane przez służbę ochrony państwa po przeprowadzeniu postępowania sprawdzającego,
 - odbyła przeszkolenie w zakresie ochrony informacji niejawnych.
- Na wniosek pełnomocnika ochrony kierownik jednostki organizacyjnej wyznacza kierownika kancelarii tajnej oraz w razie potrzeby pozostałych pracowników pionu ochrony, którzy spełniają następujące wymagania:
 - posiadają obywatelstwo polskie,
 - posiadają odpowiednie poświadczenie bezpieczeństwa wydane po przeprowadzeniu postępowania sprawdzającego,
 - odbyły przeszkolenie w zakresie ochrony informacji niejawnych.
- Kierownik jednostki organizacyjnej w oparciu o wydzielone środki finansowe tworzy tajną kancelarię w wyodrębnionym pomieszczeniu, zabezpieczonym zgodnie z przepisami o środkach ochrony fizycznej informacji niejawnych (zlokalizowanym w strefie bezpieczeństwa, z wydzieloną wokół strefy bezpieczeństwa strefą administracyjną służącą do kontroli osób i pojazdów, z systemem określającym uprawnienia do wejścia, przebywania i wyjścia ze strefy bezpieczeństwa oraz wyposażeniem i urządzeniami, którym na podstawie odrębnych przepisów przyznano certyfikaty i świadectwa kwalifikacyjne) i obsługiwaną przez pracowników pionu ochrony.
- Pełnomocnik opracowuje instrukcje pracy kancelarii tajnej.
- Kierownik jednostki organizacyjnej określa w zarządzeniu stanowiska oraz rodzaje prac zleconych, z którymi może łączyć się dostęp do informacji niejawnych, odrębnie dla każdej klauzuli tajności dla osób zatrudnionych w podległych komórkach organizacyjnych.
- Pełnomocnik ochrony prowadzi w jednostce organizacyjnej "Wykaz stanowisk i prac zleconych oraz osób dopuszczonych do pracy lub służby na stanowiskach, z którymi wiąże się dostęp do informacji niejawnych, odrębnie dla każdej klauzuli tajności" w oparciu o:
 - zwykłe postępowanie sprawdzające przeprowadzone przez pełnomocnika ochrony na pisemne polecenie kierownika jednostki organizacyjnej wobec osób zatrudnionych w podległych komórkach organizacyjnych,
 - postępowanie sprawdzające przeprowadzone przez służby ochrony państwa na pisemny wniosek kierownika jednostki organizacyjnej wobec osób zatrudnionych w podległych komórkach organizacyjnych.
- Kierownik jednostki organizacyjnej zatwierdza opracowane przez pełnomocnika ochrony, szczegółowe wymagania w zakresie ochrony informacji niejawnych oznaczonych klauzulą "zastrzeżone" w podległych komórkach organizacyjnych.

- Opracowanie przez pion ochrony planu ochrony informacji niejawnych w jednostce organizacyjnej i nadzorowanie jego realizacji.

Do podstawowych zadań pionu ochrony należy:

- organizowanie ochrony informacji niejawnych;
- klasyfikowanie informacji niejawnych;
- udostępnianie informacji niejawnych;
- organizowanie szkolenia na temat ochrony informacji niejawnych;
- ochrona informacji niejawnych w systemach i sieciach teleinformatycznych;
- prowadzenie zwykłych postępowań sprawdzających przed wydaniem poświadczeń bezpieczeństwa do klauzuli "Zastrzeżone" i "Poufne";
- ewidencjonowanie, przechowywanie, przetwarzanie i udostępnianie danych uzyskiwanych w związku z prowadzonym postępowaniem o ustalenie rękami zachowania tajemnicy w zakresie określonym w ankiecie bezpieczeństwa osobowego oraz w ankiecie bezpieczeństwa przemysłowego;
- organizowanie kontroli przestrzegania zasad ochrony informacji niejawnych w jednostce organizacyjnej;
- opracowywanie i opiniowanie planów postępowania z informacjami niejawnymi w razie wprowadzenia stanu nadzwyczajnego;
- organizowanie systemu kontroli dostępu do obiektów i poszczególnych stref bezpieczeństwa oraz nadzorowanie przechowywania i wykorzystywania kluczy i kodów do zamków szyfrowych;
- monitorowanie pomieszczeń objętych specjalną strefą bezpieczeństwa podczas narad, konferencji i odpraw prowadzonych w obiektach jednostki organizacyjnej;
- uczestniczenie w opiniowaniu projektów rozporządzeń oraz projektów programów, analiz i innych dokumentów opracowywanych w jednostce organizacyjnej, a dotyczących ochrony informacji niejawnych;
- nadzorowanie rozdziału środków finansowych przeznaczonych na realizację wspomaganie ochrony i obrony obiektów jednostki organizacyjnej;

Generalny Inspektor Ochrony Danych Osobowych (skr. **GIODO**) - organ do spraw ochrony danych osobowych powoływany na 4-letnią kadencję (liczoną od dnia złożenia przysięgi) przez Sejm RP za zgodą Senatu.

Działa na podstawie ustawy z dnia 29 sierpnia 1997 r. o ochronie danych osobowych. W zakresie wykonywania swoich zadań podlega tylko ustawie. Przysługuje mu immunitet. Kontroluje zgodność przetwarzania danych z przepisami o ochronie danych osobowych, wydaje decyzje administracyjne i rozpatruje skargi w sprawach wykonania przepisów o ochronie danych osobowych, prowadzi rejestr zbiorów danych, opiniuje akty prawne dotyczące ochrony danych osobowych, inicjuje i podejmuje przedsięwzięcia w zakresie doskonalenia ochrony danych osobowych, uczestniczy w pracach międzynarodowych organizacji i instytucji zajmujących się problematyką ochrony danych osobowych (np. Grupy roboczej art. 29).

W celu wykonania swoich zadań ma do pomocy Biuro Generalnego Inspektora Ochrony Danych Osobowych. Siedziba Biura znajduje się w Warszawie.

Generalni Inspektorzy Ochrony Danych Osobowych:

- I kadencja (4 kwietnia 1998 - 26 kwietnia 2002) - Ewa Kulesza
- II kadencja (26 kwietnia 2002 - 13 lipca 2006) - Ewa Kulesza
- III kadencja od 13 lipca 2006 - Michał Serzycki

Zest. 10.

1. atrybuty informacji: (**tajność, integralność, dostępność**)
2. czy w polskim prawie karnym jest paragraf na włamania (**tak**) (chyba par. 255k.k. <- poza konkursem)
3. jaki poziom ochrony powinien mieć dokument polityka bezpieczeństwa (**jawny**)
4. w teście B zad 1 coś z normą PN/ISO xxxx45 odpowiedź **a**) (najmniej pasująca)
5. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje (**zasada wiedzy koniecznej**)
6. weryfikacja tożsamości użytkownika na podstawie **rzeczy** (np klucz), **cech fizycznych** (np odcisk palca, zdjęcie), **wiedzy** (np hasło)
7. było coś z normą PN/ISO 27001 ale nie pamiętam już co.
8. Nie pamiętam pytania, to jest konkluzja -> **Pełny audyt informatyczny jest nadzbiorem audytu bezpieczeństwa teleinformatycznego**
wiecej nie pamiętam

Ad.1

Atrybuty informacji:

Bezpieczeństwo informacji - oznacza zachowanie poufności, integralności i dostępności informacji.

integralność - jest zdefiniowana jako zapewnienie dokładności i kompletności informacji oraz metod jej przetwarzania,

dostępność - jest zdefiniowana jako zapewnienie, że osoby upoważnione mają dostęp do informacji i związanych z nią aktywów wtedy, gdy jest to potrzebne.

Ad.2

TAK (Art. 267)

Ad.3

Dokument powinien być **jawny**.

Ad.4

a) cokolwiek to było:P

b)

Ad.5

zasada wiedzy koniecznej: Pracownik powinien mieć dostęp w określonym zakresie tylko do tych zasobów, których potrzebuje do zakończenia zadania.

Ograniczenie dostępności zasobów zgodnie z zasadą wiedzy koniecznej umożliwia zmniejszenie negatywnych skutków działania procesów błędnych.

Ad.6

Weryfikacja tożsamości użytkownika:

- **rzeczy** (np klucz)

- **cech fizycznych** (np odcisk palca, zdjęcie),

- **wiedzy** (np hasło)

Ad.7

ISO/IEC 27001 to [norma](#), która została opracowana [14 października 2005](#) r. Jest ona specyfikacją systemów zarządzania bezpieczeństwem [informacji](#) na zgodność z którą będą wydawane [certyfikaty](#).

W normie ISO/IEC 27001 wyróżniono jedenaście obszarów, mających wpływ na bezpieczeństwo informacji w organizacji:

1. Polityka bezpieczeństwa;
2. Organizacja bezpieczeństwa informacji;
3. Zarządzanie aktywami;
4. Bezpieczeństwo zasobów ludzkich;
5. Bezpieczeństwo fizyczne i środowiskowe;
6. Zarządzanie systemami i sieciami;
7. Kontrola dostępu;
8. Zarządzanie ciągłością działania;
9. Pozyskiwanie, rozwój i utrzymanie systemów informatycznych;
10. Zarządzanie incydentami związanymi z bezpieczeństwem informacji;
11. Zgodność z wymaganiami prawnymi i własnymi standardami;

Ad.8

różnica jest taka że pełny audyt jest nadzbiorem audytu bezpieczeństwa.

Ad...

klauzule tajemnicy państwowej:

tajność , ścisła tajność

Ad...

Hoax

jeden z kilku rodzajów *łańcuszków email*. Fałszywki to głupie żarty, przesyłane przez dowcipnisiów w formie ważnego ostrzeżenia przed groźnym, rozprzestrzeniającym się błyskawicznie wirusem, mającym, według opisu, bardzo destrukcyjne działanie, a informacja ta rzekomo pochodzi od producentów oprogramowania.

Ad...

Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność

Ad...

Na czym bazuje autoryzacja dostępu

na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

Add..

Miara bezpieczeństwa w common criteria (norma iso 15194 czy jakoś tak) - jest to poziom uzasadnionego zaufania.

Zest. 11.

Zestaw C:

1. Ubezpieczenie zalicza się do....

- kontroli ryzyka
- retencji ryzyka
- **transferu ryzyka**

2. Co się dzieje z plikiem po usunięciu z dysku:

- wpis w \$MFT jest usuwany, dane zostają
- **wpis w \$MFT zostaje, dane zostają i zmieniają się dwie flagi**
- wpis w \$MFT jest usuwany, dane są usuwane
- wpis w \$MFT zostaje, dane zostają

3. W którym dokumencie opisano System zarządzania bezpieczeństwem informacji:

- **ISO 27001**
- ISO 15408

4. Podpis cyfrowy zapewnia:

- **niezaprzeczalność, autentyczność i integralność**

5. Minimalny zestaw wymagań na system zabezpieczeń:

- dywersyfikacja i spójność
- dywersyfikacja, niezaprzeczalność i organizacja wg zasady ochrony "w głąb"
- **dywersyfikacja, niezaprzeczalność, spójność i organizacja wg zasady ochrony "w głąb"**
- dywersyfikacja i organizacja wg zasady ochrony "w głąb" (chyba)

6. Zasada, żeby pracownik do wykonywania pracy miał tylko dostęp do tych programów i usług, których potrzebuje, to:

- **zasada minimalnego środowiska pracy**
- zasada wiedzy koniecznej
- zasada dwóch ludzi

7. Atrybuty informacji w kontekście bezpieczeństwa:

- **poufnosc, integralnosc, dostepnosc**

8. Co tam o audycie bezpieczeństwa teleinformatycznego:

- **zawiera sie w audycie informatycznym**

9. Poprzez sporządzenie i w razie potrzeby wdrożenie planu odzyskiwania:

- minimalizujemy ryzyko
- minimalizujemy zagrożenia
- minimalizujemy podatności
- **minimalizujemy straty wynikłe z wykorzystania podatności przez zagrożenia**

10. Dokument "Polityka bezpieczeństwa dla ..." powinien być:

- **jawny**

1. (dokładnej treści nie pamiętam, ale była dużo dłuższa) Jeśli wyślemy sygnał na port 80 sprawdzający czy jest otwarty i odpowiedź dostaniemy z flagą RST to znaczy, że port jest:
- zamknięty

2. Jeśli uwierzytelniony użytkownik chce dostać się do pliku to proces logicznego sprawdzania czy użytkownik czegoś tam coś tam nazywa się:
- Proces autoryzacji.

Rok 2009

1. Miara bezpieczeństwa w common criteria (norma iso 15194 czy jakoś tak) - jest to poziom uzasadnionego zaufania.

2. Atrybuty informacji - tajemność, dostępność, integralność

3. Cechy podpisu elektronicznego - niesprzeczny, integralny i autentyczny

4. Zasada dostępu tylko do takich informacji przez pracownika, które mu są w tej chwili potrzebne to - zasada wiedzy koniecznej

5. Czy w prawie karnym jest paragraf za włamania komputerowe - Tak

6. Jaka norma jest od Systemu zarządzania bezpieczeństwem - norma 270001 lub 27001 nie pamiętam

7. Różnica pomiędzy pełnym audytem informatycznym, a audytem bezpieczeństwa teleinformatycznego - różnica jest taka że pełny audyt jest nadzbiorem audytu bezpieczeństwa.

8. Jakie etykiety ma wiadomość sklasyfikowana jako tajemnica państwowa - tajność , ścisła tajność

9. Jaki powinien być dokument "Planowania bezpieczeństwa dla ..." - powinien być jawny.

10. Na czym bazuje autoryzacja dostępu - na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

1.Co zapewnia Common Criteria i standard ISO/IEC 15408 ?

Odpowiedni poziom zaufania(odp. Ze słowem „zaufanie”)

2. Do czego wykorzystywany jest outsourcing?

Transfer ryzyka

3. Metody uwierzytelniania pracowników

weryfikacja przedmiotu posiadanego przez użytkownika (przepustka).

weryfikacja cech fizycznych użytkownika (odcisk palca, oko, długość fallusa)

weryfikacja wiedzy użytkownik (piny, hasła)

4.Co zapewnia podpis cyfrowy:

Jednoznaczność, autentyczność...(odpowiedz z największą liczbą wymienionych cech)

5. Czym różni się audyt informatyczny od audytu bezpieczeństwa

Audyt bezpieczeństwa zawiera się w audycie informatycznym.

6.) czy w polskim prawie jest paragraf dotyczący sankcji za włamania informatyczne?

tak

7. "polityka bezpieczeństwa" jaka powinna mieć klauzule tajności?

Jawna

8. w której normie jest mowa o wymaganiach dotyczących bezpieczeństwa

teleinformatycznego

norma 27001

9. Pytanie dotyczące podawania pracownikom informacji

Odp. Zgodnie z zasadą wiedzy koniecznej

10. Atrybuty informacji związane z jej bezpieczeństwem

Tajność, integralność, dostępność

1. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

2. czego dotyczy norma ISO27001

>3. czy w polskim prawie karnym jest paragraf na włamania (?)

TAK (Włamanie do systemu komputerowego jest aktem wandalizmu: Skrypt 96-99)

4. jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa

jawny

5. jakie klauzule odpowiadaja tajemnicy państwowej
tajność , ścisła tajność

6. jak nazywa sie zasada zgodnie z ktora ujawnia sie pracownikowi informacje
zasada wiedzy koniecznej ((??) Skrypt 113)

7. hoax - co to jest
(tu nie wiem jakie były możliwości, wg wikipedii hoax to mistyfikacja 😊)

1. Miara bezpieczeństwa w common criteria (norma iso 15194 czy jakoś tak) - jest to poziom uzasadnionego zaufania.

2. atrybuty informacji (Skrypt 12)

Tajność – dostęp do określonych danych i informacji posiadają tylko uprawnione osoby

Integralność – dane i informacje są poprawne, nienaruszone i nie zostały poddane manipulacji

Dostępność – dostępność danych, procesów i aplikacji zgodnie z wymaganiami użytkownika

3. Cechy podpisu elektronicznego

Integralność, Autentyczność, Niezaprzeczalność (Skrypt 124)

4. Zasada dostępu tylko do takich informacji przez pracownika , które mu są w tej chwili potrzebne to:

zasada wiedzy koniecznej (Skrypt 113)

5. Czy w prawie karnym jest paragraf za włamania komputerowe

Tak (Skrypt 96 – 99)

6. Jaka norma jest od Systemu zarządzania bezpieczeństwem

norma ISO27001

7. Różnica pomiędzy pełnym audytem informatycznym , a audytem bezpieczeństwa teleinformatycznego

różnica jest taka że pełny audyt jest nadzbiorem audytu bezpieczeństwa.

8. Jakie etykiety ma wiadomość sklasyfikowana jako tajemnica państwowa tajność , ścisła tajność

9. Jaki powinien być dokument "Planowania bezpieczeństwa dla ..."

powinien być jawny.

10. Na czym bazuje autoryzacja dostępu

na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

Dla testu B

1. atrybuty informacji: **(tajność, integralność, dostępność)**
2. czy w polskim prawie karnym jest paragraf na włamania **(tak)** (chyba par. 255k.k. <- poza konkursem)
3. jaki poziom ochrony powinien mieć dokument polityka bezpieczeństwa **(jawny)**
4. w teście B zad 1 coś z normą PN/ISO xxxx45 odpowiedź **a)** (najmniej pasująca)
5. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje **(zasada wiedzy koniecznej)**
6. weryfikacja tożsamości użytkownika na podstawie **rzeczy** (np klucz), **cech fizycznych** (np odcisk palca, zdjęcie), **wiedzy** (np hasło)
7. było coś z normą PN/ISO 27001 ale nie pamiętam już co.
8. Nie pamiętam pytania, to jest konkluzja -> **Pełny audyt informatyczny jest nadzbiorem audytu bezpieczeństwa teleinformatycznego**

Cytat:

1. w których windowsach domyślnie włączony jest dziennik zdarzeń?
2. W którym windowsie było logowanie zdarzeń?
3. ile jest well known portów?

Odpowiedzi jakie podałem:

Cytat:

1. vista + win 7
2. (podobno) od 2000 w górze (ME chyba nie bo to jeszcze nie było języko NT tylko podkolorowane 98) czyli 2000, xp, 2003, 2008, vista, 7 itd
3. 1024

1. Ubezpieczenie jest -> transferem ryzyka.
2. Polityka bezpieczeństwa -> dokument jawny.
3. Atrybuty informacji.
4. Cechy podpisu elektronicznego.
5. Pracownicy powinni mieć dostęp do sprzętu, oprogramowania, itp. zgodnie z... zasadą minimalnego środowiska pracy
6. Czy pliki są usuwane całkowicie z dysku...? -> odpowiedź z flagami
7. Audyt informatyczny vs. audyt teleinformatyczny
8. Pytanie o normę PN-ISO/IEC 27001
9. Cechy systemu informatycznego (czy jako tak)
10. Ogólnie chodzi o to, że poprzez plan awaryjny minimalizujemy skutki powstałe na skutek kryzysu.

+++++

Zestaw C:

1. Ubezpieczenie zalicza się do....

kontroli ryzyka
retencji ryzyka
transferu ryzyka

2. Co się dzieje z plikiem po usunięciu z dysku:

wpis w \$MFT jest usuwany, dane zostają
wpis w \$MFT zostaje, dane zostają i zmieniają się dwie flagi
wpis w \$MFT jest usuwany, dane są usuwane
wpis w \$MFT zostaje, dane zostają

3. W którym dokumencie opisano System zarządzania bezpieczeństwem informacji:

ISO 27001
ISO 15408

4. Podpis cyfrowy zapewnia:

niezaprzeczalność, autentyczność i integralność

5. Minimalny zestaw wymagań na system zabezpieczeń:

dywersyfikacja i spójność
dywersyfikacja, niezaprzeczalność i organizacja wg zasady ochrony "w głąb"
dywersyfikacja, niezaprzeczalność, spójność i organizacja wg zasady ochrony "w głąb"
dywersyfikacja i organizacja wg zasady ochrony "w głąb" (chyba)

6. Zasada, żeby pracownik do wykonywania pracy miał tylko dostęp do tych programów i

usług, których potrzebuje, to:
zasada minimalnego środowiska pracy
zasada wiedzy koniecznej
zasada dwóch ludzi

7. Atrybuty informacji w kontekście bezpieczeństwa:

poufność, integralność, dostępność

8. Coś o audycie bezpieczeństwa teleinformatycznego:

zawiera się w audycie informatycznym (jest podzbiorem audytu informatycznego coś takiego)

9. Poprzez sporządzenie i w razie potrzeby wdrożenie planu odzyskiwania:

minimalizujemy ryzyko
minimalizujemy zagrożenia
minimalizujemy podatności
minimalizujemy straty wynikłe z wykorzystania podatności przez zagrożenia

10. Dokument "Polityka bezpieczeństwa dla ..." powinien być:
jawny

Przykładowe pytania sprzed 2 lat dotyczyły (kopia z forum V roku):

1. atrybuty informacji
2. czego dotyczy norma ISO27001
3. czy w polskim prawie karnym jest paragraf na włamania (?)
4. jaki poziom ochrony powinien mieć dokument instrukcja bezpieczeństwa
5. jakie klauzule odpowiadają tajemnicy państwowej
6. jak nazywa się zasada zgodnie z którą ujawnia się pracownikowi informacje
7. hoax - co to jest

Rok 2009

1. Miara bezpieczeństwa w common criteria (norma ISO 15194 czy jakoś tak) - jest to poziom uzasadnionego zaufania.
2. Atrybuty informacji - tajemność, dostępność, integralność
3. Cechy podpisu elektronicznego - niesprzeczny, integralny i autentyczny
4. Zasada dostępu tylko do takich informacji przez pracownika, które mu są w tej chwili potrzebne to - zasada wiedzy koniecznej
5. Czy w prawie karnym jest paragraf za włamania komputerowe - Tak
6. Jaka norma jest od Systemu zarządzania bezpieczeństwem - norma 270001 lub 27001 nie pamiętam
7. Różnica pomiędzy pełnym audytem informatycznym, a audytem bezpieczeństwa teleinformatycznego - różnica jest taka że pełny audyt jest nadzbiorem audytu bezpieczeństwa.
8. Jakie etykiety ma wiadomość sklasyfikowana jako tajemnica państwowa - tajemność, ścisła tajemność
9. Jaki powinien być dokument "Planowania bezpieczeństwa dla ..." - powinien być jawny.
10. Na czym bazuje autoryzacja dostępu - na przedmiocie posiadanym przez osobę autoryzowaną, cechach fizycznych oraz jego wiedzy.

_____ 1. Co zapewnia Common Criteria i standard ISO/IEC 15408? Odpowiedni poziom zaufania (odp. Ze słowem „zaufanie”) 2. Do czego wykorzystywany jest outsourcing? Transfer ryzyka 3. Metody uwierzytelniania pracowników weryfikacja przedmiotu posiadanego przez użytkownika (przepustka). weryfikacja cech fizycznych użytkownika (odcisk palca, oko, długość palca) weryfikacja wiedzy użytkownika (piny, hasła) 4. Co zapewnia podpis cyfrowy: Jednoznaczność, autentyczność... (odpowiedź z największą liczbą wymienionych cech) 5. Czym różni się audyt informatyczny od audytu bezpieczeństwa Audyt bezpieczeństwa zawiera się w audycie informatycznym. 6.) czy w polskim prawie jest paragraf dotyczący sankcji za włamania informatyczne? tak 7. "polityka bezpieczeństwa" jaka powinna mieć klauzule tajemności? Jawna 8. w której normie jest mowa o wymaganiach dotyczących bezpieczeństwa teleinformatycznego norma 27001 9. Pytanie dotyczące podawania pracownikom informacji Odp. Zgodnie z zasadą wiedzy koniecznej 10. Atrybuty informacji związane z jej bezpieczeństwem Tajemność, integralność, dostępność

Proces realizowany przez podsystem kontroli dostępu logicznego systemu komputerowego, gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do pliku, nazywa się:

Wybierz jedną odpowiedź:

- ☐ a. weryfikację uwierzytelnienia
- ☒ b. weryfikację autoryzacji
- ☐ c. weryfikację poziomu ochrony
- ☐ d. weryfikację tożsamości

Odznacz mój wybór

Stosowana w określaniu praw dostępu do informacji zasada, że *każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków*, nazywa się:

Wybierz jedną odpowiedź:

- ☐ a. zasadę dwóch osób
- ☐ b. zasadę rotacji obowiązków
- ☐ c. zasadę minimalnego środowiska pracy
- ☒ d. zasadę wiedzy koniecznej

Odznacz mój wybór

Podstawowe atrybuty informacji związane z jej bezpieczeństwem to:

Wybierz jedną odpowiedź:

- ☒ a. tajność, integralność, dostępność
- ☐ b. integralność, metoda szyfrowania, dostępność
- ☐ c. tajność, integralność, długość (w bajtach)
- ☐ d. tajność, integralność, długość (w znakach)

Dokument *Polityka bezpieczeństwa informacyjnego* powinien być dokumentem zawierającym:

Wybierz jedną odpowiedź:

- ☐ a. szczegółowe plany obiegu informacji i schematy sieci teleinformatycznych
- ☐ b. zapis najważniejszych, ogólnych zamiarów działań kierownictwa organizacji w zakresie bezpieczeństwa własnych i powierzonych informacji i jego deklaracje co do zapewniania odpowiedniego poziomu tego bezpieczeństwa
- ☐ c. instrukcje i procedury dla osób korzystających z systemów teleinformatycznych organizacji
- ☐ d. wykaz stosowanych w organizacji podstawowych zabezpieczeń informacji

Odznacz mój wybór

Norma PN-ISO/IEC-15408 dotyczy

Wybierz jedną odpowiedź:

- ☐ a. sposobów archiwizowania informacji
- ☐ b. klas metod kryptograficznych
- ☒ c. konstrukcji i oceny „bezpiecznych” produktów informatycznych
- ☐ d. systemu zarządzania bezpieczeństwem informacji

Odznacz mój wybór

Podpis cyfrowy ma za zadanie zapewnić:

Wybierz jedną odpowiedź:

- ☐ a. tylko integralność informacji

- ☐ b. tylko poufność i autentyczność informacji
- c. dostępność informacji
- d. niezaprzeczalność, autentyczność, integralność informacji

Odznacz m≤jwb≤i

Zgodnie ustawą z dn. 05.08.2010,0 ochronie informacji niejawnych' Informację niejawną oznacza się klauzulę:

Wybierz jedną odpowiedź:

- ☐ a. „tajne" lub „poufne" lub „zastrzeżone"
- b. „ściśle tajne" lub „tajne" lub „poufne" lub „do użytku wewnętrznego"
- ☒ c. „ściśle tajne" lub „tajne" lub „poufne" lub „zastrzeżone"
- ☐ d. „ściśle tajne" lub „tajne" lub „poufne"

Incydent z zakresu bezpieczeństwa informacyjnego to«

Wybierz jedną odpowiedź:

- ☐ a. stan systemu informacyjnego, który powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- ☒ b. zdarzenie lub ciąg zdarzeń (składających się na realizację zagrożenia) które powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- c. zawsze i tylko rezultat działania cyberprzestępcy
- ☐ d. proces ujawniania podatności w systemie informacyjnym

Odznacz m≤jj&yb≤i

Atak na system informacyjny i informację w nim przetwarzaną jest:

Wybierz jedną odpowiedź:

- ☒ a. zagrożeniem
- ☐ b. sposobem realizacji zagrożenia
- ☐ c. elementem socjotechniki
- ☐ d. narzędziem intruza

Odznacz mdi wyb≤r

Zgodnie ustawą z dn. 05.08.2010.0 ochronie informacji niejawnych* informację niejawną oznacza się klauzulą:

Wybierz jedną odpowiedź:

- ☒ a. „ściśle tajne" lub „tajne" lub „poufne" lub „zastrzeżone"
- ☐ b. „ściśle tajne" lub „tajne" lub „poufne"
- ☐ c. „tajne" lub „poufne" lub „zastrzeżone"
- ☐ d. „ściśle tajne" lub „tajne" lub „poufne" lub „do użytku wewnętrznego"

Odznacz maj wypār

Minimalny zbi≤r cech skutecznego systemu ochrony Informacji przetwarzanej w systemach Informacyjnych obejmuje:

Wybierz jedną odpowiedź:

- ☐ a. dywersyfikację i spójność zastosowanych zabezpieczeń
- ☐ b. dywersyfikację i niesprzeczność zastosowanych zabezpieczeń
- ☒ c. dywersyfikację, spójność, niesprzeczność zastosowanych zabezpieczeń i organizację ochrony „w głgb" d. dywersyfikację oraz spójność zastosowanych zabezpieczeń i organizację ochrony w „w głgb"

Test penetracyjny to:

Wybierz jedną odpowiedź:

☐ a. metoda oddziaływania socjotechnicznego
☐ b. metoda zbierania informacji o badanym systemie
☐ c. to samo, co audyt bezpieczeństwa informacyjnego
☐ d. metoda włamywania się do systemu informatycznego

Odznacz mój wybór

Zgodnie z ustawą z dnia 05.08.2010 r. o ochronie informacji niejawnych informację niejawną oznacza się symbolem

Wybierz jedną odpowiedź

- a. 'tajne' lub 'poufne' lub zastrzeżone*
- b. 'kategorie tajne' lub 'tajne' lub 'poufne' lub 'do użytku wewnętrznego'
- ☒ c. 'Secret' lub 'tajne' lub 'poufne' lub zastrzeżone*
- d. 'informacja tajna' lub 'tajne' lub 'poufne'

Odznacz mój wybór

Incident z zakresu bezpieczeństwa informacyjnego to

Wybierz jedną odpowiedź

a. stan systemu informacyjnego, który powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji

- ☒ b. zdarzenie lub ciąg zdarzeń (składających się z realizacji zagrożenia), które powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji
- c. zawsze i tylko rezultat działania cyberprzestępcy
- d. proces ujawnienia podatności w systemie informacyjnym

Odznacz mój wybór

Czy dane w postaci elektronicznej opatrzone podpisem potwierdzonym profilem zaufanym ePUAP są równoważne pod

względem skutków prawnych dokumentowi opatrzonemu podpisem własnoręcznym:

Wybierz jedną odpowiedź:

☐ a. NIE

☒ b. TAK, chyba że przepisy odrębne stanowią inaczej

Odznacz mój wybór

7. Para (poziom atrybutu, kategoria informacji) wyznacza klasę:

Wybierz jedną odpowiedź:

☐ a. bezpieczeństwa

☐ b. sterowania dostępem

☒ c. uwierzytelniania

☐ d. autoryzacji

Odznacz mój wybór

Proces renowacji systemu kontroli dostępu logicznego systemu komputerowego, gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do punktu nazywa się

Wybierz jedną odpowiedź

a. weryfikacja uwierzytelnienia

☒ b. weryfikacja autoryzacji

c. weryfikację poziomu ochrony d. weryfikacja tożsamości

Odznacz mój wybór

Stosowana w określaniu praw dostępu do informacji zasada że "a/dy procesor ma przydzielono jedynie tak"

prawa i do tych informacji, które wynikają z jego obowiązków, nazywa

się "zasadą rotacji obowiązków". c. zasadę mimimalego Środowiska pracy

☒ d. zasadę wiedzy koniecznej

Odznacz mój wybór

Podstawowe atrybuty informacji związane z jej bezpieczeństwem to

Wybierz jedną odpowiedź

☒ a. tajność, integralność, dostępność b. integralność, metoda szyfrowania, dostępność

c. tajność, integralność, dostępność d. tajność, integralność, dostępność

Odznacz mój wybór

Dokument "Procedury bezpieczeństwa informacyjnego" powinien być dokumentem zawierającym

Wybierz jedną odpowiedź

a. szczegółowe plany obrotu informacją i schematy Md teleinformatycznych

☒ b. zozon najważniejszych, ogólnych zozonów dzion kierownictwo organizacji w zakresie bezpieczeństwa własnych

i powierzonych eWzomocj i jego deklaracje co do zapewnienia odpowiedniego poziomu tego bezpieczeństwa

c. instrukcje i procedury dla osób korzystających z systemów teleinformatycznych organizacji

d. wykaz stosowanych w organizacji podstawowych zabezpieczeń informacji

Odznacz mój wybór

Minimalny zbiór cech skutecznego systemu ochrony informacji przetwarzanej w systemach Informacyjnych obejmuje:

Wybierz jedną odpowiedź:

☐ a. dywersyfikację i spójność zastosowanych zabezpieczeń

☐ b. dywersyfikację i niesprzeczność zastosowanych zabezpieczeń

☒ c. dywersyfikację, spójność, niesprzeczność zastosowanych zabezpieczeń i organizację ochrony .w głąb"

☐ d. dywersyfikację oraz spójność zastosowanych zabezpieczeń i organizację ochrony w .w głqb'

Odznacz mśj _wybśi

Test penetracyjny to:

Wybierz jedną odpowiedź:

☐ a. metoda oddziaływania socjotechnicznego

b. metoda zbierania informacji o badanym systemie

☐ c. to samo, co audyt bezpieczeństwa informacyjnego

☐ d. metoda włamywania się do systemu informatycznego

Odznacz mśj wybśr

Norma PN-ISO/IEC-15408 dotyczy

Wybierz jedną odpowiedź

o sposobSw orchrwizowomo informacji

b kkis metod kryptograficznych

• c konstrukcji i oceny „bezpiecznych” produktSw informatycznych d systemu za'zqdzanie bezpieczeństwem informacji

Odznacz mśj wytx>

Podpis cyfrowy ma za zadanie zapewnić:

Wybierz/ jedną odpowiedź

a ty*o integralność informacji

b tylko poufność i autentyczność informacji

☐ c dostępność informacji

• d niezaprzeczalność, autentyczność, integralność informacji

Odznacz inśi wybśi

TAM GDZIE ODP 100% DOBRZE BĘDĘ OZNACZAŁ

WSZYSTKIE WYZEJ SA NA 100% DOBRZE

Proces realizowany przez podsystem kontroli dostępu logicznego systemu komputerowego, gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do pliku, nazywa się:

weryfikacją autoryzacji

Stosowana w określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków, nazywa się:

zasadą wiedzy koniecznej

Podstawowe atrybuty informacji związane z jej bezpieczeństwem to:

tajność, integralność, dostępność

Dokument Polityka bezpieczeństwa informacyjnego powinien być dokumentem zawierającym:

zapis najważniejszych, ogólnych zamiarów działań kierownictwa organizacji w zakresie bezpieczeństwa własnych i powierzonych informacji i jego deklaracje co do zapewniania odpowiedniego poziomu tego bezpieczeństwa

Norma PN-ISO/IEC-15408 dotyczy:

konstrukcji i oceny „bezpiecznych” produktów informatycznych

Podpis cyfrowy ma za zadanie zapewnić:

niezaprzeczalność, autentyczność, integralność informacji

Zgodnie ustawą z dn. 05.08.2010 „O ochronie informacji niejawnych” informację niejawną oznacza się klauzulą:

„ściśle tajne” lub „tajne” lub „poufne” lub „zastrzeżone”

Incydent z zakresu bezpieczeństwa informacyjnego to:

zdarzenie lub ciąg zdarzeń (składających się na realizację zagrożenia) które powoduje lub może spowodować niepożądaną zmianę wartości istotnych kryteriów jakości informacji

Minimalny zbiór cech skutecznego systemu ochrony informacji przetwarzanej w systemach informacyjnych obejmuje:

dywersyfikację, spójność, niesprzeczność zastosowanych zabezpieczeń i organizację ochrony „w głąb”

Test penetracyjny to:

Metoda zbierania informacji o badanym systemie

PBI:

Test na kartce jednokrotnego wyboru spośród czterech możliwych. 10 pytań. Kilka grup. Za każde pytanie można otrzymać 1 pkt.

Jest to zbiór możliwych pytań z odpowiedziami, które należałoby zweryfikować.

1. W których Windowsach domyślnie włączony jest dziennik zdarzeń?

Odp.: Vista i Windows 7. ok

2. W którym Windowsie było logowanie zdarzeń?

Odp.: (Podobno) od 2000 w górę (ME chyba nie bo to jeszcze nie było jądro NT tylko podkolorowane 98) czyli 2000, XP, 2003, 2008, Vista, 7 itd. ok

3. Ile jest well-known portów?

Odp.: 1024. ok

4. Ubezpieczenie zalicza się do:

Odp.: Transferu ryzyka.

Ubezpieczenie jest bardzo ważną metodą podejmowania ryzyka. Towarzystwa ubezpieczeniowe powstały właśnie po to, by przejmować (w przypadku zakładów wzajemnych dzielić, co tylko w pewnych wypadkach zmienia charakter tej metody podejmowania ryzyka) ryzyka innych podmiotów. Budują one kapitały i metody działania pozwalające na bezpieczną realizację tego celu.

Jednocześnie należy podkreślić, iż z punktu widzenia jakiejkolwiek organizacji ubezpieczenie jest jedną z najgorszych metod podejmowania ryzyka. Ubezpieczenie bowiem może jedynie kompensować i to tylko w określonym, żadko pełnym, zakresie finansowe skutki zdarzeń losowych.

5. Co się dzieje z plikiem po usunięciu z dysku:

Odp.: Wpis w \$MFT zostaje, dane zostają i zmieniają się dwie flagi.

Kasowanie plików nie jest równoznaczne z ich usunięciem z twardego dysku. System tak naprawdę nie kasuje plików, on po prostu zaznacza te pliki jako skasowane. Zostaje wsawiona wartość E5h (liczba w systemie szesnastkowym) jako pierwsza litera nazwy pliku. Jest to taki znacznik systemu informujący, że dany plik został skasowany. Miejsce zajmowane przez dany plik jest dostępne dla innych plików, ale nie jest czyszczone, jest po prostu zostawiane. Jeśli klastry skasowanego pliku nie zostały powtórnie użyte to bardzo łatwo jest odzyskać skasowane pliki.

6. W którym dokumencie opisano System zarządzania bezpieczeństwem informacji:

Odp.: ISO 27001. ok

7. Podpis cyfrowy zapewnia:

Odp.: Niezaprzeczalność, autentyczność i integralność.

8. Minimalny zestaw wymagań na system zabezpieczeń:

Odp.: Dywersyfikacja, niezaprzeczalność, spójność i organizacja wg zasady ochrony "w głąb".

Minimalne wymagania dla systemów teleinformatycznych

9. Zasada, żeby pracownik do wykonywania pracy miał tylko dostęp do tych programów i usług, których potrzebuje, to:

Odp.: Zasada minimalnego środowiska pracy. ok

10. Atrybuty informacji w kontekście bezpieczeństwa:

Odp.: Poufność, integralność, dostępność.

11. Coś tam o audycie bezpieczeństwa teleinformatycznego:

Odp.: Zawiera się w audycie informatycznym (jest podzbiorem audytu informatycznego coś takiego).

12. Poprzez sporządzenie i w razie potrzeby wdrożenie planu odzyskiwania:

Odp.: Minimalizujemy straty wynikłe z wykorzystania podatności przez zagrożenia.

13. Dokument "Polityka bezpieczeństwa dla ..." powinien być:

Odp.: Jawny. ok

14. W Windows XP dzienniki są:

Odp.: Aplikacji, zabezpieczeń, system (domyślnie wyłączone). ok

15. Co jest wyposażeniem teleinformatycznym wg PN-EN ISO/IEC 17025:

Odp.: Nie pamiętam dokładnie, ale najdłuższa odpowiedź (A) w której było oprogramowanie, urządzenia i jeszcze kilka innych rzeczy.

16. Plan bezpieczeństwa powinien być:

Odp.: Dostępny zgodnie z zasadą wiedzy koniecznej.

Na świeżo po zaliczeniu.

Są dwa zestawy - 10 pytań, 15 min. Po skończonym kolosie wszyscy wychodzą a po 10 minutach woła do sali czyta wyniki i ewentualnie jeżeli już jest się po laborkach robi wpisy.

Kilka pytań się powtórzyło z tych z pierwszego postu, ale było też kilka nowych np:

1. jakieś pytania o audyt

odp: wymaga wzorca audytowego i niezależnego wykonawcy

2. pytanie o kolejność wykonywania exploita

odp: mfsconsole->mfsupdate->use exploit<nazwa>->RHOST<ip ofiary>->LHOST<ip intruza>->exploit

3. co to jest promieniowanie ujawniające

odp: (nie jestem pewien) promieniowanie elektromagnetyczne zagrażające poufności informacji w sieci.

Odrębną klasę zagrożeń związanych z podsłuchem stanowi tzw. promieniowanie ujawniające (określane

także jako ulot elektromagnetyczny), czyli promieniowanie elektromagnetyczne emitowane przez sprzęt komputerowy (np. monitory, drukarki), które może być rejestrowane nawet ze znacznych odległości.

4. na czym polega weryfikacja tożsamości użytkownika

odp nie pamiętam dokładnie, ale były 3 czynniki

5. jakieś pytanie o meterpreter

W trzecim trochę inna odpowiedź.

3. co to jest promieniowanie ujawniające?

promieniowanie akustyczne i/lub elektromagnetyczne zagrażające poufności informacji w sieci.

4. na czym polega weryfikacja tożsamości użytkownika?

Weryfikacja cech fizycznych użytkownika; Weryfikacja przedmiotu posiadanego przez użytkownika;

Weryfikacja wiedzy użytkownika;

Poza tym warto wiedzieć:

outsourcing = transfer ryzyka

Zasada dostępu tylko do takich informacji przez pracownika , które mu są w tej chwili potrzebne to:

- zasada wiedzy koniecznej. (pytanie brzmiało trochę inaczej)

Zestaw E

1) Informacja i jej atrybuty

2) Outsourcing

?) Co to UTM?

?) Co to jest RTA>?

?)Promowieniowanie było..

?) Do czego służy firewall?

Moja odp: Do kontrolowania ruchu pakietów w sieci?

10) Gdzie następuje autoryzacja użytkownika systemu komputerowego.

Moja odp: Poza systemem komputerowym.

W grupie C:

-co to jest hoax,

-pytanie o Web Application Firewall

-co to jest kolokacja

Audyt bezpieczeństwa informatycznego (...)

odp.: wymaga wzorca audytowego i musi być wykonany przez podmiot niezależny

Dokument polityka bezpieczeństwa - jawny

Kolejność wykonywania exploita - jak w poprzednich postach, w pytaniu jest mały kruczek - dwie bardzo podobne odp. w jednej RHOST (host intruza) - źle, w drugiej RHOST(host ofiary) - dobrze

Zestaw C :

Kolejność losowa:

1. Informacja - cechy (Poufność, integralność, dostępność.)

2. Island hopping (atakowanie najsłabszego systemu i skakanie na inne)

3. Kolokacja (wynajęcie miejsce sprzęt własny)

4. Dokument w którym opisano System zarządzania bezpieczeństwem informacji (ISO 27001)

5. Ubezpieczenie zalicza się do (transfer ryzyka)

6. Minimalny zestaw wymagań na system zabezpieczeń: (Dywersyfikacja, spójność, niesprzeczność, organizacja wg zasady ochrony "w głąb".)

7. Co zapewnia podpis cyfrowy (Niezaprzeczalność, autentyczność i integralność.)

8. Pytanie z odp : zasada minimalnego środowiska pracy.

9. Pytanie z odp dane wrażliwe

10. Co to jest hoax (poprawna odpowiedź z atakiem socjotechnicznym)

Grupa A:

Odpowiedzi: (na ocenę BDB - 12.04.2017)

- 1.D
- 2.A
- 3.C
- 4.A
- 5.D
- 6.A
- 7.A
- 8.A
- 9.B
- 10.C

Zestaw C:

1. Ubezpieczenie zalicza siä do - transferu ryzyka
2. Co to jest SNORT - IDS/IPS...
3. Atrybuty informacji - poufnoä, integralnoä, dostäpnoä
4. W ktärym dokumencie opisano System Zarzädzenia Bezpieczeästwem Informacji - ISO 27001
5. Podpis cyfrowy zapewnia - niezaprzeczalnoä, autentycznoä, integralnoä
6. Zasada, äeby pracownik, do wykonywania pracy, miaä tylko dostäp do tych programäw i usäug, ktärych potrzebuje to - zasada minimalnego ärodowiska pracy
7. Minimalny zestaw wymagaä na system zabezpieczeä - dywersyfikacja, niezaprzeczalnoä, späjnoä i organizacja wg zasady ochrony "w gä?b"
8. Usäuga kolokacji - udostäpnienie miejsca, wäasny sprzät
9. Co to jest hoax - atak socjotechniczny
10. Pytanie z odpowiedziä - dane wraäliwe

Grupa D:

1. Ubezpieczenie zalicza siä do - transferu ryzyka
2. Co to jest SandBox? Coä äe ärodowiskiem do sprawdzania nieznanego oprogramowania
3. Atrybuty informacji - poufnoä, integralnoä, dostäpnoä
4. Co to jest Recovery Point Object? ['A' byäo, jedyna odpowiedä w cudzysäowie.]
5. Co to jest UTM?
6. Na czym polega hosting? Udostäpnienie centrum danych i sprzätu
7. Na czym polega personal firewall ? Filtracja pakietäw
8. Zapis plikäw, przez tydzień itp. Przyrostowe
9. Co to jest steganografia? Metoda ukrywania informacji
10. Chodziäo o nazwä czegoä, jakiegoä procesu, ktäry wykonuje siä, kiedy uäytkownik chce uzyskaä dostäp do pliku i odpowiedä byäa z autoryzacjä.

grupa F:

- 1) integralnoä, späjnoä i to 3 gäwno
- 2) outsourcing odp. transfer ryzyka
- 3) steganografia -ukrywanie

- 4) Promieniowanie (odp. akustyczne i/lub elektromagnetyczne (odp C))
- 5) klonujemy pliczki, cos tam cos tam: odpowiedź B (przyrostowe)
- 6) firewall co robi - ogarnia pakiety do i z
- 7) UTM - co to/co robi (nie rozwinięcie skrót)
- 8) odp. A
- 9) odp. A (... + uwierzytelnienia)
- 10) zasada Kerchoffa (odp. B, klucz jest tajny a nie shaker)

grupa x:

Rta,

pytania z odp: renetcja ryzyka,

transfer ryzyka,

retencja aktywna,

ePUAP,

utm,

firewall,

audyt,

pytanie o dokumenty jawne lub niejawne,

zadanko ze od pon do cz o 18 jest backup niepelny a w piatek o 18 pelny i jak w czwartek o

17 50 sie zepsuje system to ile dyskow potrzeba z backupem żeby odnowic system - jeden backup = jeden dysk

grupa y:

1. outsourcing

transfer ryzyka

2. informacja atrybuty

integralnosc

dostepnosc

tajnosc

3. stenografia

utajnianie informacji

4. rta time actual

chodzilo o eksperymenty do wyznaczania czasu jakiegos

5. backup taki ze zapisuje raz pelny a potem tylko modyfikacje roznicowy

6. UTM

wielofunkcyjne zapory sieciowe zintegrowane w postaci jednego urządzenia

7. Personal firewall

is an application which controls network traffic to and from a computer

8. ochrona danych osobowych

tylko dla zyjących

9. promieniowanie ujawniające

akustyczne lub elektromagnetyczne

10. zasada ochrony w glab

jak przedostanie sie przez zapore to napotyka druga

grupa z:

1. Podstawowe atrybuty informacji związane z bezpieczeństwem - tajność, integralność, dostępność
2. Dokument polityka bezpieczeństwa powinien być dokumentem zawierającym - zapis najważniejszych ogólnych zamiarów działającego kierownictwa organizacji w zakresie bezpieczeństwa własnym i powierzonych informacji i jego deklaracje w stosunku do zapewnienia bezpieczeństwa
3. Zgodnie z ustawą o ochronie informacji niejawnych informacje nie jawne oznacza się klauzulą - ściśle tajne lub tajne lub poufne lub zastrzeżone
4. Proces realizowany przez podsystem kontroli dostępu logicznego systemu komputerowego gdy uwierzytelniony użytkownik próbuje uzyskać dostęp do pliku nazywa się
 - weryfikacja autoryzacji
5. Norma 27001 dotyczy
 - systemów zarządzania bezpieczeństwem informacji
6. Podpis cyfrowy ma za zadanie zapewnić - nieprzeliczalność autentyczność integralność informacji
7. Stosowana w określaniu praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i takie informacje, które wynikają z jego obowiązków nazywa się
 - zasada wiedzy koniecznej
8. Za pomocą VPN nie da się zabezpieczyć - dostępności
9. Test penetracyjny to metoda zbierania informacji o badanym systemie
10. Minimalny zbiór cech skutecznego systemu ochrony informacji przetwarzanej w systemach informatycznych obejmuje
 - dywersyfikacja, niezaprzeczalność, spójność i organizacja wg zasady ochrony w gęb

grupa m:

1. Czy zastosowanie profilu zaufanego ePUAP w kontaktach z administracją państwową jest równoważne, co do skutków prawnych, użyciu bezpiecznego podpisu elektronicznego weryfikowanego kwalifikowanym certyfikatem? - tak
2. Postępowanie i wdrożenie planu zapewniania ciągłości działania w ramach metod postępowania z ryzykiem to
 - kontrolowania ryzyka
3. Podstawowe atrybuty informacji związane z jej bezpieczeństwem to
 - tajność integralność dostępność
4. Podstawowe metody realizacji operacji uwierzytelniania to samości użytkownika to:
 - weryfikacja przedmiotu posiadanego przez użytkownika, weryfikacja cech fizycznych użytkownika, weryfikacja wiedzy użytkownika
5. Audyt w zakresie bezpieczeństwa informacyjnego
 - wymaga tzw wzorca audytowego i niezależności podmiotu wykonującego audyt
6. Wymagania na system zarządzania bezpieczeństwem informacji (SZBI) są opisane w normie
 - PN-ISO/1EC-27001
7. Promieniowanie ujawniające

- jest promieniowaniem akustycznym i/lub elektromagnetycznym stanowi zagrożenie dla poufności informacji przetwarzanej w systemie komputerowym

8. Stosowanie określania praw dostępu do informacji zasada, że każdy pracownik ma przydzielone jedynie takie prawa i do tych informacji, które wynikają z jego obowiązków nazywa się

- zasada wiedzy koniecznej

9. Czy obowiązuje w Polsce Kodeks Karny przewiduje sankcje za nieuprawnione, szkodliwe działanie wobec systemu komputerowego i informacji w nim przetwarzanej? - tak

10. Dokument Polityka bezpieczeństwa teleinformatycznego dla... powinien być dokumentem

- jawnym